Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет информационных технологий и компьютерной безопасности
Кафедра систем информационной безопасности
Направление подготовки (специальность) 10.05.03 «Информационная безопасность автоматизированных систем»
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА
Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)
Комарчева Александра Викторовича
(фамилия, имя, отчество обучающегося)

Тема: Сценарии реализации и меры противодействия для атак класса «Социальная инженерия»: алгоритмическое и программное обеспечение

Состав выпускной квалификационной работы:
Расчетно-пояснительная записка на 155 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:
Заведующий кафедрой _____ (А.Г. Остапенко)
(подпись) (инициалы, фамилия)

Руководитель _____ (А.С. Щеголеватых)
(подпись) (инициалы, фамилия)

Консультанты:
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

Обучающийся _____ А.В. Комарчев
(подпись) (инициалы, фамилия)

«02» 07 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет информационных технологий и компьютерной безопасности

Кафедра систем информационной безопасности

Направление подготовки/специальность 10.05.03 «Информационная безопасность автоматизированных систем»
(код, наименование)

Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

Утверждаю _____
(дата)

Зав.кафедрой _____
(подпись)

ЗАДАНИЕ

ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Комарчеву Александру Викторовичу
фамилия, имя, отчество

1. Тема: Сценарии реализации и меры противодействуя для атак класса «социальная инженерия»: алгоритмическое и программное обеспечение

утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Глава 1. Исследование предметной области и изучение существующих аналогов, направленных на противодействие угрозам социальной инженерии

Глава 2. Разработка алгоритмического обеспечения для автоматизированного построения, оценки рисков и визуализации сценариев атак класса «Социальная инженерия»

Глава 3. Тестирование разработанного решения

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03.25 - 22.05.25
2	Исследование предметной области и изучение существующих аналогов, направленных на противодействие угрозам социальной инженерии	22.03.25 - 22.05.25
3	Разработка алгоритмического обеспечения для автоматизированного построения, оценки рисков и визуализации сценариев атак класса «Социальная инженерия»	23.05.25 - 31.05.25
4	Тестирование разработанного решения	1.06.25 - 24.06.25
5	Заключение	25.06.25 - 02.07.25

Руководитель _____
(подпись)

Дата выдачи задания 22.03.25

Задание принял к исполнению 22.03.25
(дата)

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающегося Комарчева Александра Викторовича

Тема ВКР: Сценарии реализации и меры противодействия для атак класса «Социальная инженерия»: алгоритмическое и программное обеспечение

Характеристика выпускной квалификационной работы

Актуальность исследования

Актуальность работы обусловлена стремительным ростом числа атак социальной инженерии, использующих персонализированные сценарии, дипфейки и ИИ-модели.

Традиционные меры защиты оказываются недостаточными, что требует разработки автоматизированных инструментов моделирования, оценки рисков и формирования адаптивных мер противодействия, ориентированных на человеческий фактор.

Задачи, решаемые в ВКР

– разработка и реализация алгоритмической модели, обеспечивающею построение сценариев атак класса «социальная инженерия» на основе существующих баз знаний;

– разработка и внедрение программных модулей, позволяющих выполнять автоматизированную оценку рисков сформированных сценариев, учитывающую вероятности реализации и потенциальные последствия атак;

– визуализация и интерпретация сценариев атак, в том числе с использованием взаимодействия с AI-агентом, для последующего формирования регламентов реагирования и противодействия атакам социальной инженерии;

Структура ВКР

Введение – 6 страниц;

Раздел 1. Исследование предметной области и изучение существующих аналогов, направленных на противодействие угрозам социальной инженерии – 11 страниц;

Раздел 2. Разработка алгоритмического обеспечения для автоматизированного построения, оценки рисков и визуализации сценариев атак класса «Социальная инженерия» – 47 страниц;

Раздел 3. Тестирование разработанного решения – 11 страниц;

Заключение – 2 страницы;

Список литературы – 11 страниц;

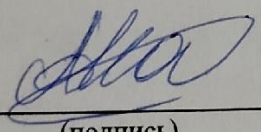
Приложение – 52 страницы.

Краткая характеристика полученных результатов

В ходе работы разработан программный комплекс для автоматизированного построения сценариев атак социальной инженерии с использованием баз знаний CAPEC и MITRE ATT&CK. Реализован механизм агрегации и сопоставления техник, что позволило сформировать обширный набор реалистичных сценариев атак.

Для каждого сценария проводится количественная оценка риска с учётом вероятности, ущерба и уязвимостей, а также реализована визуализация цепочек атак и приоритизация угроз. Это обеспечивает аналитическую поддержку при формировании защитных мер.

Внедрён AI-модуль, формирующий регламенты реагирования на основе анализа сценариев, что повышает адаптивность защиты и расширяет возможности применения комплекса в практических задачах информационной безопасности.

Автор ВКР  Комарчев Александр Викторович

(подпись)

СОДЕРЖАНИЕ

Введение 7

1 Исследование предметной области и изучение существующих аналогов, направленных на противодействие угрозам социальной инженерии 14

1.1 Современные подходы к противодействию атакам социальной инженерии 14

1.2 Анализ сценарного подхода к моделированию атак социальной инженерии ... 18

1.3 Входные сведения об атаках класса «социальная инженерия» 21

1.4 Исследование существующих аналогов 23

2 Разработка алгоритмического обеспечения для автоматизированного построения, оценки рисков и визуализации сценариев атак класса «Социальная инженерия» 27

2.1 Проектирование модуля агрегации данных об атаках класса «Социальная инженерия» 27

2.2 Проектирование модуля анализатора уязвимостей и шаблонов атак 32

2.3 Проектирование модуля оценки рисков сценариев атак класса «Социальная инженерия» 36

2.4 Проектирование модуля визуализации сценариев атак класса «Социальная инженерия» 43

2.5 Проектирование модуля взаимодействия с AI-агентом для формирования регламентов по противодействию атакам класса «Социальная инженерия» 52

2.6 Проектирование модуля конструктора мер защиты 57

2.7 Проектирование взаимодействия модулей в системе 63

3 Тестирование разработанного решения 77

3.1 Тестовая инфраструктура и сценарии тестирования 77

3.2 Оценка производительности и масштабируемости 83

3.3 Выводы о работоспособности системы и направления улучшения 86

Заключение 90

Список литературы 92

Приложение А 103

ВВЕДЕНИЕ

Сегодня обеспечение безопасности в киберпространстве выходит на первый план как для организаций, так и для частных пользователей. Злоумышленники активно совершенствуют свои методы, расширяя инструментальный арсенал: если десять лет назад кибератаки были сосредоточены преимущественно на технических уязвимостях, то теперь всё чаще используются психотехнические приёмы, направленные на целенаправленное обманное воздействие на человека. В 2024 году социальная инженерия использовалась в 50% атак на организации и 88–92% атак на частных лиц:

- по данным на 2024 год социальную инженерию применяли примерно в 98 % всех атак, инфильтрировавших организационные структуры;
- для частных лиц ключевыми каналами стали фишинговые сайты (около 44 %), социальные сети (22 %) и мессенджеры (18 %) — аналогичные данные отмечены в отчётах различных групп;
- в IV квартале 2024 года почти 50 % атак на граждан были нацелены на финансовую выгоду — значительный рост по сравнению с предыдущим годом;
- атаки на организации чаще всего проводились через email-фишинг: поддельные письма с вложениями и QR-кодами (quishing) достигли, по оценкам, порядка 84–88 % всех кейсов [1];
- новый тревожный тренд — вредоносные скрипты, замаскированные под CAPTCHA, запускающие троянов вроде Lumma Stealer [2];
- использование дипфейков и открытые разведданные (OSINT) усиливает персонализированные атаки в мессенджерах, а также уже активно применяются для голосовых и видеоподделок [3];
- рост персонализированных атак с использованием генеративных моделей ИИ отмечается также в отчётах Microsoft и OpenAI, где подчеркивается использование LLM в фишинговых кампаниях [25, 26];

• ожидается, что в ближайшем будущем доля атак с проводимыми в реальном времени дипфейками и синтезированными голосами (vishing) значительно вырастет [4];

• также резко выросло число многоэтапных атак, когда комбинация социальной инженерии и технических уязвимостей создаёт цепочки компрометации.

Учитывая вышесказанное, социальная инженерия стала ключевым инструментом в арсенале киберпреступников. Её популярность обусловлена высокой эффективностью и минимальными затратами на проведение атак. Для организаций главными угрозами остаются утечки и компрометация данных, непредвиденные расходы и сбои в работе — что подтверждается ростом числа атак, связанных именно с человеческим фактором. Частные лица в большей степени подвержены финансовым потерям, мошенничеству и риску кражи личных данных [5].

Уровень научной проработанности темы подтверждается большим количеством фундаментальных исследований и обзоров:

• в рамках академической литературы подробно анализируются нормативно-правовые аспекты использования ИИ в кибербезопасности — затрагиваются вопросы регулирования, ответственности, конфиденциальности и прозрачности алгоритмов, что отражено в сравнительных исследованиях EU AI Act и GDPR/CCPA [6];

• обзоры (около 415 документов) показывают: исследования сгруппированы по направлениям — «атаки» (угрозы, векторы, модели атак) и «защита» (аргументированные рекомендации, технические решения и стандарты) [7];

• в работах подчёркивается, что современные модели ИИ усиливают социальную инженерию — делая атаки более персонализированными, достоверными и труднораспознаваемыми [8];

• исследования побуждают к реализации многоуровневых подходов: объединению технологических мер (например, NIST CSF, ISO/IEC 27001 и CRA) с обучением сотрудников, созданием этических и регулируемых рамок по всему жизненному циклу ИИ-систем [9];

• инициативы Arizona: на международном уровне—ЕС внедрил AI Act (система риск-классификации, обязательств по аудитам и CE-маркировка для ИИ), США —

продвигает технологически ориентированный подход с упором на отраслевые стандарты, а также обсуждает глобальную координацию для гармонизации регуляции.

Все вышеизложенное, говорит о важности данного исследования и необходимостью разработки алгоритмического и программного обеспечения для противодействия атакам, характерной чертой которых является использование человеческого фактора даже при реализации атак посредством технических уязвимостей.

Объект исследования – элементы социо-информационного пространства, такие как мессенджеры, социальные сети, почтовые серверы, а также конечные пользователи и их цифровые учётные записи. Все они представляют собой возможные цели атак социальной инженерии и, вместе, создают область, в которой необходимо использование специализированного ПО для построения механизмов защиты для моделирования угроз.

Предмет исследования – программные модули, а также алгоритмы, которые используются для выявления, классификации и оценки сценариев атак класса «социальная инженерия», а также ПО для создания автоматизированных систем противодействия таким атакам с использованием баз знаний, поведенческого анализа и методов визуализации угроз.

Цель исследования – повышение уровня защищённости социо-информационного пространства благодаря созданию алгоритмических и программных инструментов, обеспечивающих автоматизированное построение сценариев атак социальной инженерии, расчет и оценку их рисков, а также формирование адаптивных мер защиты.

Анализ предметной области позволил выявить несколько существенных **противоречий** между:

• необходимостью в автоматизированном формировании сценариев атак социальной инженерии и отсутствием формализованных, алгоритмизируемых баз знаний, интегрируемых в программные средства: есть потребность в формировании всех возможных сценариев реализации атак класса «социальная инженерия» для

последующего изучения и выработки мер противодействия. Однако сет нет формализованных, комплексных, и систематизированных баз знаний, которые встроены в программные средства;

• необходимостью точной оценки рисков атак и отсутствием унифицированных алгоритмов расчёта на уровне сценариев: несмотря на очевидную необходимость оперативной оценки вероятностей реализации атак с использованием конкретных техник и уязвимостей, сейчас нет унифицированных алгоритмов для точного расчёта рисков на уровне отдельных сценариев. Также отсутствуют подходы к определению приоритетов защиты и степени уязвимости систем;

• противоречие между необходимостью в единой архитектуре программного обеспечения для противодействия атакам социальной инженерии и фрагментарностью существующих решений: хотя и существуют отдельные решения и рекомендации, нет единой методологии и программной системы, способной обеспечить оценку, автоматическое выявление, а также визуализацию сценариев атак социальной инженерии с последующим формированием защитных рекомендаций. Это способствует фрагментарности реагирования и понижает актуальность существующих мер безопасности.

Для достижения цели исследования с учетом выявленных противоречий необходимо решить следующие **задачи**:

1. разработать и реализовать алгоритмическую модель, обеспечивающую построение сценариев атак класса «социальная инженерия» на основе существующих баз знаний (CAPEC, MITRE ATT&CK и др.) с учётом актуальных уязвимостей и техники атак;

2. разработать и внедрить программные модули, позволяющие выполнять автоматизированную оценку рисков сформированных сценариев, учитывающую вероятности реализации и потенциальные последствия атак;

3. обеспечить визуализацию и интерпретацию сценариев атак, в том числе с использованием взаимодействия с AI-агентом, для последующего формирования регламентов реагирования и противодействия атакам социальной инженерии.

На защиту выносятся следующие **результаты**:

1. разработан алгоритм и реализован модуль сбора и обработки данных, формирующий полноту входной информации для анализа атак социальной инженерии на основе внешних баз знаний (CAPEC, MITRE ATT&CK и др.);

2. реализованные программные средства расчёта рисков и вероятностей, позволяющие оценивать уязвимости и техники атак, выявлять критические сценарии и формировать обоснованные приоритеты реагирования;

3. разработанный программный модуль визуализации и взаимодействия с AI-агентом, обеспечивающий формирование адаптивных регламентов и рекомендаций по обнаружению, реагированию и ликвидации последствий атак социальной инженерии.

Новизна результатов, полученных в итоге написания работы обусловлена тем, что:

1. разработан алгоритмический подход к построению и моделированию сценариев атак социальной инженерии, основанный на формализованной структуре данных, агрегируемой из внешних источников (CAPEC, MITRE ATT&CK и др.), что позволило впервые реализовать автоматизированное формирование сценариев с учётом логических и поведенческих взаимосвязей;

2. в рамках программного решения реализована интеграция существующих методов оценки рисков, что позволило на практике применить известные принципы анализа для автоматизированной классификации сценариев атак по степени потенциальной опасности;

3. разработан и реализован комплекс модулей, обеспечивающий полный цикл обработки угроз: от сбора и анализа данных до визуализации сценариев атак и формирования адаптивных регламентов реагирования с использованием AI-инструментов.

Практическая ценность работы заключается в следующем:

1. разработанное программное обеспечение может использоваться в учебных и прикладных целях для моделирования сценариев атак класса «социальная инженерия», а также в системах поддержки принятия решений в области информационной безопасности;

2. интеграция существующих подходов к оценке рисков и визуализация сценариев атак позволяет специалистам по ИБ быстрее анализировать возможные векторы вторжений, выявлять критические уязвимости и формировать обоснованные приоритеты реагирования;

3. сформированный программный комплекс обеспечивает единый технологический подход к построению, анализу и визуализации атак социальной инженерии, что делает возможным его применение в организациях различного профиля для повышения устойчивости к подобным угрозам и автоматизации части процессов ИБ.

Теоретическая значимость **результатов** обусловлена следующим:

1. систематизация и алгоритмизация сценариев атак социальной инженерии, выполненные в рамках разработки базы знаний, способствуют более глубокому пониманию логики построения атак и расширяют научные представления о механизмах их реализации в социо-информационном пространстве;

2. программная формализация процессов анализа и визуализации атак, основанная на существующих источниках (CAPEC, MITRE ATT&CK и др.), способствует развитию прикладных аспектов теории информационной безопасности в части моделирования сложных сценариев вторжений;

3. интеграция методов поведенческого и структурного анализа угроз в единую архитектуру программного комплекса вносит вклад в формирование инженерных основ для построения автоматизированных систем оценки и противодействия атакам, ориентированных на человеческий фактор.

1 Исследование предметной области и изучение существующих аналогов, направленных на противодействие угрозам социальной инженерии

1.1 Современные подходы к противодействию атакам социальной инженерии

Социальная инженерия представляет собой один из наиболее сложных и коварных видов киберугроз, поскольку она основывается не на технических уязвимостях программного обеспечения или аппаратного обеспечения, а на манипуляции поведением и восприятием человека. Основной механизм действия таких атак заключается в создании ложного ощущения доверия, авторитета или срочности, что побуждает жертву совершить действия, выгодные злоумышленнику: перейти по вредоносной ссылке, передать конфиденциальную информацию или предоставить доступ к защищённым ресурсам. Именно поэтому противодействие социальной инженерии выходит за рамки исключительно технической защиты и требует комплексного подхода, включающего организационные, технические и интеллектуальные меры.

В настоящее время применяются различные стратегии защиты, каждая из которых ориентирована на свой уровень — от индивидуального пользователя до корпоративных систем. Наиболее традиционным направлением остаются организационно-управленческие меры. Они включают в себя разработку внутренних нормативных документов по информационной безопасности, проведение обучающих мероприятий, внедрение практик цифровой гигиены и регулярные симуляции атак. Сотрудники организаций обучаются правилам безопасного взаимодействия в цифровой среде: как отличать подозрительные письма, как вести себя в случае получения неизвестных запросов, какие действия следует предпринимать при обнаружении потенциального инцидента безопасности. На основе регулярного мониторинга уровня осведомлённости могут корректироваться стратегии обучения, а сама практика построения ИБ-культуры становится непрерывным процессом, дополнительно применяются игровые подходы и микрообучение, как в Terranova и Hoxhunt [29, 30].

Тем не менее, даже самая проработанная система обучения не исключает ошибок, вызванных усталостью, невнимательностью или неочевидностью атакующего воздействия. Именно поэтому всё большее значение приобретают технические средства защиты, направленные на блокировку или ограничение последствий атак социальной инженерии. Среди таких инструментов можно выделить системы фильтрации фишинга в почтовых сервисах, технологии многофакторной аутентификации, инструменты управления доступом (IAM, PAM), а также системы анализа поведения пользователей (UEBA) и реагирования на инциденты (SIEM, SOAR). Интеграция SIEM и SOAR становится основой концепции threat-informed defense, как указано в документации MITRE и работах SafeBreach [27, 28]. Эти технологии позволяют отслеживать аномалии, автоматизировать сбор событий и предпринимать действия до того, как инцидент перерастёт в серьёзную утечку или компрометацию.

Однако технические средства, как правило, функционируют в режиме реактивной защиты и редко способны предугадывать действия атакующего. Большинство решений по-прежнему ограничены реагированием на уже зафиксированные события, а не на моделирование потенциальных векторов атак. Поэтому в последние годы наблюдается рост интереса к аналитическим и моделирующим подходам, позволяющим формировать сценарии атак и оценивать вероятность их реализации до момента инцидента. В этом контексте всё большее значение приобретает использование формализованных баз знаний, таких как MITRE ATT&CK, CAPEC, CWE. Эти базы описывают тактики, техники и процедуры (TTPs), которые злоумышленники применяют в реальных условиях, и могут быть использованы для автоматизированного построения сценариев вторжений.

Аналитические подходы включают в себя не только построение сценариев на основе известных шаблонов, но и оценку их рисков, визуализацию логических связей между этапами атак и формирование рекомендаций по реагированию. Наиболее перспективными являются системы, способные в реальном времени или близком к реальному оценивать критичность сценария, предлагать приоритеты защиты и подстраивать меры безопасности под текущий контекст. Такие инструменты

становятся частью концепции threat-informed defense — обороны, основанной на данных об угрозах. Программные средства, реализующие подобные подходы, позволяют организациям не просто «гасить пожары», а активно предотвращать инциденты путём прогнозирования и анализа потенциальных сценариев вторжений.

На практике применение существующих решений для противодействия атакам социальной инженерии остаётся крайне ограниченным и фрагментарным. Несмотря на наличие таких инструментов, как ATT&CK Navigator, Red Canary, а также частично интегрированных модулей в рамках SIEM-платформ (например, Splunk, QRadar, ArcSight), их функциональные возможности в большинстве случаев не адаптированы под специфику атак, ориентированных на поведенческие и психологические уязвимости. Эти решения изначально разрабатывались для работы с техническими инцидентами, связанными с цифровыми артефактами — логами, индикаторами компрометации, сетевой активностью, вредоносным ПО — и предназначены для автоматической обработки событий на уровне информационной инфраструктуры.

Атаки социальной инженерии, напротив, строятся на манипулировании человеческим поведением, использовании когнитивных и организационных слабостей, а также на эксплуатации доверия, авторитета и недостатка осведомлённости пользователей. Такие угрозы проявляются в виде последовательных поведенческих шагов, которые сложно зафиксировать с помощью традиционных средств мониторинга. Сценарии социальной инженерии часто развиваются во времени и требуют интерпретации контекста взаимодействия между злоумышленником и целью. Это делает существующие инструменты крайне ограниченными: в них отсутствуют модули анализа фишинговых коммуникаций, ложных контекстов, подделки деловой переписки или симуляции доверия, которые являются характерными признаками социальной инженерии.

Кроме того, большая часть существующих решений требует высокой квалификации операторов. Их настройка предполагает ручную конфигурацию источников данных, написание правил корреляции, создание индивидуальных сценариев реагирования. Такие задачи под силу только опытным специалистам в

области информационной безопасности, что существенно ограничивает применимость подобных решений в организациях с низким уровнем зрелости ИБ или ограниченными кадровыми ресурсами. Также важно отметить, что практически отсутствует поддержка автоматического формирования формализованных регламентов реагирования на сценарии атак социальной инженерии, что приводит к несогласованности действий при инцидентах и повышает общий уровень риска.

Таким образом, несмотря на наличие отдельных компонентов, таких как таксономии атак, инструменты визуализации данных и оценки рисков, на сегодняшний день не существует полноценных программных решений, способных объединить в рамках единой архитектуры сценарный анализ, моделирование угроз, количественную оценку уязвимостей и автоматическую генерацию защитных мероприятий. Это особенно критично в условиях, когда атаки социальной инженерии становятся всё более изощрёнными, многоступенчатыми и адаптивными, а ручной подход к анализу утрачивает свою эффективность.

Указанные ограничения подчёркивают необходимость разработки специализированного программного комплекса, ориентированного на автоматизированное противодействие атакам социальной инженерии. Такой комплекс должен реализовывать проактивный, алгоритмически обоснованный и визуально-интерактивный подход, предполагающий построение возможных сценариев атак с использованием формализованных баз знаний (например, MITRE ATT&CK, CAPEC), оценку рисков на основе вероятностно-ущербной модели, автоматическую генерацию регламентов реагирования и возможность интеграции с существующими системами обеспечения безопасности.

Внедрение такого решения позволит не только повысить оперативность и точность реагирования на инциденты социальной инженерии, но и обеспечит единообразие в принятии решений, снижение зависимости от человеческого фактора и повышение общего уровня защищённости информационных систем организации.

1.2 Анализ сценарного подхода к моделированию атак социальной инженерии

Нынешние угрозы социальной инженерии отличаются повышенным уровнем адаптивности, сложности и вариативности. Если классические технические атаки основываются на прямой эксплуатации уязвимостей, то атаки социальной инженерии больше всего эксплуатируются, используя последовательность этапов, каждый такой этап затрагивает различные аспекты поведения, восприятия и взаимодействия человека с информационной системой. Поэтому в данный момент всё наибольшее внимание к анализу и моделированию таких угроз получает сценарный подход.

Всеми известные механизмы противоборства социальной инженерии исследуют отдельные техники (например, phishing, pretexting, quid pro quo), не беря в расчет их возможные последовательности, а также логические связи. Тем не менее в реальности атаки не состоят из одной техники: злоумышленник начинает собрать информацию (OSINT), после вступает в контакт (через поддельную идентичность), затем начинает манипулировать жертвой, а на финальном этапе возможно применение технических средств (допустим, инъекция вредоносного файла на компьютер жертвы). Приведенная последовательность техник является сценарием атаки — структурированный набор шагов, организованный по логике и времени.

Пример такого сценария:

1. разведка (поиск контактных данных в LinkedIn) — [TA0043: Reconnaissance];
2. первичный контакт через email (фишинг) — [T1566: Phishing];
3. завоевание доверия (цепочка писем) — [CAPEC-123: Pretexting];
4. передача вредоносной ссылки — [T1204: User Execution];
5. установка RAT — [T1059: Command & Scripting Interpreter].

В такой схеме каждый шаг обусловливает следующий. Расчет риска, основанный только на отдельной технике (например, T1566), не учитывает контекст, цель, глубину и связи.

В сценарном подходе главным становится переход от техник к логическим моделям атак.

Используемые методологии:

- **MITRE ATT&CK**: определяет «скелет» сценария — 14 тактик, в рамках которых организованы техники;
- **CAPEC**: предоставляет шаблоны (attack patterns), которые могут заполнять эти тактики;
- **CWE**: дает понять, какие из уязвимостей эксплуатируются на каждом шаге.

Таким образом, сценарий может быть представлен как связанный граф.

Исследования показывают, что применение графов для моделирования атак существенно повышает точность прогноза рисков [31, 32].

Данный аспект позволяет:

- строить многовариантные цепочки;
- выделять критические узлы;
- проводить оценку рисков на уровне всей цепи, а не отдельной техники.

Преимущества сценарного моделирования можно отобразить в таблице 1.

Таблица 1. Преимущества сценарного моделирования

Критерий	**Моделирование техник**	**Сценарный подход**
Уровень детализации	Средний	Высокий
Учет логики атакующего	Частично	Да
Возможность оценки совокупного риска	Ограничена	Полная
Анализ повторяющихся паттернов	Нет	Да
Использование в генерации контрмер	Частично	Да, особенно в AI-модулях

Получается, что сценарий — это не только «набор техник», а единица моделирования угроз. Она предусматривает порядок, зависимость и цель действий злоумышленника.

Сценарный подход уже используется в нескольких системах, однако чаще всего — в рамках Red Team-симуляций или threat modeling на этапе проектирования. Инструменты, например ATT&CK Navigator, дают возможность отмечать техники на «матрице атак», одно не предоставляет функционал построения автоматических сценариев. BAS-платформы (например, Cymulate, AttackIQ) отчасти имеют сценарные симуляции, но по большей части специализируются на технических векторах.

Минус большей части существующих решений — отсутствие автоматической генерации сценариев, их формализованной оценки и связки с контрмерами.

Это сокращает масштаб таких систем в рамках постоянного мониторинга или SOC.

Для атак класса «социальная инженерия» сценарный подход особенно важен по следующим причинам:

- социальная инженерия — контекстуальная: доверие и восприятие строятся на фоне предшествующих шагов;
- поведение жертвы зависит от цепочки воздействий;
- часто только вся последовательность шагов (например, фишинг → убеждение → загрузка файла) ведёт к результату;
- контрмеры работают не на каждый шаг, а на разрыв логической цепи.

Таким образом, для защиты от угроз применения социальной инженерии требуется понимание целостных цепочек атак, а не только анализа отдельных техник.

Именно этот вывод и лежит в основе алгоритмической реализации, представленной в главе 2 настоящей работы.

1.3 Входные сведения об атаках класса «социальная инженерия»

В текущем разделе будет приведена актуальная информация об атаке класса «социальная инженерия». Актуальность этого обусловлена тем, что без начальных данных об атаке дальнейшее исследование оказывается неинформативным.

В настоящей работе «социальная инженерия» рассматривается как связь техник и шаблонов, которые используются в целях влияния на сознание людей и общества в целом. «Социальная инженерия» — это стартовая точка злоумышленников, которая позволяет им извлекать конфиденциальные данные, красть учетные данные, а также совершать иные вредоносные действия, нарушающие конфиденциальность, целостность и доступность данных. Последнее время можно наблюдать печальную тенденцию: рост числа атак на целых 442%. Визуализация на рисунке 1 и данные из результатов исследования Positive Technologies, подтверждают эту печальную статистику.

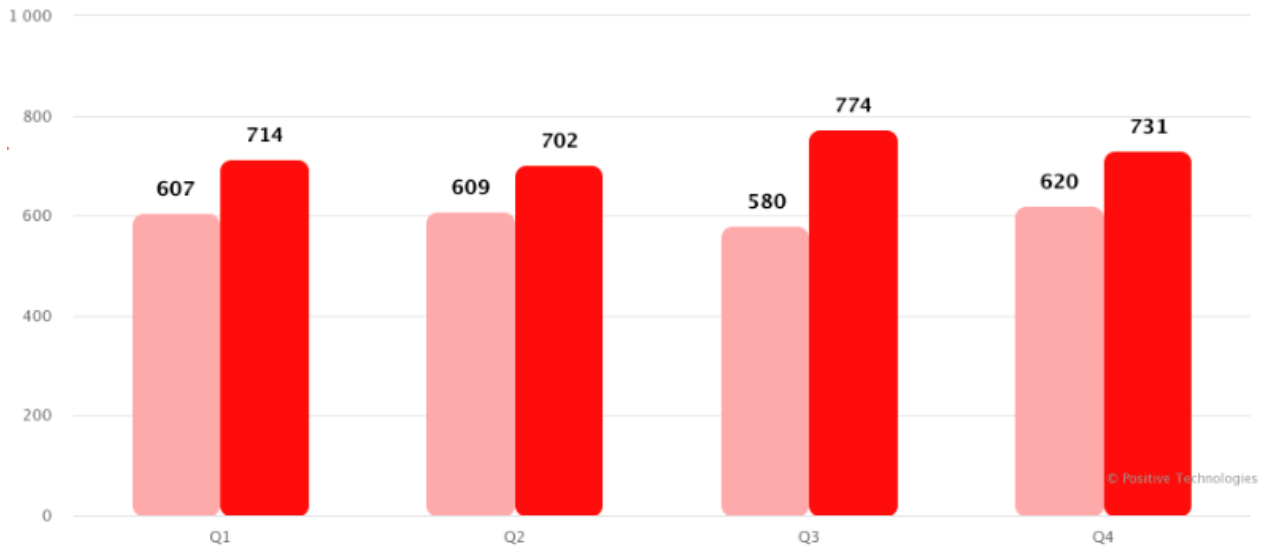


Рисунок 1 – Статистика роста атак класса «социальная инженерия»

Существует широкий спектр техник социальной инженерии [21].

1. **Клон-фишинг** — создание подделок реальных сообщений с добавлением вредоносной ссылки [22].

2. **Целевой фишинг (Spear phishing)** — высокоперсонализированные атаки на конкретных лиц или организации [23].

3. **Вишинг** (voice phishing) — телефонные звонки с притворным представлением от лица банкира, полицейского или техподдержки [24].

4. **Смишинг** — фишинг через SMS и мессенджеры [25].

5. **Quid Pro Quo** — предложение услуги (например, от техподдержки) в обмен на доступ/информацию.

6. **Baiting** — приманка (как USB-носитель), заражённая вредоносным ПО.

7. **Honey trapping** — эмоциональная манипуляция через фальшивые отношения.

8. **Tailgating** — проникновение вслед за сотрудником через физический доступ.

9. **Обратная социальная инженерия** — когда жертва добровольно предоставляет доступ тому, кто предлагает «помощь».

Как правило, социальная атака проходит в несколько этапов:

- **сбор информации** через соцсети, утечки, публичные источники;
- **установление доверия** — через персонализированное сообщение, подставное письмо, телефонный звонок;
- **эксплуатация** — выманивание данных или доступа;
- **распространение** — атака «углубляется» в сеть компании или переходит к шантажу, кражам, компрометации;

Статистика и актуальные тенденции таковы что:

- по данным Sprinto, 98 % кибератак используют социальную инженерию;
- Secureframe отмечает, что большинство организаций сталкивается с более 700 атаками этого типа в год, а 89 % социально-инженерных атак направлены на финансовую выгоду;
- по отчёту CrowdStrike, вторая половина 2024 года показала рост атак с целью кражи учетных данных на 442 %;
- согласно Zscaler/ThreatLabz, несмотря на 20 % глобальное снижение фишинга в 2024, атаки стали более целевыми, включая голосовые и видеотехники, особенно в США (падение на 32 %);

- также 42 % организаций в 2024 отмечали инциденты, связанные с фишингом и социальной инженерией;
- CrowdStrike указывает, что в 2024 стали расти «malware-free» социально-инженерные атаки, включая эволюцию от классического фишинга к более скрытым способам эксплуатации.

Примеры из практики:

- Иранские спецслужбы активно используют spear-phishing и создают поддельные профили для шпионажа;
- группа Scattered Spider атакует страховые компании США, представляясь сотрудниками службы поддержки и обходя технические меры через социальную манипуляцию.

Влияние на организацию:

- финансовые потери: утечка данных, вымогательство, сбои в работе;
- репутационный ущерб: потеря доверия клиентов и партнёров;
- правовые последствия: штрафы, судебные разбирательства;
- сетевые последствия: получение доступа к внутренней инфраструктуре.

Проведённый анализ демонстрирует, что атаки, основанные на приёмах социальной инженерии, в настоящее время представляют собой один из наиболее масштабных и быстроразвивающихся классов угроз информационной безопасности. Их ключевая особенность заключается в том, что объектом воздействия становится не только техническая инфраструктура, но прежде всего человек — как элемент системы, наиболее подверженный манипуляции, обману и психологическому влиянию. Таким образом, социальная инженерия занимает особое место в ландшафте киберугроз, функционируя на стыке информационных, поведенческих и организационных уязвимостей.

1.4 Исследование существующих аналогов

В рамках текущей работы проведено тщательное исследование существующих решений и платформ, используемых для минимизации угроз социальной инженерии.

Будут изучены как обучающие системы и симуляторы фишинга, так и инструменты для имитации атак, а также сервисы, ориентированные на технический и интеллектуальный контроль. Упомянутые ниже решения затрагивают обширный спектр инструментов — от моделирования сложных сценариев угроз до формирования человеческого «файервола».

KnowBe4 — это глобальный лидер в области обучения персонала, а также моделирования фишинга. Инструмент имеет собственную библиотеку материалов, фишинговых симуляций, AI-поддержку персонализированного обучения и функционал SmartRisk, позволяющий отслеживать прогресс и уровень уязвимости пользователей.

Факт снижения кликабельности фишинговых сообщений до 5 % в среднем и трехлетний ROI в 276 % говорят о его эффективности. К минусам можно отнести отсутствие автоматизированного построения сценариев атак и оценки рисков на основе моделей угроз.

Proofpoint Security Awareness Training (Wombat) и Hoxhunt — решения, которые можно отнести к конкурентам KnowBe4. Они также предлагают фишинг-симуляции и обучающие микрокурсы на основе AI. Основное отличие заключается в индивидуальной адаптации обучения и аналитике поведения пользователей. Ограничение: как и у KnowBe4, фокус на обучение без интеграции с оценкой рисков и сценарным анализом.

Cofense PhishMe, Barracuda Email Protection, Mimecast Awareness Training, PhishingBox предлагают автоматизированные фишинг-кампании, мониторинг ответов пользователей и интеграцию с Detection/Response-системами. Однако не включают глубокий анализ человеческих факторов и не моделируют комплексные атаки.

Cymulate, AttackIQ, Picus Security, SafeBreach — BAS-платформы, способные моделировать полный цикл атак в соответствии с MITRE ATT&CK и включающие модули социальной инженерии. Cymulate расширяет возможности, включая Email Gateway и Employee Awareness симуляции, а также AI-планировщик атаки и

автоматическое обновление политик безопасности. Ограничение: в основном ориентированы на технические векторы и требуют интеграции и настройки вручную.

Новое поколение платформ, таких как Picus Security и ThreatConnect, предлагает расширенные возможности симуляции и автоматизации реагирования [33, 34].

Social-Engineer Toolkit (SET) — мощный open-source-инструмент для проведения фишинговых, спуфинг- и других атак социальной инженерии. Подходит для red-team, но не предполагает анализ рисков или создание регламентов обороны.

Adaptive Security — AI-платформа для защиты от фишинга, smishing, deepfake-атак. На начальных стадиях распространения, с перспективой использования AI для анализа и реагирования.

Terranova Security, Silent Breach, Panacea — решения с применением NLP, игровых элементов и интеллектуальных AI-агентов для повышения осведомлённости сотрудников о способах фишинга.

Исследуемые решения включают имитацию атак, обучение и техническую симуляцию угроз, но не обеспечивают комплексный подход: автоматизированную генерацию сценариев атак социальной инженерии, встроенную оценку рисков и поддержку принятия решений через AI. Существующие платформы выполняют лишь отдельные функции, это можно увидеть в таблице 2.

Таблица 2. Сравнительный анализ существующих аналогов

Инструмент	**Цель**	**Поддержка сценариев атак**	**Оценка рисков**	**Визуализация / аналитика**	**AI / адаптивность**	**Ограничения**
KnowBe4	Обучение сотрудников, фишинг-тесты	-	-	+	+	Нет моделирования атак, слабая техническая связность

Продолжение таблицы 2

Cofense PhishMe	Имитация фишинга и поведенческий анализ	-	-	+	-	Только обучение, нет глубокой интеграции
Hoxhunt	Персонализированное обучение	-	-	+	+	Только человеческий фактор, нет технического охвата
Proofpoint SA Training	Тренинги + защита email	-	-	+	-	Нет глубокой моделирующей части
MITRE ATT&CK	Методология, таксономия атак	+	-	+	-	Это не программное ПО, нет автоматизации
Cymulate	BAS: симуляция атак, в т.ч. фишинг	+	+	+	+	Фокус на технические атаки, ограничена по соц. инж.
AttackIQ	Комплексная проверка защиты (MITRE TTPs)	+	+	+	-	Сложность настройки, нет специфики по соц. инженерии
Social-Engineer Toolkit (SET)	Проведение атак, пентест	+	-	-	-	Только атакующая сторона, не даёт защитных рекомендаций
Barracuda Email Security	Защита почты от фишинга, спама	-	-	+	-	Не обучает и не анализирует поведение
Adaptive Security	AI-анализ новых угроз (deepfake, vishing)	-	+	+	+	Ранний этап, нет интеграции с корпоративными SOC
Terranova Security	Интерактивное обучение, игровые методы	-	-	+	±	Нет сценарного моделирования и оценки последствий

2 Разработка алгоритмического обеспечения для автоматизированного построения, оценки рисков и визуализации сценариев атак класса «Социальная инженерия»

2.1 Проектирование модуля агрегации данных об атаках класса «Социальная инженерия»

Модуль агрегации данных представляет собой один из критически важных компонентов системы автоматизированного анализа. К его задачам можно отнести унификацию, структурирование и кросс-связывание информации из разнородных источников знаний, таких как MITRE ATT&CK и MITRE CAPEC. Основная цель — формирование полной картины всевозможных сценариев атак класса «социальная инженерия» через сопоставление техник, тактик и шаблонов атак.

Архитектура данного модуля построена по принципам модульности и независимого масштабирования. Он реализован как отдельный логический компонент с возможностью взаимодействия по REST-интерфейсу, поддерживающего как синхронную обработку данных, так и асинхронную загрузку справочников по расписанию.

Форматы входных данных (таблица 3):

- **MITRE ATT&CK**: представлена в формате STIX 2.1 (JSON), содержащем объекты attack-pattern, tactic, relationship, course-of-action и другие;
- **CAPEC**: описана в XML-структуре, соответствующей XSD-схеме CAPEC версии 3.x, с элементами Attack_Pattern, Execution_Flow, Relationships, Taxonomy_Mappings [35, 36].

Таблица 3. Поддерживаемые форматы входных данных:

Источник	Формат	Основные элементы	Версия
MITRE ATT&CK	STIX 2.1 (JSON)	attack-pattern, tactic, relationship, course-of-action	v14/v15
MITRE CAPEC	XML	Attack_Pattern, Execution_Flow, Relationships	3.x

На этапе извлечения и подготовки данных реализуется автоматизированная загрузка из официальных источников MITRE, включая репозитории, зеркала и API-интерфейсы. Затем выполняется синтаксический разбор, а также нормализация данных:

- извлечение идентификаторов, описаний, связей между техниками, тактиками и шаблонами;
- приведение терминов и таксономий к единой структуре;
- очистка и стандартизация наименований и иерархий;
- обработка вложенных структур и семантических связей.

В итоге получается унифицированное представление данных в виде графовой модели, где узлы соответствуют техникам, тактикам и шаблонам, а рёбра — типам связей (например, hasPhase, mappedTo, precededBy, extends).

Кросс-индексирование позволяет сопоставлять элементы двух таксономий. В модуле реализованы следующие методы сопоставления:

1. прямое соответствие по идентификаторам, если оно указано явно в CAPEC (Taxonomy_Mapping);

2. семантическое соответствие, вычисляемое путём сопоставления текстовых описаний (включая названия и аннотации техник/шаблонов) на основе модели близости (например, на основе косинусного расстояния);

3. контекстное сопоставление, учитывающее принадлежность элементов к определённым фазам атаки и связь с тактиками.

На основании этих критериев строится матрица соответствия между шаблонами CAPEC и техниками ATT&CK. В неё включаются только те пары, коэффициент соответствия которых превышает заданный порог релевантности (например, 0.65).

Важной особенностью CAPEC является наличие внутренних связей между шаблонами, таких как:

- CanPrecede (может предшествовать);
- CanFollow (может следовать за);
- HasSubPattern (частный случай);

- Related_Attack_Pattern.

Модуль формирует направленные графы возможных сценариев атак, где вершины — шаблоны CAPEC, а рёбра — логические связи между ними. Далее происходит:

- построение транзитивного замыкания по связям CanPrecede;
- генерация допустимых путей с учётом фаз модели ATT&CK;
- исключение циклов и неконсистентных переходов;
- обогащение путей через добавление техники ATT&CK, соответствующей каждому шаблону, на этапе сопоставления.

Это позволяет создавать сложные цепочки атак, соответствующие реальным сценариям злоумышленников и учитывающие взаимосвязь между действиями.

Финальный результат работы модуля — представление атаки в виде структурированного сценария, который включает:

- последовательность фаз (тактик) из ATT&CK;
- конкретные техники, применяемые на каждой фазе;
- один или несколько шаблонов CAPEC, соответствующих технике;
- связи между шагами на основе CAPEC-графов;
- метаинформацию: вероятность применения техники, предполагаемый ущерб, количество случаев в статистике, уровень риска.

Каждый сценарий сериализуется в формат, пригодный для машинной обработки — граф RDF, JSON-LD, YAML — в зависимости от дальнейшего применения.

Такая структура позволяет использовать сценарии:

- для визуализации с помощью специализированных библиотек;
- для численной оценки рисков;
- для автоматизированного формирования политик реагирования;
- для тренировки AI-моделей распознавания сценариев и генерации контрмер.

В процессе проектирования модуля были выявлены следующие технические сложности:

- семантическая неоднозначность описаний: термины CAPEC и ATT&CK зачастую отличаются даже при описании схожих атак;
- наличие циклов и дублирующих связей в CAPEC, требующее нормализации графа и исключения лишних маршрутов;
- отсутствие единых идентификаторов для сопоставления: необходимо строить логические соответствия на основе содержательного анализа;
- разные версии таксономий: ATT&CK и CAPEC обновляются асинхронно, что требует поддержки версионирования и миграции между версиями;
- ограничения производительности: генерация всех возможных сценариев с глубиной более 10 шагов требует оптимизации по памяти и времени выполнения.

Для устранения вышеуказанных проблем, возникающих при агрегации и обработке данных из разнородных источников (включая базы знаний MITRE ATT&CK, CAPEC и другие специализированные репозитории угроз), в архитектуре модуля были реализованы несколько ключевых технических решений, направленных на обеспечение высокой производительности, точности сопоставления и устойчивости к неполному или конфликтному входному содержимому.

Во-первых, внедрены кэширующие механизмы, позволяющие минимизировать избыточные обращения к внешним и внутренним хранилищам данных при повторной загрузке или интерпретации часто используемых записей. Кэширование реализуется как на уровне прикладной логики (in-memory cache), так и на уровне промежуточного хранилища данных (persistent local cache), что обеспечивает как ускорение обработки при многократных обращениях, так и отказоустойчивость при потере соединения с внешними источниками.

Во-вторых, применяется индексация агрегируемых элементов по ключевым атрибутам, включая идентификаторы техник, тактик, описания атак, категориальные метки и уровни риска. Такая индексация позволяет реализовать быстрый и масштабируемый механизм поиска, сопоставления и фильтрации записей при построении сценариев социальной инженерии, в том числе при агрегации данных по сценариям с несколькими источниками.

В-третьих, для повышения гибкости и устойчивости сопоставления записей из различных источников используются эвристические методы корреляции, включающие частичное совпадение семантических маркеров, использование синонимических рядов, лемматизацию терминов, а также анализ контекста с применением элементов обработки естественного языка (NLP). Это позволяет успешно агрегировать и связывать данные, даже если они представлены в различных форматах, структурах или с различной степенью полноты описания.

Дополнительно в модуле реализован компонент валидации сценариев, целью которого является проверка формируемых цепочек атак на предмет логической и семантической согласованности. Данный компонент проверяет наличие обязательных этапов атаки (например, наличие этапов первичного доступа, установления контроля и эксфильтрации), соответствие зависимостей между техниками и тактиками, а также корректность переходов между этапами. В случае выявления логических несоответствий, система формирует диагностическое сообщение с указанием типа нарушения и предложением корректирующих действий.

Таким образом, совокупность указанных механизмов обеспечивает надёжную и масштабируемую основу для построения устойчивого модуля агрегации данных, пригодного для использования в условиях высокой вариативности входной информации и необходимости автоматизированного построения сценариев атак. Подробная схема и логическая последовательность работы модуля агрегации представлена на рисунке 2, где отображены основные этапы обработки: от получения и предварительной нормализации данных до формирования унифицированного представления сценария атаки.

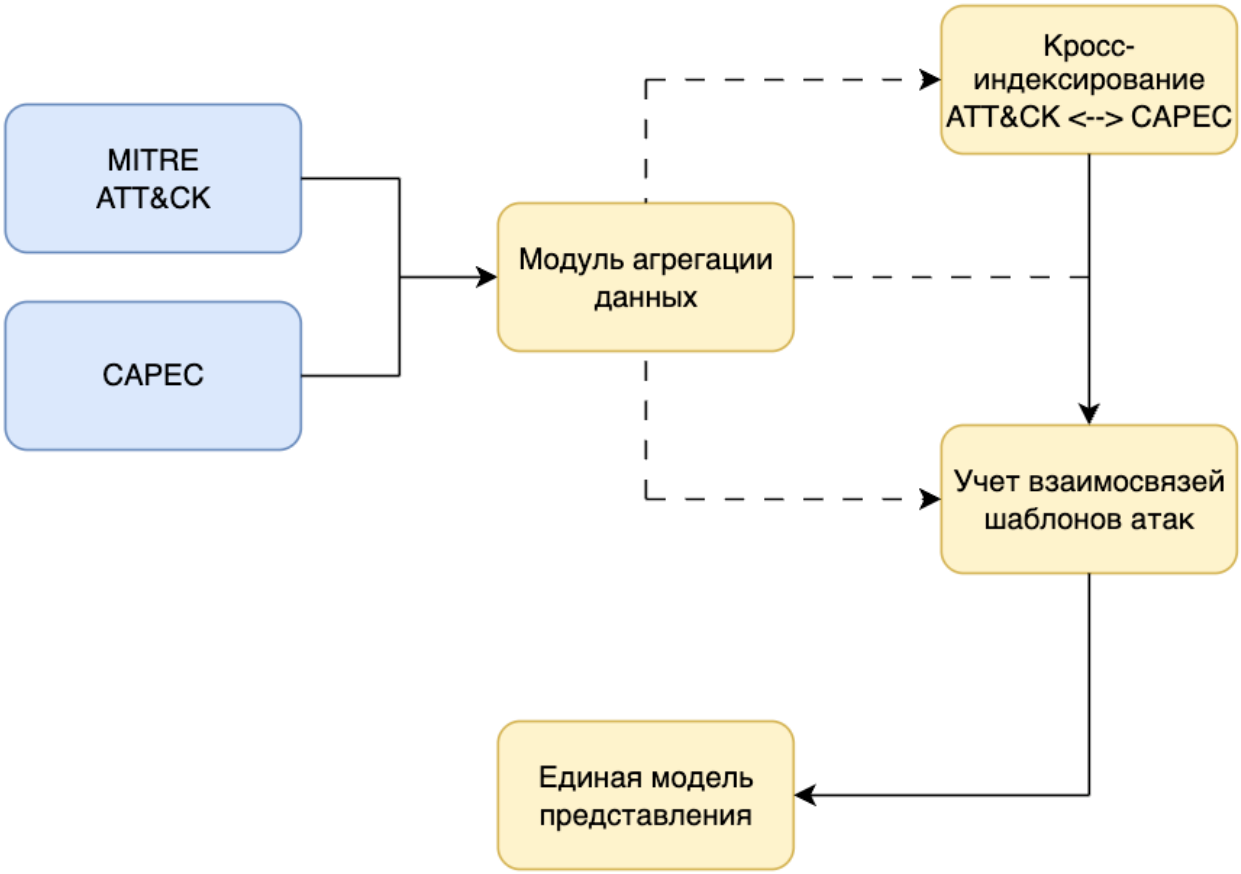


Рисунок 2 – Полный алгоритм работы модуля агрегации

2.2 Проектирование модуля анализатора уязвимостей и шаблонов атак

Модуль анализатора получает на вход агрегированные сценарии (последовательности техник ATT&CK с аннотациями CAPEC) и выполняет углублённый анализ содержимого.

Основная цель – сопоставление техник и шаблонов с целью выявления уязвимых мест (weak points) в каждом сценарии и построения обобщённых паттернов атак.

Алгоритмы модуля опираются на знание связей между техниками, шаблонами и известными уязвимостями. В частности, каждый шаблон CAPEC содержит указание на связанные слабости системы (CWE), которые эксплуатируются данным шаблоном.

Например, шаблон CAPEC-98 «Phishing» (фишинг) ассоциирован со слабостью CWE-451 (недостатки в интерфейсе, позволяющие ввести пользователя в

заблуждение) [14]. Анализатор извлекает такие связи: для каждого шага сценария, если шаг помечен шаблоном CAPEC, модуль собирает перечень соответствующих уязвимостей CWE. Это позволяет автоматически понять, какие уязвимости должны присутствовать в системе жертвы, чтобы данный шаг сценария сработал. Таким образом выявляются слабые места сценария – те компоненты или уязвимости, без которых атака бы не удалась.

Другая функция – алгоритмы сопоставления техник и шаблонов для построения сводных паттернов. Так как различные сценарии могут иметь одни и те же подпоследовательности действий злоумышленника, анализатор старается обобщить эти повторяющиеся цепочки в виде паттернов. Для этого все сгенерированные сценарии представляются как цепочки идентификаторов (например, T1566 → T1059 → ... → T1486), и затем применяются методы кластеризации или частотного анализа подпоследовательностей. В результате модуль выделяет наиболее типичные «шаблоны атак» – например, часто встречающийся паттерн: фишинговая атака с последующим запуском скрипта и шифрованием данных. Эти выявленные паттерны позволяют сосредоточиться на ключевых комбинациях техник, представляющих наибольшую угрозу.

В основе анализатора лежит онтологическое сопоставление данных из разных источников: ATT&CK, CAPEC, CWE, а при необходимости и CVE. Сложность прямого связывания уязвимостей с шаблонами атак давно отмечается специалистами: это трудоёмкий процесс, требующий интерпретации разнородной информации вручную [15]. Поэтому данный модуль основывается на заранее известных соответствиях: например, работы Xianghui et al. демонстрируют, что можно автоматически использовать взаимосвязи между базами CAPEC, CWE и CVE для улучшения анализа угроз [16]. Учитывая эти подходы, анализатор строит граф связей: техника ATT&CK → шаблон(ы) CAPEC → слабость CWE → известные уязвимости (CVE) в конкретных продуктах, пример можно увидеть в таблице 4.

Таблица 4. Сопоставление техник, шаблонов и уязвимостей

Тактика	**Техника ATT&CK**	**Шаблон CAPEC**	**Связанные CWE**
Разведка	T1595 (Active Scanning)	CAPEC-152 (Footprinting)	CWE-200 (Exposure of Sensitive Information)
Подготовка ресурсов	T1583.001 (Obtain Infrastructure: Domains)	CAPEC-580 (Establish Infrastructure)	CWE-668 (Exposure of Resource)
Первоначальный доступ	T1566 (Phishing)	CAPEC-98 (Phishing)	CWE-451 (User Interface Misrepresentation)
Исполнение	T1059 (Command-Line Interface)	CAPEC-137 (Command Line Interface)	CWE-78 (OS Command Injection)
Закрепление	T1547 (Boot or Logon Autostart Execution)	CAPEC-232 (Auto-Start Configuration)	CWE-16 (Configuration Errors)
Повышение привелегий	T1068 (Exploitation for Privilege Escalation)	CAPEC-54 (Privilege Escalation)	CWE-264 (Privilege Management)
Предотвращение обнаружения	T1140 (Deobfuscate/Decode Files)	CAPEC-242 (Obfuscation)	CWE-779 (Obfuscated Code)
Получение учетных данных	T1003 (Credential Dumping)	CAPEC-49 (Credential Dumping)	CWE-255 (Credentials Management)
Обнаружение	T1087 (Account Discovery)	CAPEC-171 (User Enumeration)	CWE-200 (Information Disclosure)
Боковое смещение	T1021.002 (SMB/Windows Admin Shares)	CAPEC-551 (Shared Resource Manipulation)	CWE-276 (Incorrect Default Permissions)
Сбор данных	T1113 (Screen Capture)	CAPEC-247 (Sniffing User Activity)	CWE-359 (Exposure of Sensitive Info)
Командование и управление	T1071.001 (Web Protocols)	CAPEC-509 (Command Channel)	CWE-319 (Unencrypted Communication)
Эксфильтрация	T1041 (Exfiltration Over C2 Channel)	CAPEC-160 (Data Leakage)	CWE-311 (Missing Encryption)

Продолжение таблицы 4

Тактика	**Техника ATT&CK**	**Шаблон CAPEC**	**Связанные CWE**
Удар	T1486 (Data Encrypted for Impact)	CAPEC-118 (Ransomware)	CWE-311 (Missing Encryption)

Использование онтологий позволяет автоматизировать связывание данных CAPEC↔CWE↔CVE [37, 38, 39].

Если на каком-то шаге сценария присутствует известная уязвимость CVE, это фиксируется как особенно опасный узел (concrete vulnerability) сценария. Также модуль проводит проверку на критические точки сценария: шаги, без которых достижение финальной цели невозможно (например, единственный способ эскалации привилегий). Такие шаги отмечаются как ключевые слабые места.

Результатом работы анализатора служит разметка сценариев дополнительной информацией: указанием, какие именно слабости и уязвимости эксплуатируются, и какие паттерны атак они образуют. Например, сценарий, включающий технику «Выполнение через скрипт» (ATT&CK T1059) может соответствовать CAPEC-шаблону «Command-Line Interface Execution», связанному с CWE-78 (ошибки в нейтрализации спецсимволов в команде OS). Анализатор добавит эти сведения в структуру сценария.

Помимо этого, формируется каталог типовых паттернов: например, паттерн «фишинг + запуск вредоносного скрипта» или «кража учетных данных + использование легитимного аккаунта», с указанием частоты их встречаемости среди всех сценариев.

Эти паттерны затем используются для оценки и визуализации, а также для генерирования рекомендаций по защите.

2.3 Проектирование модуля оценки рисков сценариев атак класса «Социальная инженерия»

Для полноценного оценки рисков стоит изучить доступные системы оценивания уязвимостей. Затем необходимо узнать общую оценку пронормировав выборку полученных значений.

Особенность заключается в том, что не каждая система оценивания имеет результат в пределах одной шкалы оценки. Исходя из этого, можно сделать вывод, что для старта правильного риск-анализа стоит сначала пронормировать все известные значения для каждой уязвимости. Для нормировки будет использоваться формула (1):

$$S_{norm} = \frac{S - S_{min}}{S_{max} - S_{min}}, \quad (1)$$

где S_{norm} – нормализованная оценка калькулятора;

S_{max} – максимальная оценка;

S_{min} – минимальная оценка.

S – актуальная оценка;

Начнем рассматривать систему оценки DREAD, однако стоит упомянуть, что методология FAIR и NIST SP 800-30 также активно используется в моделях оценки ИБ-рисков [40, 41]. DREAD – система оценки рисков, созданная Microsoft. Система предоставляет пять категорий для оценки уровня угроз безопасности:

- damage – уровень серьезности атаки;
- discoverability – коэффициент «легкости» угрозы.
- reproducability – насколько можно воспроизвести атаку;
- affected users – какое количество людей будут затронуты;
- exploitability – насколько работы потребуется для запуска атаки.

Для расчёта метрики в процентах от 1% до 100% подключаются три ключевых компонента: CISA CVE, CVSS, EPSS.

По итогу, получается учесть технические аспекты, вероятность эксплуатации, известность и эксплуатируемость уязвимости. Через выполнение математических вычислений оценка уязвимости, выполняется приоритизация. Важным моментом является то, что в контексте рассматриваемого демонстрационного ресурса пользователь может сам выбрать веса для интегрируемых метрик, это показано на рисунке 3, на нем представлено классическое распределение весов для адекватной оценки [20].

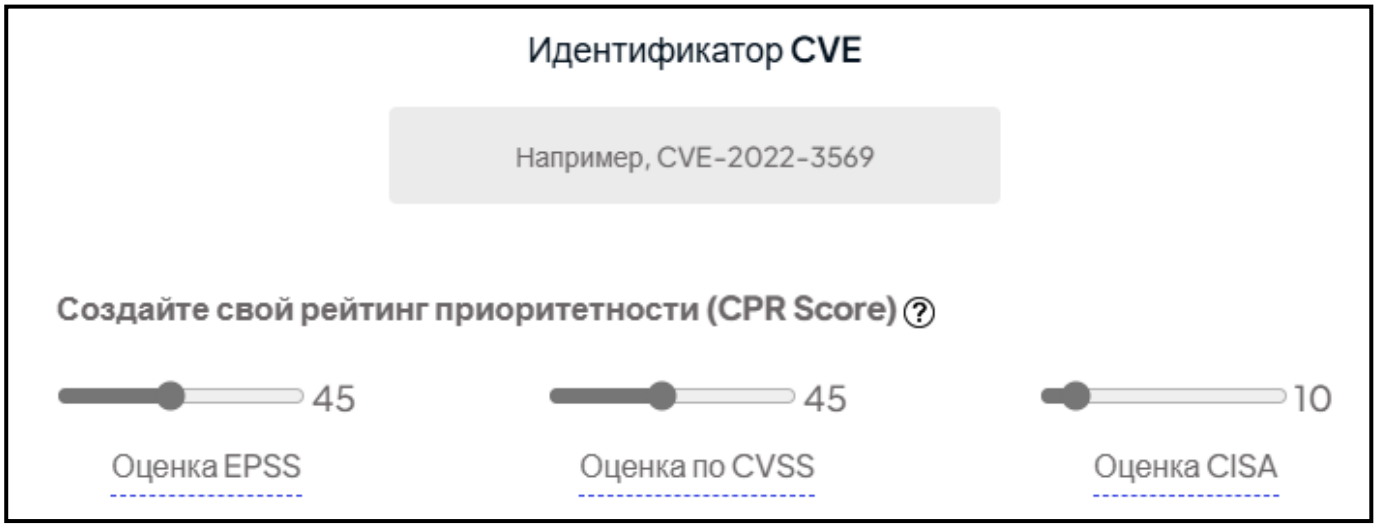


Рисунок 3 – Формирование метрики SRP-Score.

Метрика EPSS. EPSS система рассчитывает вероятность того, что уязвимость будет эксплуатирована в атаке, это позволяет приоритизировать усилия по её устранению, в сочетании с оценкой CVSS. CVSS предназначен для определения уровня угрозы уязвимости. Он классифицирует её по различным уровням опасности, но она ограничена только оценкой угрозы. Однако EPSS обладает актуальной информацией о реальных угрозах из базы данных CVE, что делает её более точной. Оценка EPSS находится в пределах от 0 до 100%: если значение больше это означает, что уязвимость будет использована.

Система базовой оценки CVSS 3.1. Система начинает с построения вектора и дает оценку, базируясь на базовых метриках:

• вектор атаки: (сеть локальная, сеть смежная, сетевой, физический);

• влияние на целостность (нет, высокое, низкое);

• влияние на доступность (нет, высокое, низкое);

• сложность атаки (низкая, высокая, средняя);

• уровень привилегий (нужен, не нужен);

• влияние на другие компоненты системы (есть, нет);

• влияние на конфиденциальность (нет, высокое, низкое).

Система базовой оценки CVSS 4.0. Происходит построение вектора и формируется оценка, которая опирается на базовые метрики:

• вектор атаки (сетевой, смежный, локальный, физический);

• сложность атаки (низкая, высокая);

• требования к атаке (нет, есть);

• уровень привилегий (нет, низкий, высокий);

• взаимодействие с пользователем (нет, активное, пассивное);

• влияние на конфиденциальность (высокое, низкое, нет);

• влияние на целостность, конфиденциальность (высокое, низкое, нет);

• влияние на доступность, конфиденциальность (высокое, низкое, нет) [23].

Система базовой оценки OWASP. Для оценки уязвимости использует следующе 4 фактора:

• финансовый ущерб - насколько критично отразится на финансовом секторе компании: (1) - небольшие расходы для исправления уязвимости, (3) - незначительное влияние на прибыль, (7) - Существенное влияние на прибыль, (9) - Полное банкротство;

• ущерб репутации – повлияет ли эксплойт на репутацию компании: (1) - минимальные потери, (4) - потеря ключевых клиентов, (5) - потеря деловой репутации, (9) - серьезный ущерб бренду;

• несоблюдение требований – насколько критичен риск несоответствия нормам: (2) - легкое нарушение, (5) - явное нарушение, (7) - существенное нарушение;

• нарушение неприкосновенности частной жизни - Какой объем личных данных может быть раскрыт: (3) - данные одного человека, (5) - данные сотен людей, (7) - данные тысяч людей, (9) - данные миллионов людей [24].

По итогам такого анализа формируется результат об уровне вероятности и влияния риска (рисунок 4).

Уровни вероятности и влияния	
От 0 до <3	НИЗКИЙ
От 3 до <6	ТЕРПИМАЯ
От 6 до 9	ВЫСОКИЙ

Рисунок 4 – Уровень влияния и вероятности по OWASP

Распределив оценку критичности по разным системам оценивания, можно начать оценку рисков сценариев атаки класса «социальная инженерия». Для этого, учитывая уже нормализованные значения критичности, нужно совершить расчет среднеквадратичной оценки критичности по следующей формуле (2).

$$S_f = \sqrt{\frac{1}{n}\sum_{i=1}^{n_k} S_{norm}^2}, \quad (2)$$

Где n_k – количество калькуляторов;

S_f – среднеквадратическая оценка.

Стоить заметить, что согласно формуле (3), от величины среднеквадратичной оценки риска напрямую зависит вероятность использования актуальной уязвимости.

$$P(CVE) = \frac{S_f}{\sum S_f} \quad (3)$$

Данная формула дает возможность рассчитать вероятность эксплуатации уязвимости через реализацию в контексте определенных техник и тактик.

Затем, используя формулу (4), появляется возможность посчитать вероятность для сценария в целом.

$$P(X_i = k_i) = \prod_{i=1}^{S_т} \frac{1}{\sqrt{P(CVE)}} \times \frac{1}{\sqrt{2\pi n}^{S_т - 1}}, \quad (4)$$

где n – количество успешные атаки;

$S_т$ – количество уязвимостей в технике;

k_i – успешные атаки для i уязвимости;

Затем, используя формулу (5), можно рассчитать количественную оценку риска, который возникает при реализации сценариев, состоящих из последовательного выполнения тактик через определенные техники.

$$\overline{Risk} = \prod_{j=1}^{m} P(X)_j \times \sum_{j=1}^{m} U_j, \quad (5)$$

где m – количество техник на этапе;

U_j – ущерб, рассчитанный по формуле (6), который наносится при реализации техники:

$$U = \frac{\sum_{i=1}^{S_т} (K_i \times U_i)}{n}, \quad (6)$$

где U_i – ущерб, для единичной уязвимости вне сценария реализации атаки, рассчитывается по формуле (7).

$$U = 1 - (1 - U_k) \times \left(1 - U_д\right) \times (1 - U_ц), \quad (7)$$

где Uк – ущерб конфиденциальности;

Uд – ущерб доступности;

Uц – ущерб целостности.

Похожие метрики используются также в ISO/IEC 27005 и OWASP Risk Rating [42, 43].

Теперь реализуем результирующую схему с используемыми техниками и шаблонами CAPEC. Далее она будет использоваться при формировании регламентов противодействия (рисунок 9 - 11), а также позволит визуально представить множество сценариев для каждого шаблона атаки класса «социальная инженерия». К тому же, это приведет в соответствие используемые в рамках шаблона техники и классы, по которым было разложено множество самих шаблонов реализации CAPEC. Представляя результат, модуль классифицирует сценарии на критические, средние и минимальные по уровню риска (по аналогии с категориями High, Moderate, Low в терминологии NIST). Границы категорий присваиваются на основе экспертно заданных порогов по вероятности и ущербу.

Например, сценарий является критическим, когда вероятность его реализации оценена как высокая или средняя, а потенциальный ущерб – как высокий (либо вероятность экстремально высокая при умеренном ущербе). Среднерисковыми являются сценарии, для которых либо вероятность, либо ущерб невелики, но не пренебрежимо малы. Минимальный (низкий) риск присваивается либо очень маловероятным угрозам, либо тем, чье влияние незначительно. Формально, после расчета численного показателя риска вводятся два порога R_{med} и R_{high}, разделяющие диапазон на три зоны.

Тогда классификация уровня риска сценария производится по следующим правилам, представленным на рисунке 5.

$$\text{Уровень риска} = \begin{cases} \text{Критический}, & \text{если } R \geq R_{\text{high}} \\ \text{Средний}, & \text{если } R_{\text{med}} \leq R < R_{\text{high}} \\ \text{Минимальный}, & \text{если } R < R_{\text{med}} \end{cases}$$

Рисунок 5 – Правила классификации уровня риска

Модуль производит оценку для всех ~300 000 сценариев, что, в свою очередь требует эффективных вычислений. Для оптимизации используется параллельная обработка и кэширование повторяющихся фрагментов: учитывая, что многие сценарии схожи по структуре, им зачастую присваиваются одинаковые значения вероятности/ущерба на схожих этапах.

В результате функционирования модуля оценки риска сценариев атак осуществляется автоматизированное распределение построенных сценариев социальной инженерии по категориям риска. Данный процесс базируется на количественном анализе, включающем три ключевых компонента: вероятности реализации каждой техники внутри сценария, ожидаемого уровня ущерба при успешной атаке, а также эффективности применённых или возможных защитных мер. На основании этих параметров рассчитывается интегральный риск для каждого сценария, что позволяет классифицировать их по шкале: низкий, средний, высокий, критический.

Наиболее многочисленная категория — сценарии с низким уровнем риска, включающие как маловероятные техники (например, сложные многоходовые схемы без достаточной опоры на уязвимости), так и сценарии с незначительными последствиями даже при их успешной реализации. Эти сценарии, несмотря на численное преобладание, представляют меньшую угрозу в практическом плане и могут быть временно отложены при принятии решений о мерах защиты.

Таким образом, полученные результаты формируют приоритезационную основу для последующего принятия решений в рамках управления рисками информационной безопасности. Они позволяют не только визуализировать распределение рисков по всем возможным сценариям, но и сфокусировать ресурсы на нейтрализации наиболее опасных и реалистичных сценариев. Это, в свою очередь, обеспечивает повышение эффективности защитных мероприятий и оптимизацию затрат на обеспечение безопасности: критически важные сценарии требуют немедленного вмешательства и усиленной защиты, тогда как сценарии с минимальной значимостью могут быть учтены в рамках периодического мониторинга или отложенных мер.

2.4 Проектирование модуля визуализации сценариев атак класса «Социальная инженерия»

Модуль визуализации отвечает за наглядное представление как общей статистики по всем сгенерированным сценариям, так и деталей отдельных сценариев, в удобной для анализа форме. Визуализация играет ключевую роль в понимании большого объёма данных (сотен тысяч сценариев) и выделении приоритетных угроз.

Разработанный модуль формирует интерактивную дашборд-панель.

Важной функцией модуля также является полная визуализация всех полученных сценариев атак, включая каждый этап — от «Разведки» до «Удара». Для этого реализована таблица, в которой каждый строковый сценарий представлен как последовательность из 14 техник MITRE ATT&CK, соответствующих тактикам. На выходе пользователь получает развернутую структуру сценария в виде цепочки действий злоумышленника, а также рассчитанный риск, выраженный численно (рисунки 6, 7, 8, 9).

Разведка	Подготовка ресурсов	Первоначальный доступ	Исполнение	Закрепление	Повышение привелегий	Предотвращение обнаружения	Получение учетных данных	Обнаружение	Боковое смещение	Сбор данных	Командование и управление	Эксфильтрация	Удар	Риск
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1025	T1095	T1567	T1486	0.0489309843365454
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1113	T1095	T1567	T1486	0.0489151350330258
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1025	T1095	T1567	T1486	0.0487369861585187
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1113	T1095	T1567	T1486	0.0487249965658396
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1078	T1534	T1025	T1095	T1567	T1486	0.0482072725412761
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1078	T1534	T1113	T1095	T1567	T1486	0.0481920028990624
T1598	T1586	T1189	T1204	T1053	T1068	T1221	T1606	T1033	T1534	T1025	T1095	T1567	T1486	0.0481047596473555
T1598	T1586	T1189	T1204	T1053	T1068	T1221	T1606	T1033	T1534	T1113	T1095	T1567	T1486	0.0480907090074072
T1593	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1025	T1095	T1567	T1486	0.0480168049577432
T1593	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1113	T1095	T1567	T1486	0.0480068733225937
T1598	T1586	T1189	T1204	T1053	T1068	T1221	T1606	T1518	T1534	T1025	T1095	T1567	T1486	0.0479129875630935
T1598	T1586	T1189	T1204	T1053	T1068	T1221	T1606	T1518	T1534	T1113	T1095	T1567	T1486	0.0479027480647899
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1025	T1095	T1052	T1486	0.0479011283401728
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1113	T1095	T1052	T1486	0.0478809141178638
T1593	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1025	T1095	T1567	T1486	0.0478225771765419

1 2 3 4 5 ··· 2212 > 10 / page

Рисунок 6 – Таблица всех возможных сценариев, страница 1

Разведка	Подготовка ресурсов	Первоначальный доступ	Исполнение	Закрепление	Повышение привилегий	Предотвращение обнаружения	Получение учетных данных	Обнаружение	Боковое смещение	Сбор данных	Командование и управление	Эксфильтрация	Удар	Риск
T1593	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1113	T1095	T1567	T1486	0.0478164941063905
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1025	T1095	T1567	T1485	0.0477481293329682
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1113	T1095	T1567	T1485	0.0477283661181250
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1025	T1095	T1052	T1486	0.0477144345059252
T1598	T1586	T1189	T1053	T1053	T1068	T1656	T1606	T1033	T1534	T1113	T1095	T1567	T1486	0.0477091479701428
T1598	T1586	T1189	T1053	T1053	T1068	T1656	T1606	T1033	T1534	T1025	T1095	T1567	T1486	0.0477091435415872
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1113	T1095	T1052	T1486	0.0476979478038504
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1025	T1095	T1567	T1565	0.0476575332115200
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1113	T1095	T1567	T1565	0.0476382175396033
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1025	T1095	T1567	T1485	0.0475617668692044
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1113	T1095	T1567	T1485	0.0475457234596081
T1598	T1586	T1189	T1053	T1053	T1068	T1656	T1606	T1518	T1534	T1113	T1095	T1567	T1486	0.0475133272182895
T1598	T1586	T1189	T1053	T1053	T1068	T1656	T1606	T1518	T1534	T1025	T1095	T1567	T1486	0.0475093918182918
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1025	T1095	T1567	T1565	0.0474712432250303
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1113	T1095	T1567	T1565	0.0474556447473928

< 1 2 3 4 5 ··· 2212 > 10 / page

Рисунок 7 – Таблица всех возможных сценариев, страница 2

Разведка	Подготовка ресурсов	Первоначальный доступ	Исполнение	Закрепление	Повышение привилегий	Предотвращение обнаружения	Получение учетных данных	Обнаружение	Боковое смещение	Сбор данных	Командование и управление	Эксфильтрация	Удар	Риск
T1598	T1586	T1189	T1204	T1053	T1068	T1656	T1606	T1033	T1534	T1025	T1095	T1567	T1486	0.0468992768265477
T1598	T1586	T1189	T1204	T1053	T1068	T1221	T1606	T1518	T1534	T1113	T1095	T1052	T1486	0.0468943155321203
T1593	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1025	T1095	T1567	T1485	0.0468604110708138
T1598	T1586	T1189	T1204	T1053	T1068	T1221	T1606	T1033	T1534	T1025	T1095	T1567	T1565	0.0468538837244554
T1593	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1113	T1095	T1567	T1485	0.0468464085323649
T1598	T1586	T1189	T1204	T1053	T1068	T1221	T1606	T1033	T1534	T1113	T1095	T1567	T1565	0.0468363622377698
T1593	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1025	T1095	T1052	T1486	0.0468240309656362
T1593	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1113	T1095	T1052	T1486	0.0468133114577315
T1593	T1586	T1189	T1053	T1053	T1068	T1656	T1606	T1033	T1534	T1113	T1095	T1095 57	T1486	0.0468079254681223
T1593	T1586	T1189	T1053	T1053	T1068	T1656	T1606	T1033	T1534	T1025	T1095	T1567	T1486	0.0468021009976752
T1593	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1025	T1095	T1567	T1565	0.0467710830614380
T1598	T1586	T1189	T1204	T1053	T1068	T1221	T1606	T1518	T1534	T1025	T1095	T1567	T1485	0.0467588383878893
T1593	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1113	T1095	T1567	T1565	0.0467575184658344
T1598	T1586	T1189	T1204	T1053	T1068	T1221	T1606	T1518	T1534	T1113	T1095	T1567	T1485	0.0467445502692391
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1033	T1534	T1025	T1095	T1052	T1485	0.0467395234298900

< 1 ··· 3 4 5 6 7 ··· 2212 > 10 / page

Рисунок 8 – Таблица всех возможных сценариев, страница 5

Разведка	Подготовка ресурсов	Первоначальный доступ	Исполнение	Закрепление	Повышение привилегий	Предотвращение обнаружения	Получение учетных данных T1518	Обнаружение	Боковое смещение	Сбор данных	Командование и управление	Эксфильтрация	Удар	Риск
T1598	T1586	T1189	T1204	T1053	T1078	T1221	T1606	T1078	T1534	T1113	T1095	T1567	T1486	0.0049609319845108
T1593	T1586	T1189	T1053	T1053	T1068	T1221	T1606	T1078	T1534	T1113	T1105	T1567	T1486	0.0049608075705329
T1598	T1586	T1566	T1053	T1053	T1068	T1656	T1606	T1033	T1534	T1113	T1095	T1567	T1486	0.0049603545546588
T1598	T1586	T1566	T1053	T1053	T1068	T1656	T1606	T1033	T1534	T1025	T1095	T1567	T1486	0.0049601683154974
T1598	T1586	T1189	T1053	T1053	T1078	T1656	T1606	T1033	T1534	T1113	T1095	T1567	T1565	0.0049601604274485
T1598	T1586	T1566	T1053	T1053	T1068	T1221	T1606	T1518	T1534	T1113	T1095	T1052	T1486	0.0049597127429374
T1598	T1586	T1189	T1053	T1053	T1548	T1221	T1606	T1078	T1534	T1025	T1095	T1567	T1565	0.0049593113651287
T1598	T1586	T1189	T1053	T1078	T1068	T1221	T1606	T1078	T1534	T1025	T1095	T1567	T1485	0.0049591916985817
T1593	T1586	T1189	T1204	T1078	T1068	T1221	T1606	T1518	T1534	T1025	T1095	T1567	T1486	0.0049585121210889
T1598	T1586	T1189	T1204	T1053	T1548	T1221	T1606	T1033	T1534	T1025	T1095	T1567	T1485	0.0049583811948991
T1598	T1586	T1189	T1053	T1053	T1078	T1221	T1606	T1518	T1534	T1025	T1095	T1052	T1565	0.0049583672718006
T1598	T1586	T1189	T1053	T1078	T1068	T1656	T1606	T1078	T1534	T1025	T1095	T1567	T1486	0.0049582639838106
T1598	T1586	T1189	T1053	T1053	T1068	T1221	T1558	T1518	T1534	T1114	T1095	T1052	T1486	0.0049580157224191
T1598	T1586	T1189	T1204	T1053	T1068	T1221	T1558	T1078	T1534	T1025	T1095	T1567	T1485	0.0049577067838616
T1598	T1586	T1189	T1053	T1053	T1548	T1221	T1606	T1518	T1534	T1025	T1095	T1567	T1561	0.0049576305011667

< 1 ··· 103 104 105 106 107 ··· 2212 > 10 / page

Рисунок 9 – Таблица всех возможных сценариев, страница 105

Данная таблица интерактивна: поддерживает поиск, фильтрацию и сортировку, что позволяет быстро выделить, например, все сценарии с техникой T1053 (планировщик задач) или отфильтровать только те, у которых уровень риска превышает заданный порог.

Таким образом, специалист ИБ может на практике изучить каждый сгенерированный путь атаки, включая все техники, которые может использовать злоумышленник на каждом этапе. Это предоставляет уникальную возможность анализировать не только обобщенные характеристики (статистику по техникам и тактикам), но и конкретные реализуемые сценарии с высоким риском, оценивать полноту и глубину защиты организации.

Такой тип визуализации особенно полезен в процессе расстановки приоритетов по устранению уязвимостей: например, можно выделить подмножество сценариев, где применяется техника эксфильтрации (T1025, T1041), и отслеживать, какие шаги

предшествуют ей. Это делает модуль визуализации не только аналитическим инструментом, но и оперативным помощником при принятии решений о внедрении контрмер.

Пример распределения количества сценариев по уровням риска (рисунок 10) для CAPEC 163.



Рисунок 10 – Распределение сценариев по рискам для CAPEC 163

Пример распределения количества сценариев по уровням риска (рисунок 11) для CAPEC 98.



Рисунок 11 – Распределение сценариев по рискам для CAPEC 98

На рисунке 12 приведен пример распределения количества сценариев по уровням риска для CAPEC 164.



Рисунок 12 – Распределение сценариев по рискам для CAPEC 164

На рисунке 13 приведен пример распределения количества сценариев по уровням риска для CAPEC 630.

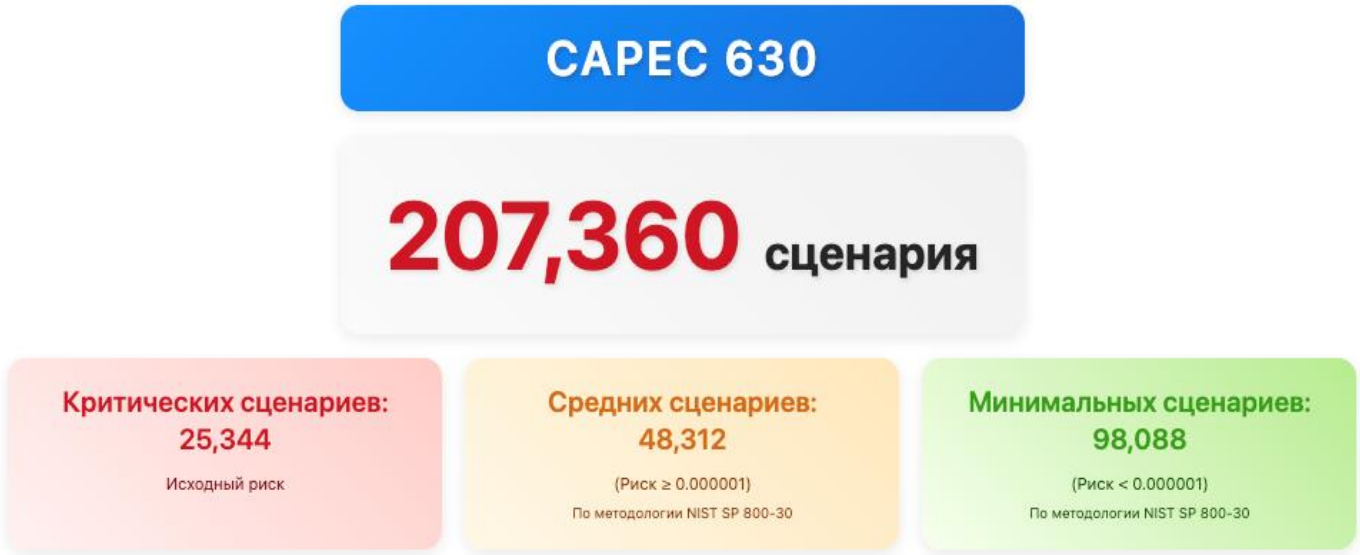


Рисунок 13 – Распределение сценариев по рискам для CAPEC 630

На рисунках показано условное число сценариев с критическим, средним и минимальным уровнями риска.

Такая визуализация по категориям риска сразу демонстрирует общую картину: сколько сценариев представляют наибольшую опасность.

Обычно она имеет сильно смещённое распределение – лишь небольшой «столбец» критических и более высокий столбец минимальных, что сигнализирует о пирамиде рисков (немного сценариев с очень высоким риском, множество с низким).

Эта информация важна для лица, принимающего решения: например, из 300 тыс. сценариев в особом контроле нуждаются лишь десятки самых критичных.

Отдельный вид визуализации – распределение техник и тактик, используемых в сценариях. Модуль строит диаграммы частот, позволяющие выявить наиболее распространенные методы атаки.

Например, можно отобразить гистограмму по техникам ATT&CK: по оси X – идентификаторы техник по оси Y – количество сценариев, где данная техника присутствует (Рисунок 14).

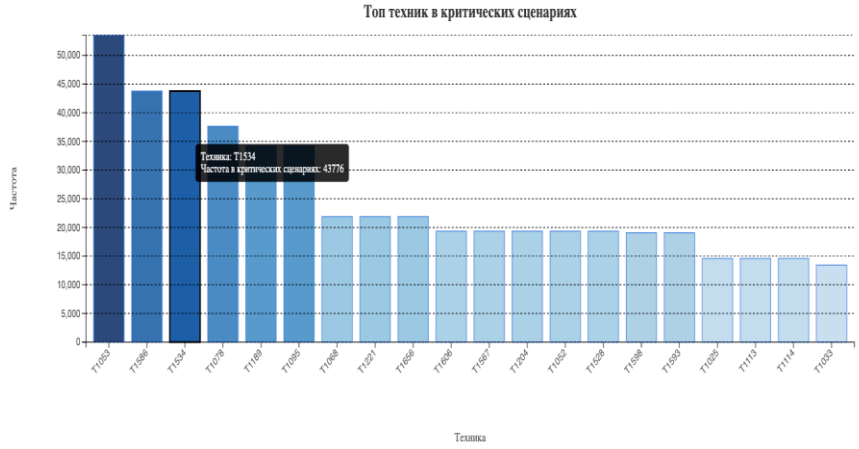


Рисунок 14 – Топ техник в критических сценариях для CAPEC 163

Для CAPEC 98 гистограмма выглядит иначе (рисунок 15).

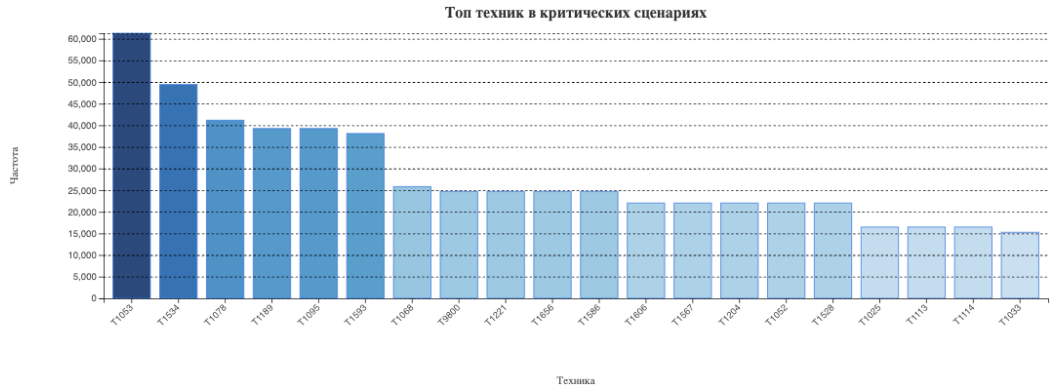


Рисунок 15 – Топ техник в критических сценариях для CAPEC 98

Такая диаграмма сразу выявит топ-10 самых часто встречающихся техник. По нашим данным, к примеру, техника Command and Scripting Interpreter (использование командной оболочки/скриптов, ATT&CK T1059) фигурирует более чем в половине сгенерированных сценариев, а техника начального доступа Phishing (фишинг, T1566) – приблизительно в 15% сценариев. Это соответствует мировым трендам: скриптовое выполнение часто применяется злоумышленниками (например, для запуска полезной нагрузки), а фишинг остаётся главным методом первичного проникновения [20].

Для наглядности модуль строит круговую диаграмму по наиболее частым техникам: каждый сектор показывает долю сценариев с данной техникой (рисунок 16).

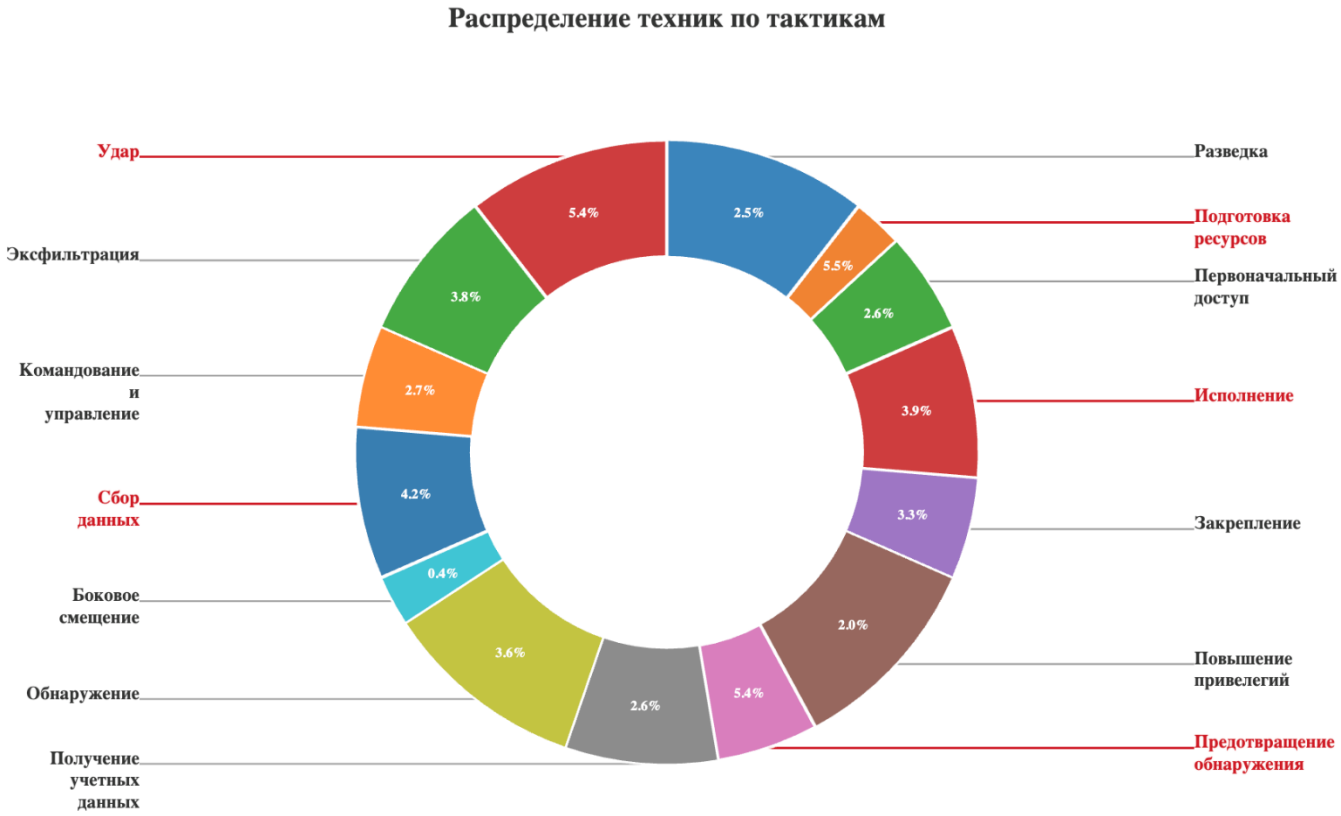


Рисунок 16 – Распределение техник по тактикам

В нашем случае подобная диаграмма (сгенерированная по сценариям социальной инженерии) может показать преобладание техник социальной инженерии на этапе начального доступа и различных скриптов/утилит на этапах выполнения и разведки. Также строятся диаграммы по тактикам – например, распределение,

сколько сценариев задействуют каждую из тактик ATT&CK. Поскольку полный сценарий может охватывать все 14 тактик, более информативно считать уникальные сочетания или определять, на каких тактиках происходят ключевые различия между сценариями.

Кроме частотных диаграмм, модуль визуализирует кластеризацию сценариев (рисунки 17, 18, 19, 20).

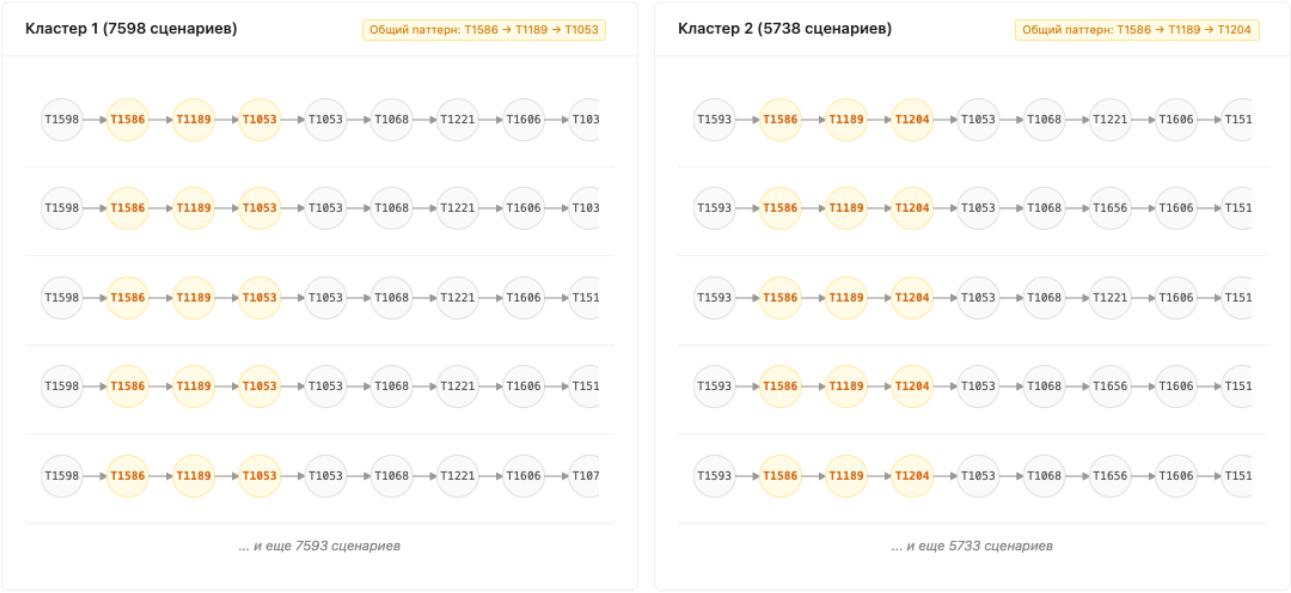


Рисунок 17 – Кластер сценариев для CAPEC 163



Рисунок 18 – Кластер сценариев для CAPEC 98

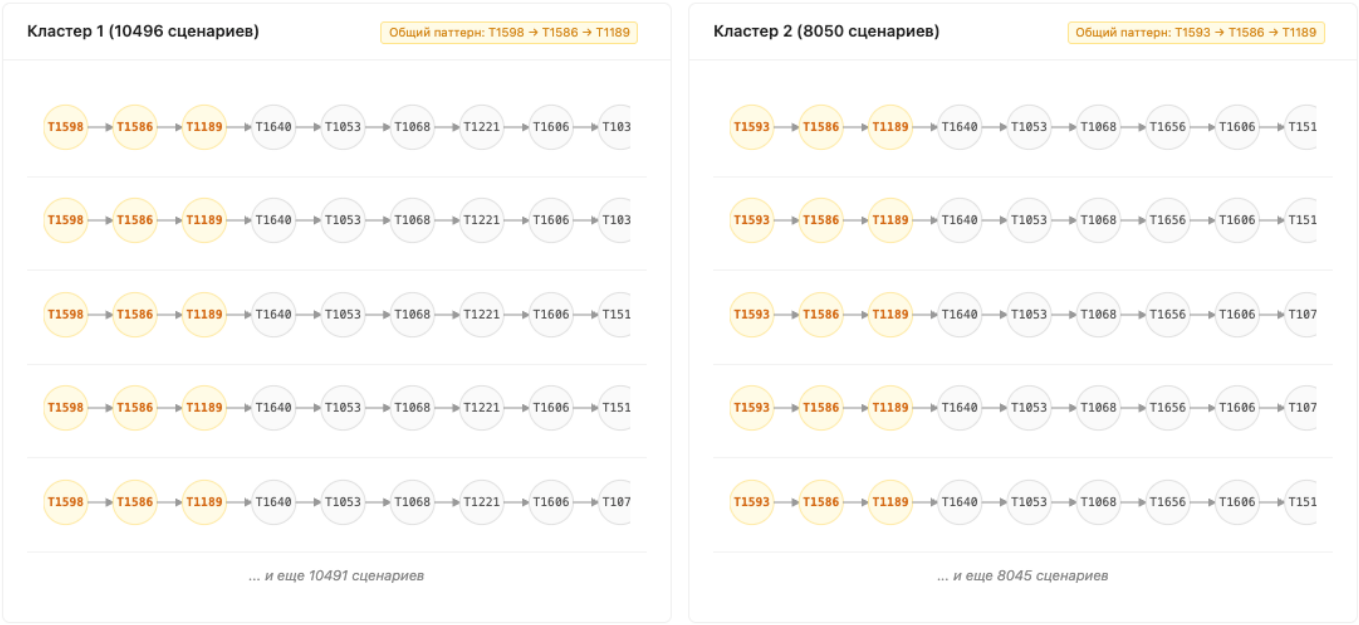


Рисунок 19 – Кластер сценариев для CAPEC 164

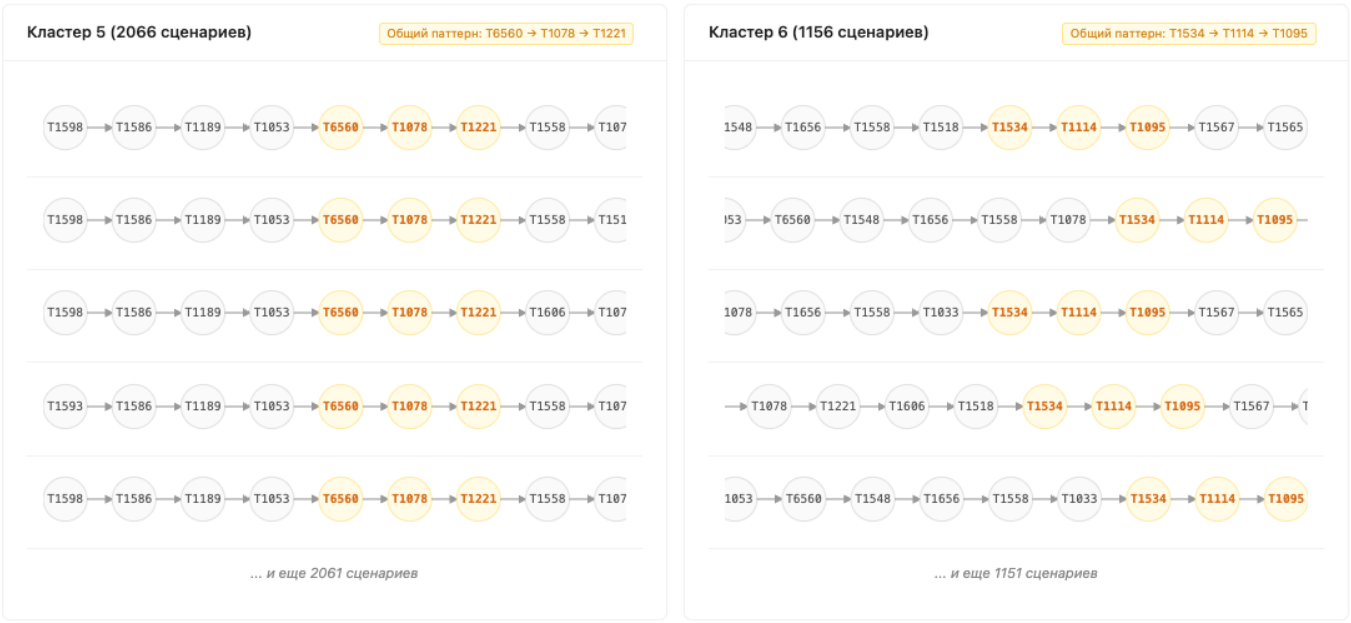


Рисунок 20 – Кластер сценариев для CAPEC 656

С помощью методов машинного обучения (например, k-means) сценарии группируются по сходству – например, по тому, какие техники включают и на каких этапах [44, 45].

Это позволяет выявить несколько типовых групп сценариев атак. Например, один кластер может соответствовать «простым» атакам (фишинг без малвари, ориентированный только на кражу паролей), другой – более сложным многоэтапным проникновениям с установкой бекдора и движением по сети. Аналитик может кликнуть на кластер, чтобы увидеть таблицу сценариев, принадлежащих к этой группе, с указанием их характеристик (ключевые техники, идентифицированные уязвимости, рассчитанный риск).

Такие таблицы позволяют детально изучить определённый сценарий или сравнить несколько сценариев между собой. В таблице отображаются, например: ID сценария, последовательность техник, наличие критических шагов, общий риск-фактор.

Пользовательский интерфейс позволяет сортировать и фильтровать эту таблицу – например, вывести все критические сценарии, отсортировать их по убыванию риска или отфильтровать сценарии, содержащие конкретную технику.

2.5 Проектирование модуля взаимодействия с AI-агентом для формирования регламентов по противодействию атакам класса «Социальная инженерия»

Модуль взаимодействия с AI-агентом служит интеллектуальным ядром системы, обеспечивающим трансформацию аналитических данных, полученных на предыдущих этапах (агрегации, оценки, визуализации), в формализованные регламенты реагирования и защиты от атак социальной инженерии.

Он базируется на дообученном генеративном AI-агенте, построенным на базе открытой языковой модели (LLM) и адаптированной под предметную социальной инженерии.

Эффективно дообучить модель помогло использование LoRA и P-tuning [46, 47].

Модуль имеет многоуровневую архитектуру, включающую ядро AI-агента.

Данный AI-агент разработан на платформе открытой архитектуры, которая включает модели, обладающие возможностями генерации текста, анализа инструкций и составления регламентов.

Однако в базовом виде такие модели обладают общими знаниями, не адаптированными под специфику MITRE ATT&CK, CAPEC, CWE, NIST 800-30 и сценариев социальной инженерии.

Поэтому ядро проходит дополнительное обучение (fine-tuning) и инструкционную адаптацию (instruction-tuning).

Также архитектура включает обучающий pipeline (Data Adapter), включающий:

- сбор корпоративных и технических данных, включая:
  - сценарии из модуля генерации (более 300 000);
  - мэппинг техник на уязвимости (ATT&CK ↔ CAPEC ↔ CWE);
  - каталоги митигирующих мер (ATT&CK Mitigations, CIS Benchmarks, NIST SP 800-53);
- аннотирование данных: каждая техника и шаблон маркируется контрмерами, приоритетами, типами воздействия и эффективностью;
- формирование инструкционных пар: на вход — описание сценария, на выход — мера защиты с аргументацией;
- обучение через LoRA или P-tuning (для сокращения ресурсоемкости): модель дообучается без полного fine-tuning, но с сохранением доменной адаптации.

Еще одним ключевым элементом архитектуры является внутренняя база знаний, которая формируется путем агрегации данных из:

- MITRE ATT&CK (все техники, тактики, митигирующие меры);
- CAPEC (паттерны атак);
- CWE (связанные уязвимости);
- NIST SP 800-30 (модель оценки рисков);
- NIST SP 800-53 / ISO 27001 (контрмеры, регламенты);
- реальные playbook-и SOC (SOC maturity guides, IR manuals);
- обогащение данными из OSINT/CTI (например, отчеты от FireEye, Mandiant, IBM X-Force).

Формирование регламентов в модуле взаимодействия с AI-агентом организовано как непрерывный конвейер. Каждый этап основывается на данных предыдущих модулей, что обеспечивает создание обоснованных мер защиты от самых опасных сценариев социальной инженерии.

Изначально агенту передаются агрегированные данные: перечни сценариев с максимальным риском, частотность использования техник и паттернов, распределения по тактикам, а также известные уязвимости, которые часто фигурируют в критических цепочках. Дополнительно загружаются глобальные параметры, отражающие ограничения и цели конкретной организации, включая бюджет, целевую модель угроз, требования нормативов (например, ISO/IEC 27001, PCI DSS) и зрелость SOC.

На основе этого входного массива строится контекстная картина угроз, где учитывается, какие тактики и техники чаще всего используются в сценариях с высоким риском, какие уязвимости являются повторяющимися, а также какие шаги типично предшествуют финальному этапу атаки — воздействию на актив. Эта агрегированная картина служит основой запроса к языковой модели: AI-агент должен определить, какие контрмеры способны эффективно разорвать цепочку реализации наиболее опасных сценариев.

Используя дообученную модель, агент выполняет инференс — генерацию набора регламентов, привязанных к техникам MITRE ATT&CK и шаблонам CAPEC.

В ответ формируется структурированный перечень защитных мер с оценкой их приоритета и эффективности. Каждая мера сопровождается пояснением применимости: какие техники она перекрывает, на каких этапах внедряется, и насколько она влияет на снижение совокупного риска по NIST SP 800-30. Формируются также детализированные пошаговые инструкции по реализации контрмер, от базовых (включение MFA, сегментация сети) до более сложных (например, внедрение PAM или hardening системных политик).

Сгенерированные регламенты могут быть экспортированы в нескольких форматах: как автоматизируемые YAML/JSON объекты для интеграции с SIEM/SOAR-системами, так и в виде читаемых PDF или Markdown-отчетов для

использования офицерами ИБ. Таким образом, AI-модуль не просто выдает список общих рекомендаций, а генерирует конкретный план действий, адаптированный под структуру угроз и возможности конкретной организации.

При необходимости AI-агент запрашивает дополнительные параметры: уровень зрелости SOC, состав инфраструктуры (Cloud, On-Prem, Hybrid), уровень допущений (Zero Trust/Legacy). Это позволяет адаптировать меры к конкретной ИТ-среде, например:

- Для облачной среды AI рекомендует CSPM/CIEM;
- Для локальных систем — DLP, AD hardening и JIT-доступ;
- Для низкозатратного сегмента — повышение осведомленности и MFA.

Генерируемые регламенты экспортируются:

- в внутренний интерфейс системы (дашборд, отчёты);
- в формате YAML/JSON для интеграции с SIEM/SOAR;
- как отчет для CISO/аналитиков: визуализированный план по снижению риска.

Полный цикл работы AI модуля представлен на рисунке 21.

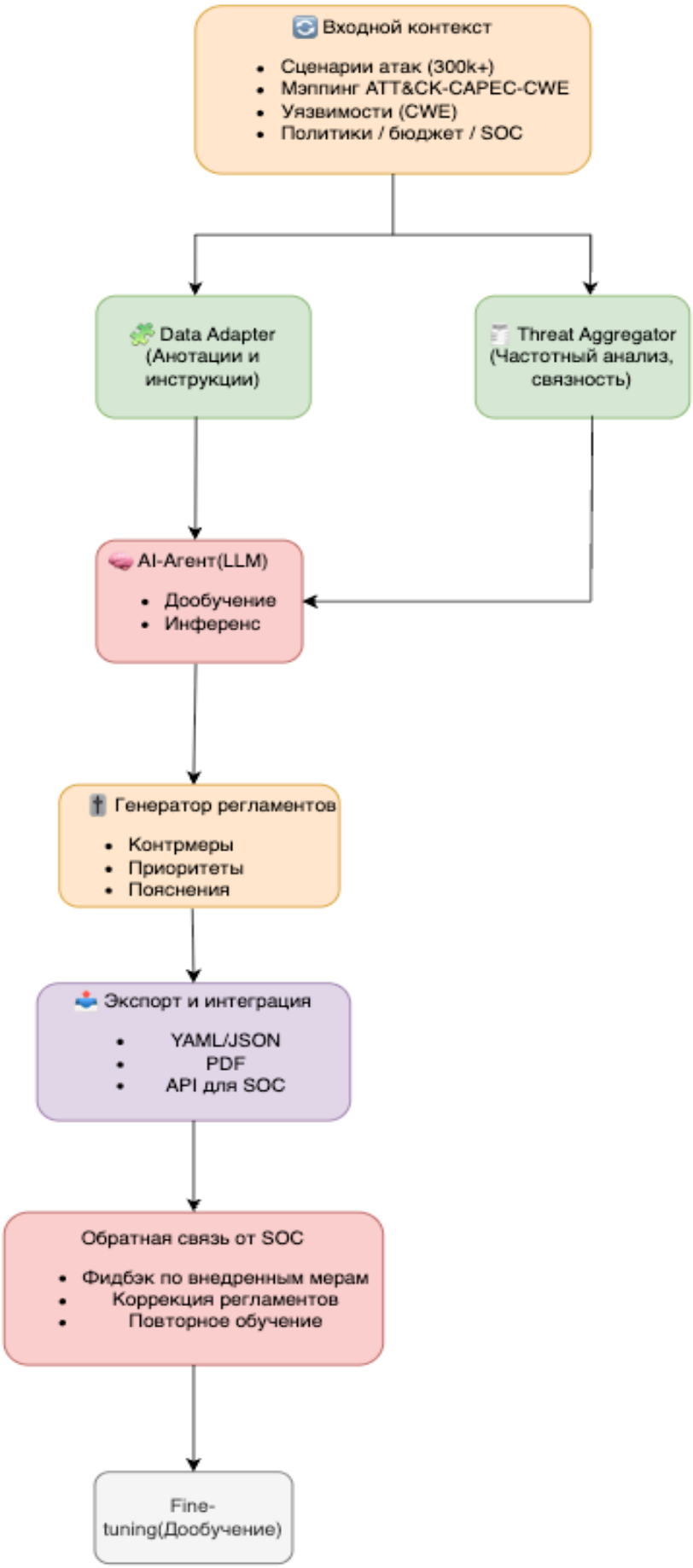


Рисунок 21 – Алгоритм работы AI-модуля

Модуль взаимодействия с AI-агентом замыкает аналитический контур: от генерации и оценки рисков — к интеллектуальному реагированию, формируя рекомендации, приоритеты и меры защиты. Использование дообученной модели на предметных данных и связка с формализованной базой знаний делает AI не просто генератором текста, а экспертной системой, способной выдавать обоснованные, адаптивные и практически применимые регламенты реагирования на социальную инженерию.

2.6 Проектирование модуля конструктора мер защиты

Модуль "Конструктор мер защиты" представляет собой прикладной компонент системы анализа и минимизации рисков атак социальной инженерии, предназначенный для интерактивного выбора и применения контрмер в рамках общей оценки сценариев на основе формализованных метрик.

Его функциональность базируется на интеллектуальной связке с AI-агентом и системе количественной оценки риска, а также учитывает динамическое воздействие выбранных мер на уровень совокупного риска сценариев атак.

Основная задача конструктора — сопоставление известных техник атак (на базе MITRE ATT&CK) с релевантными компенсирующими мерами, и моделирование изменений в структуре риска после их внедрения.

Таким образом, модуль не только предоставляет рекомендации, но и даёт возможность оценить, как применение той или иной меры повлияет на текущую совокупность сценариев атак**.**

Каждая мера представлена в виде структурированной карточки с формализованным содержанием:

- название меры (например, "Многофакторная аутентификация");
- приоритет внедрения (HIGH, MEDIUM, LOW) — отражает критичность её реализации;
- ожидаемая эффективность (%) — коэффициент снижения ущерба от уязвимых техник;

- список техник MITRE ATT&CK, на которые влияет мера;
- пошаговая инструкция внедрения, поддерживающая реализацию меры на практике;
- кнопка "Применить меру", которая запускает расчёт эффекта на сценарный риск.

Пример предложенных мер можно увидеть на рисунках ниже.

Так на рисунке 22 можно увидеть динамически предлагаемую меру «Многофакторная аутентификация».

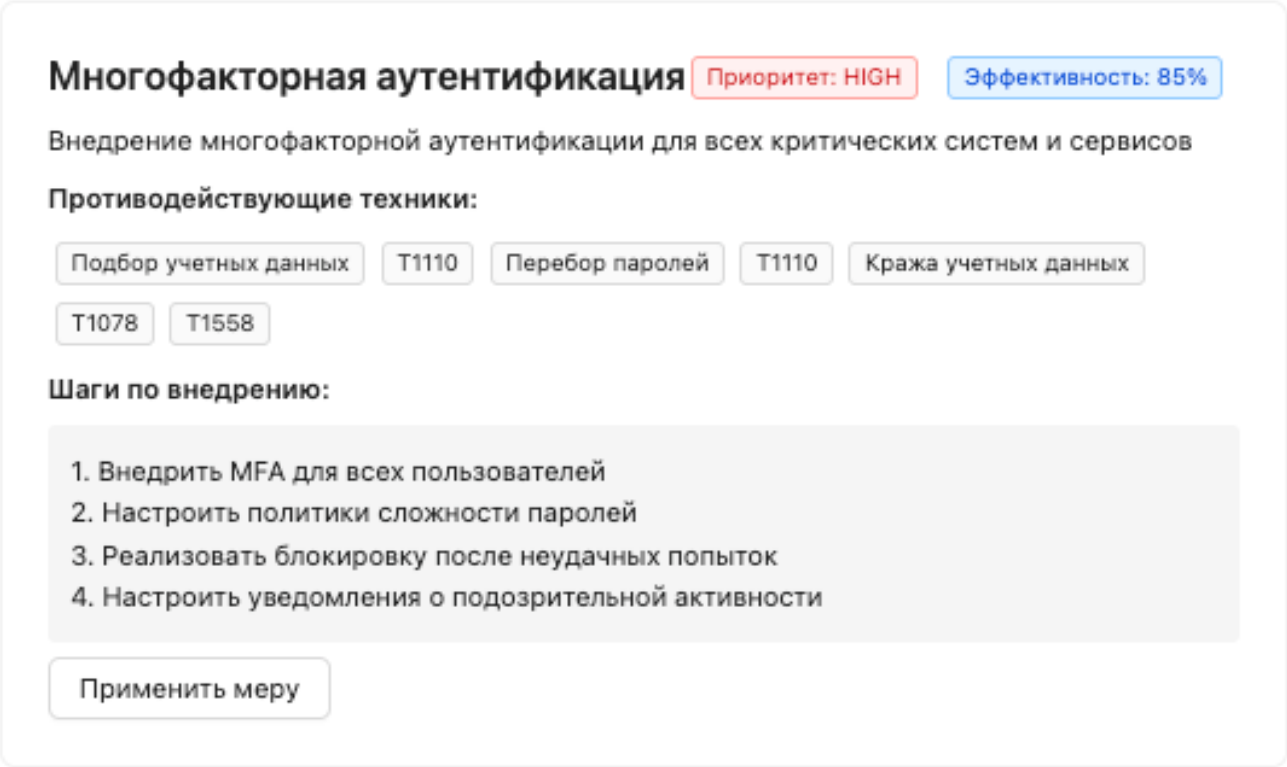


Рисунок 22 – Предложенная мера «Многофакторная аутентификация»

На рисунке 23 изображена мера «Шифрование данных».

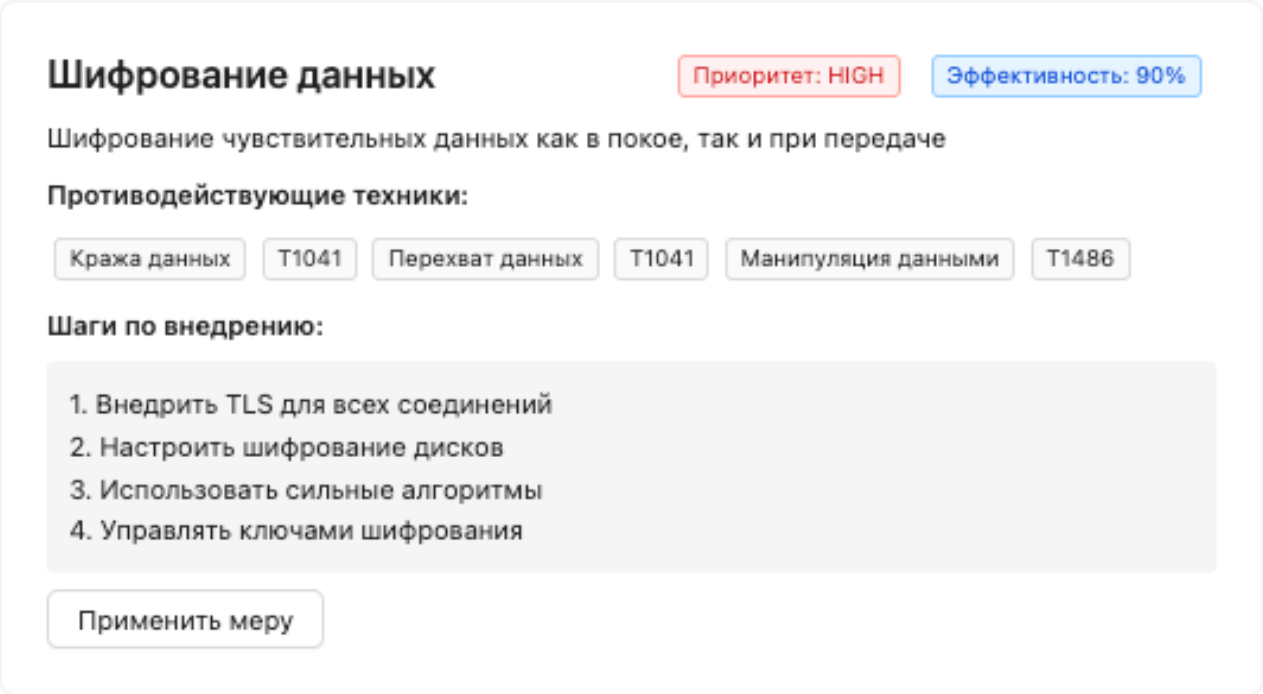


Рисунок 23 – Предложенная мера «Шифрование данных»

«Резервное копирование» – также немаловажная мера, ее эффективность и противодействующие техники можно увидеть на рисунке 24.

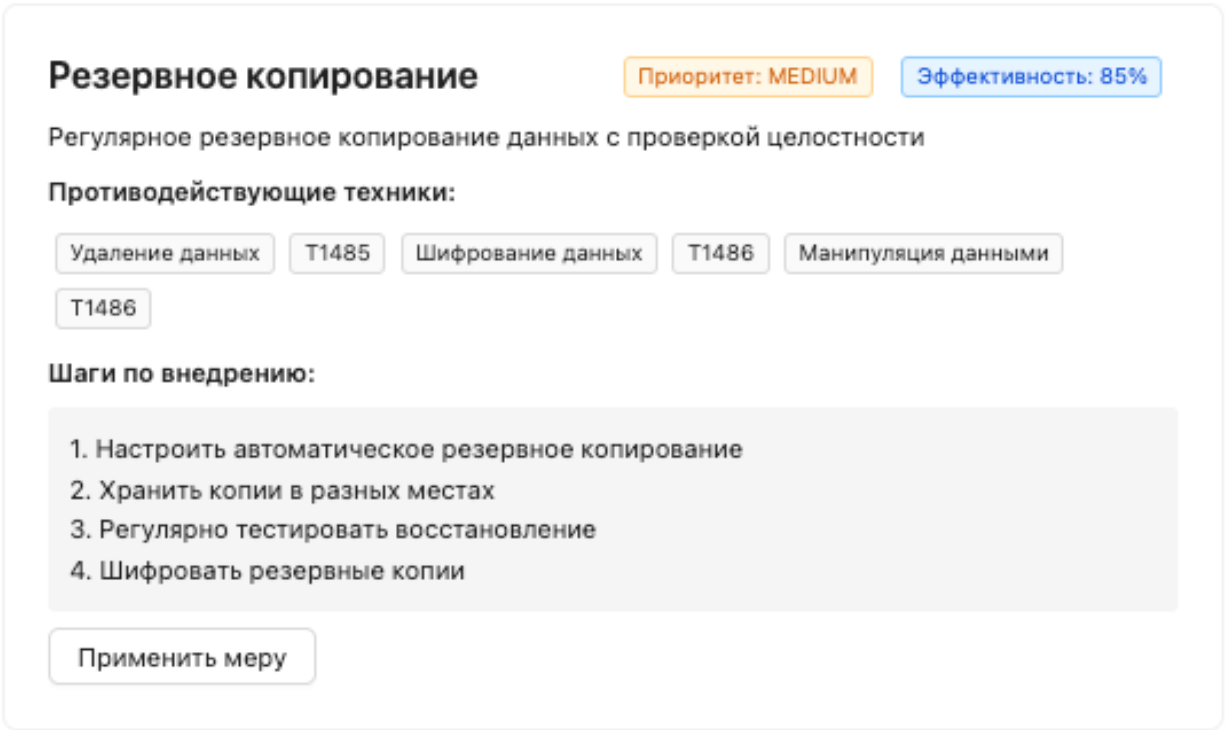


Рисунок 24 – Предложенная мера «Резервное копирование»

На рисунке 25 показана менее эффективная мера (75%), с приоритетом «Medium»

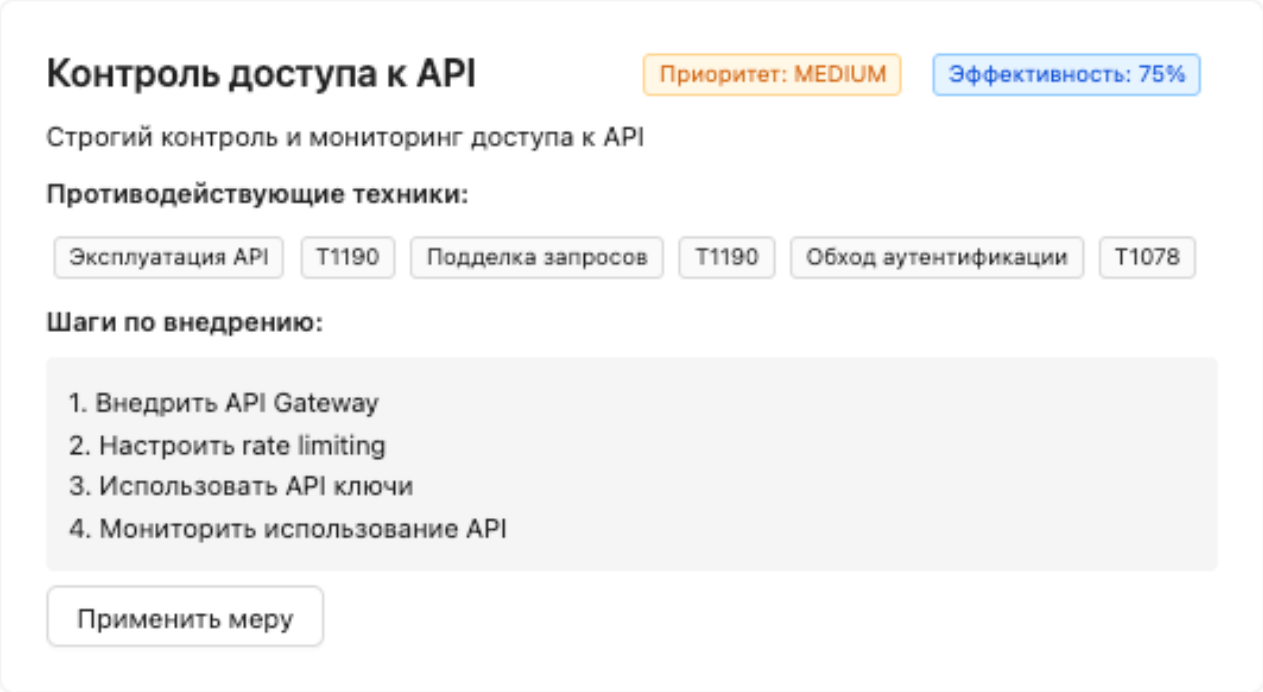


Рисунок 25 – Предложенная мера «Контроль доступа к API»

Каждый сценарий атаки рассматривается как цепочка техник:

$$T_1 \rightarrow T_2 \rightarrow \cdots \rightarrow T_n \quad (1)$$

Общий риск сценария $R_{\text{сцен}}$ рассчитывается по формуле:

$$R_{\text{сцен}} = (\sum_{i=1}^{n} U_i) * (\prod_{i=1}^{n} P_i) \quad (2),$$

где U_i — ущерб от техники T_i , P_i — вероятность реализации T_i

При применении меры, её эффективность E применяется к каждой из техник, на которые она влияет:

$$U_i' = U_i * (1 - E) \quad (3),$$

После чего риск пересчитывается:

$$R'_{\text{сцен}} = \left(\sum_{i=1}^{n} U'_i\right) * \left(\prod_{i=1}^{n} P_i\right) \quad (4),$$

А затем рассчитывается снижение риска в процентах:

$$\Delta R(\%) = \frac{R_{\text{сцен}} - R'_{\text{сцен}}}{R_{\text{сцен}}} * 100\%$$

Результат применения мер можно увидеть в таблице на рисунке 26.

Сбор данных	Командование и управление	Эксфильтрация	Удар	Риск
T1025	T1095	T1567	T1486	0.3937408103891934 Нет снижения риска
T1113	T1095	T1567	T1486	0.3936424388850754 Нет снижения риска
T1025	T1095	T1567	T1486	0.3921597384463597 Нет снижения риска
T1113	T1095	T1567	T1486	0.3920927417961035 Нет снижения риска
T1025	T1095	T1567	T1486	0.3596529777145699 ↓ Снижение риска на 7.3% Многофакторная аутентификация: -7.3%
T1113	T1095	T1567	T1486	0.3595657343610233 ↓ Снижение риска на 7.3% Многофакторная аутентификация: -7.3%
T1025	T1095	T1567	T1486	0.3863549313003425 Нет снижения риска
T1113	T1095	T1567	T1486	0.3863042730548508 Нет снижения риска

Рисунок 26 – Результат применения мер для CAPEC 656

На рисунке 27 можно увидеть результат применения сразу нескольких мер («Многофакторная аутентификация» и «Шифрование данных»).



Рисунок 27 – Результат применения нескольких мер для CAPEC 656

После применения меры:

1. Пересчитываются значения риска для всех затронутых сценариев;

2. Обновляется визуализация таблицы рисков (сценарии High могут перейти в Medium/Low);

3. Пользователь получает наглядную обратную связь по эффективности внедрённой меры.

Модуль тесно связан с остальными компонентами платформы, в частности — с:

- AI-агентом, который предлагает релевантные меры;
- Модулем визуализации сценариев, где отражаются изменения в уровне риска.

Модуль демонстрирует интеграцию количественного подхода к управлению рисками с автоматизированной системой генерации регламентов. Такой подход:

- позволяет перейти от декларативной ИБ (политики "в общем виде") к точечным компенсирующим мерам;
- даёт численную оценку эффективности защиты;

• поддерживает концепции «решений на основе данных» (data-driven security engineering).

Системы типа CIS Benchmarks и NIST SP 800-53 могут служить основой для создания карточек мер [48].

2.7 Проектирование взаимодействия модулей в системе

Взаимодействие между всеми компонентами платформы организовано по модульному принципу, обеспечивая чёткое разделение функций и обмен данными через определённые интерфейсы. На рисунке 28 представлена общая схема информационных потоков.

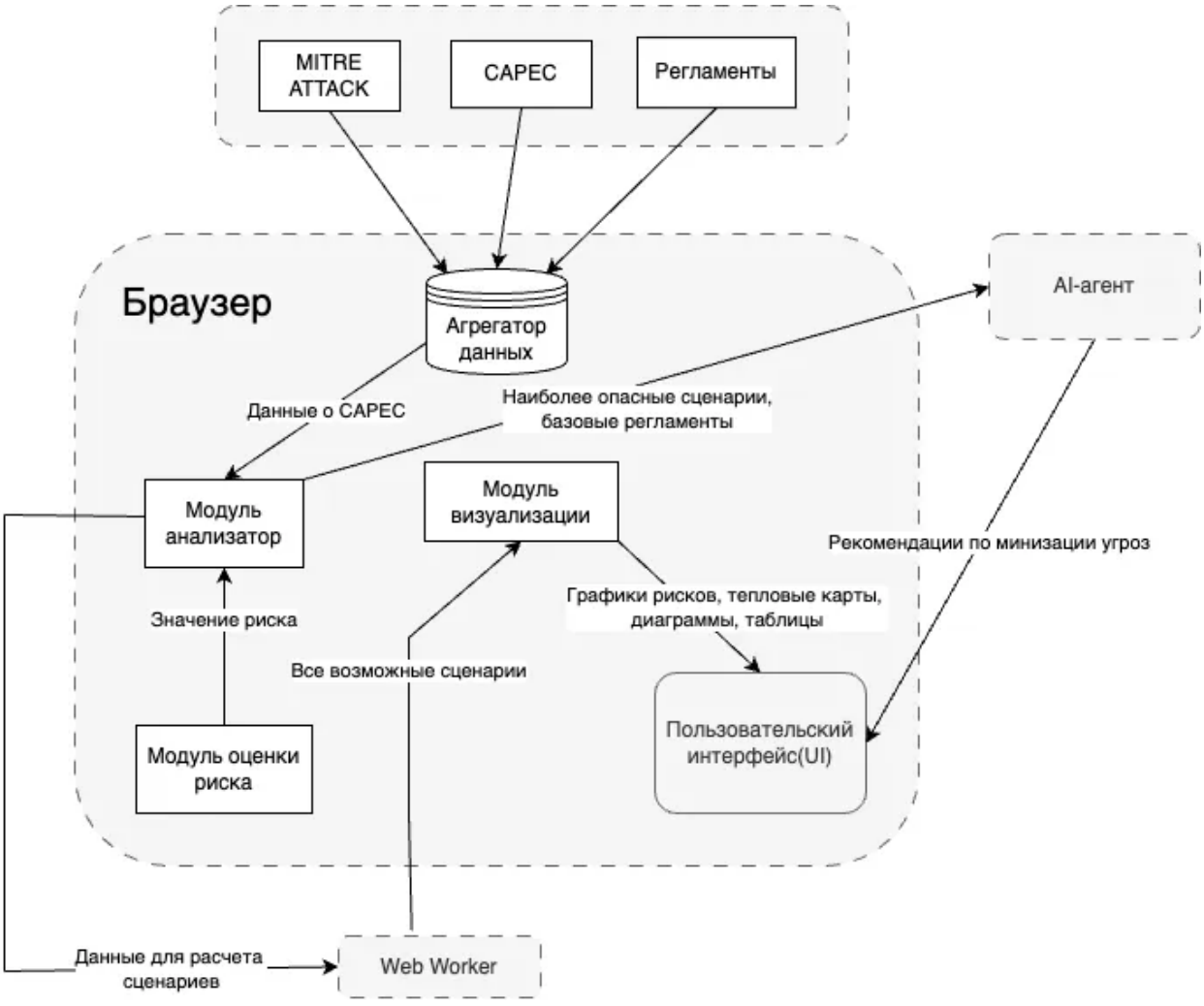


Рисунок 28 – Взаимодействие между всеми компонентами платформы

Модуль агрегации данных выступает центральным хранилищем знаний, получая информацию из баз знаний (MITRE ATT&CK, MITRE CAPEC и из нормативных регламентов) и распределяя обогащённые данные другим подсистемам; анализатор, модуль оценки рисков и визуализатор последовательно обрабатывают эти данные, а результаты их работы интегрируются через пользовательский интерфейс (UI) и фоновые процессы Web Worker. Ниже подробно рассматривается, какие данные и в каком формате передаются между модулями, а также логика запуска компонентов и расширяемость системы.

На верхнем уровне система разделена на фронтенд-часть (браузерное приложение) и внешние сервисы. Основные модули — агрегация, анализ, оценка рисков, визуализация и AI-агент — взаимодействуют по схеме «конвейера», где выходные данные одного этапа служат входными для следующего. В рамках браузерного приложения функционирует пользовательский интерфейс (UI), отвечающий за интерактивное отображение результатов и приём команд пользователя, и Web Worker, выполняющий ресурсоёмкие вычисления в фоновом потоке. Внешними по отношению к браузеру являются источники данных (базы знаний MITRE ATT&CK, CAPEC и др.) и модуль AI-агента (развёрнутый как отдельный сервис ИИ).

Модуль агрегации данных занимает центральное положение: он импортирует информацию из авторитетных баз знаний и формирует единое хранилище сценариев атак. В частности, агрегатор загружает каталог MITRE CAPEC (XML/JSON-файл с описанием шаблонов атак) и базу MITRE ATT&CK (например, через REST API или файл в формате STIX 2.0), а также может включать связанные нормативные справочники по мерам защиты (например, типовые контрмеры из NIST SP 800-53, ISO/IEC 27001).

Полученные данные нормализуются и сохраняются во внутреннем формате: для каждой атаки класса «социальная инженерия» строится структурированный сценарий (последовательность этапов с привязкой к тактикам ATT&CK) с детализацией техник и соответствующих шаблонов CAPEC. Агрегатор осуществляет кросс-связку записей (например, сопоставляет шаблоны CAPEC с техниками

ATT&CK, как описано в разделе 2.1) и сохраняет результирующие сущности в виде объектов (например, JSON-документов) в памяти приложения или локальной базе данных. Это централизованное хранилище служит основой для всех последующих модулей — анализатора, оценки риска, визуализатора и AI-агента.

Модуль анализатора уязвимостей и паттернов получает на вход агрегированные сценарии атак (из хранилища агрегатора) и дополняет их новой информацией. В ходе анализа каждому шагу сценария добавляются сведения о связанных уязвимостях и слабостях системы: анализатор извлекает из описаний CAPEC ссылки на CWE (Common Weakness Enumeration) и, при наличии, конкретные идентификаторы уязвимостей CVE. Например, если шаг включает технику фишинга (ATT&CK T1566) с шаблоном CAPEC-98, модуль найдёт связанные слабости CWE-451 (UI Misrepresentation of Critical Information) и прикрепит их к шагу сценария. Таким образом, исходный сценарий обогащается связной информацией о том, какие уязвимости необходимы злоумышленнику для реализации каждого этапа. Кроме того, анализатор выполняет обобщение повторяющихся последовательностей шагов (паттернов атак): выявляет часто встречающиеся комбинации техник и строит на их основе типовые шаблоны атак. Результаты работы анализатора (перечень слабых мест сценария, указание критических шагов и каталог типовых паттернов) сохраняются в модели данных сценария — либо в том же хранилище агрегатора (добавлением полей к объектам сценариев), либо передаются напрямую следующему модулю.

Модуль оценки рисков автоматически присваивает каждому сценарию количественную или категорийную оценку уровня риска на основе методологии NIST SP 800-30. Входными данными для него служат обновлённые сценарии из агрегатора (уже помеченные техниками, CAPEC-шаблонами и связанными уязвимостями). Алгоритм расчёта включает: оценку вероятности реализации сценария и оценку потенциального ущерба от него.

Вероятность определяется на основе ряда факторов (наличие редких уязвимостей, число сложных этапов, требуемые навыки атакующего и т.п.), а ущерб — по наихудшим последствиям, связанным с финальной целью сценария (например,

утечка данных или отказ в обслуживании). Модуль присваивает каждому сценарию числовое значение риска R = P × Impact или относительную категорию (High, Moderate, Low) согласно риск-матрице NIST. Результаты расчёта (например, вероятность, влияние, итоговый уровень риска для каждого сценария) добавляются к структуре данных сценария. Поскольку число сгенерированных сценариев может достигать сотен тысяч, модуль оценки рисков оптимизирован для пакетной обработки: вычисления выполняются параллельно и кэшируются для повторяющихся фрагментов сценариев. Реализовать такой механизм в браузере помогает фоновый поток Web Worker, который получает от агрегатора необходимый объём данных (список сценариев с их параметрами) и производит вычисления без блокировки UI. По завершении расчётов модуль оценки рисков обновляет хранилище сценариев: каждому сценарию присвоен атрибут уровня риска, а совокупность данных о распределении рисков (количество сценариев в каждой категории, статистики по значению R и пр.) передаётся в модуль визуализации.

Модуль визуализации отвечает за преобразование полученной информации в интерактивные графические представления, удобные для анализа. На вход он получает сразу несколько видов данных: полный перечень сгенерированных сценариев (от модуля агрегации), результаты анализа уязвимостей и шаблонов (от анализатора) и оценки риска по каждому сценарию (от модуля риска). Визуализатор агрегирует эти сведения, подготавливая набор отображений:

• **таблица сценариев** – перечень всех сгенерированных сценариев (или отфильтрованных подмножеств) с разбивкой по этапам атаки и указанием рассчитанного риска. Каждый сценарий представлен как цепочка из идентификаторов техник ATT&CK (от «Разведки» до «Воздействия»), дополненная ссылками на шаблоны CAPEC в шагах и значением риска. Пользовательский интерфейс позволяет сортировать и фильтровать эту таблицу (например, показать только сценарии с высоким риском или содержащие конкретную технику);

• **графики распределения рисков** – диаграммы, показывающие суммарную статистику по уровням риска среди сценариев. Например, гистограмма с количеством

сценариев в категориях низкий, средний и критический риск позволяет сразу увидеть общую «пирамиду рисков»;

• **диаграммы частот техник и тактик** – визуализация частоты встречаемости определённых техник ATT&CK и этапов-тактик в сгенерированных сценариях.

Модуль строит гистограммы топ-N наиболее часто используемых техник (например, доля сценариев, где присутствует техника T1059 – Command and Scripting Interpreter, T1566 – Phishing и т.д.), а также круговые диаграммы распределения техник по тактикам атаки. Эти визуализации отражают, какие методы атаки преобладают в сценариях социальной инженерии, и помогают сфокусировать защитные меры на самых распространённых векторах;

• **кластеризация сценариев** – группировка схожих сценариев методом машинного обучения (например, алгоритмом k-means) и отображение результатов в виде кластерной диаграммы. Сценарии, близкие по структуре (совпадающие последовательности техник), объединяются в кластеры, позволяя выявить несколько типовых сценарных семейств: от простых одностадийных (например, только фишинг для сбора учётных данных) до сложных многоэтапных цепочек атак. Аналитик может интерактивно изучить каждый кластер через UI, получив список входящих в него сценариев и их характеристики (ключевые техники, обнаруженные уязвимости, уровень риска и пр.). Это даёт возможность сравнить группы угроз между собой и понять, какие сочетания техник встречаются чаще всего.

Вся подготовленная визуализацией информация передаётся в пользовательский интерфейс. UI-модуль встроен в веб-приложение и отвечает за отображение интерактивной дашборд-панели со всеми вышеперечисленными элементами: таблицами, графиками, диаграммами и пр. Пользователь через UI может инициировать определённые действия (например, отфильтровать данные, выбрать конкретный сценарий для подробного рассмотрения или запросить рекомендации AI-агента) — эти команды обрабатываются соответствующими модулями в фоне, после чего UI обновляет отображаемое состояние. Так достигается двусторонняя связь: визуализатор (в связке с Web Worker) обеспечивает поток данных в интерфейс, а UI,

в свою очередь, позволяет пользователю запрашивать новые расчёты или уточнения, которые перенаправляются в нужный модуль.

Модуль AI-агента интегрируется в систему как отдельный интеллектуальный сервис, генерирующий рекомендации по защите от обнаруженных угроз. Он взаимодействует с остальными компонентами через чётко определённый интерфейс: на вход получает обобщённые аналитические данные, а на выходе возвращает сформированные регламенты (наборы мер по минимизации рисков).

Поскольку этот модуль реализован на базе большой языковой модели (LLM) и требует значительных вычислительных ресурсов, он вынесен за пределы браузерного приложения (см. правую часть рисунка 8): взаимодействие с AI происходит через сетевой API вызов. В качестве входных данных AI-агенту передаются:

• **отчёт о сценариях высокого риска:** список наиболее опасных сценариев (например, топ-10 или топ- процент по уровню риска) с описанием их ключевых шагов, используемых техник и связанных уязвимостей. Эти сведения позволяют модели сфокусироваться на тех атаках, которые представляют наибольшую угрозу организации;

• **статистическая сводка:** данные о распространённости методов атаки – самые частые техники и тактики, выявленные в сценариях (в особенности в критических сценариях). Например, модель получает информацию, что техника T1059 встречается в >50% сценариев, а фишинг (T1566) — в 15% случаев, и что на этапах Initial Access и Execution наблюдается наибольшее разнообразие методов. Такая сводка формирует у AI «картину угроз», характерных для рассматриваемого множества сценариев;

• **контекст организации:** дополнительные параметры, задаваемые пользователем или по умолчанию – профиль организации, для которой проводится анализ, её отраслевая принадлежность, уровень зрелости процессов безопасности (SOC maturity), действующие нормативы и ограничения (например, требования стандартов PCI DSS, GDPR, региональных регуляторов). Эти данные помогают AI-агенту адаптировать рекомендации под конкретные условия эксплуатации. Например, если указано, что инфраструктура облачная, агент учтёт это при подборе

мер (посоветует внедрение CSPM/CIEM для контроля облачных настроек); если бюджет ограничен – сделает упор на недорогие организационные меры, такие как обучение персонала и включение MFA;

• **база знаний по контрмерам:** помимо сведений о самих атаках, AI-модуль располагает встроенной базой знаний о защитных мерах. В процессе дообучения модели были загружены каталоги митигирующих действий MITRE ATT&CK (предлагаемые контрмеры против каждой техники), контрольные рекомендации из NIST SP 800-53, CIS Controls, а также реальные плейбуки реагирования (IR playbooks). За счёт этого AI обладает информацией о том, какие меры эффективно прерывают те или иные цепочки атаки.

Получив входные данные, AI-агент формирует развернутый ответ с рекомендациями. Результат представляет собой структурированный перечень мер безопасности, каждая из которых содержит: описание и назначение меры, приоритет внедрения, ожидаемую эффективность в снижении риска (в процентах), список атакующих техник, которые она нейтрализует, и ссылки на релевантные стандарты или политики.

Эти рекомендации можно рассматривать как проект регламента по противодействию социальной инженерии. Пример фрагмента такого ответа: «Внедрить многофакторную аутентификацию (приоритет High, эффективность ~85%) – мера против техник T1110 Brute Force, T1078 Valid Accounts, препятствует несанкционированному использованию украденных учётных записей».

Сгенерированные меры передаются обратно в браузерное приложение через API. Пользовательский интерфейс получает их и отображает в удобном виде — список карточек мер в специальном разделе дашборда.

Модуль конструктора мер защиты (интерактивного применения мер) тесно связан с AI-агентом и модулем оценки риска, объединяя их функциональность.

Получив от AI список рекомендаций, система позволяет пользователю выбрать конкретные меры и применить их виртуально к набору сценариев, чтобы увидеть, как это повлияет на общий уровень риска.

Технически это реализовано следующим образом: когда пользователь нажимает «Применить меру» для выбранной рекомендации, конструктор вызывает процедуру перерасчёта рисков в Web Worker с учётом введённой меры.

Внутри модуль оценки риска обновляет параметры тех шагов сценариев, на которые влияет данная контрмера (например, снижает вероятность успешности этапа или уменьшает потенциальный ущерб от него на указанный процент эффективности меры). Затем вычисляется новый суммарный риск каждого затронутого сценария по скорректированной формуле.

Изменения немедленно сохраняются в модели данных и передаются в модуль визуализации для обновления отображения: в таблице сценариев пересчитываются значения риска, сценарии могут перейти из категории High в Medium или Low, графики распределения рисков перестраиваются.

UI подчёркивает достигнутый эффект (например, показывает величину снижения риска в процентах для всей группы сценариев).

Такой интерактивный подход («что, если применить меру X?») позволяет эксперту по безопасности протестировать различные стратегии защиты и выбрать наиболее эффективные, опираясь на количественные показатели.

Обобщённые данные, которые циркулируют между компонентами, можно представить в виде API или форматов обмена.

В таблице 5 перечислены ключевые сущности и структуры, передаваемые между модулями системы, с указанием их типа и содержания.

Таблица 5. Основные данные, передаваемые между модулями системы

Интерфейс / Сущность	Источник → Получатель	Формат данных	Описание содержимого
Каталог ATT&CK (тактики/техники)	Внешняя база MITRE → Агрегатор	STIX 2.0 (JSON), REST API	Описание тактик и техник ATT&CK: идентификатор (T####), название, тактика-владелец, описание техники, связанные рекомендуемые меры и др.

Продолжение таблицы 5

Интерфейс / Сущность	Источник → Получатель	Формат данных	Описание содержимого
Каталог CAPEC (шаблоны атак)	Внешняя база CAPEC → Агрегатор	XML, JSON	Список шаблонов атак: идентификатор CAPEC-###, название атаки, описание, связанные слабости (CWE), связь CanPrecede (каким шаблонам может предшествовать данный) и пр.
Единый сценарий атаки	Агрегатор → Анализатор → Оценка риска → Визуализация	JSON	Структура сценария: последовательность шагов 1...N. Каждый шаг содержит: этап ATT&CK (тактика), технику ATT&CK (ID + название), соответствующий шаблон CAPEC (ID + название, если есть), связанные CWE (список), флаг «критический шаг» (если без него цель атаки недостижима).
Расчёт риска сценария	Оценка риска → Визуализация (и хранилище)	JSON	Показатели риска для сценария: рассчитанная вероятность (Low/Medium/High или численно), рассчитанный Impact (уровень ущерба), значение R = P×I (число или категория риска). Эти поля добавляются в объект сценария.
Сводка по рискам	Оценка риска → Визуализация → UI	JSON	Статистика по всем сценариям: количество сценариев каждого уровня риска, процент сценариев с конкретными техниками, топ-10 самых опасных сценариев (ID и краткое описание), и т.д. Используется для построения графиков и передачи в AI.
Данные для AI-запроса	Визуализация/Аналитика → AI-агент		Подготовленный запрос к AI: текстовое описание ситуации (напр. “Обнаружены 300 тыс. сценариев, из них X критических...”),

Продолжение таблицы 5

Интерфейс / Сущность	Источник → Получатель	Формат данных	Описание содержимого
Данные для AI-запроса	Визуализация/Аналитика → AI-агент	JSON context	включающее встроенные JSON-фрагменты или списки (перечень топ-рисковых сценариев, часто встречающихся техник, известных уязвимостей). Формат адаптирован под модель (инструкция + данные).
Рекомендации AI (меры защиты)	AI-агент → UI/Конструктор мер	JSON (массив объектов Measure)	Набор сгенерированных мер: каждый объект содержит поля: name (название меры), priority (приоритет: High/Med/Low), effect (ожидаемое снижение риска, %), techniques (список ID техник ATT&CK, на которые мера воздействует), description (пояснение и шаги внедрения). Эти данные отображаются в UI и используются конструктором мер для перерасчёта рисков.

Каждый модуль имеет чётко определённый интерфейс взаимодействия. Например, модуль визуализации получает от предшественников сразу два типа данных: полный список сценариев (с полями техник, CAPEC и уязвимостей) и результаты оценки риска (сводку и пометки об уровне риска для каждого сценария). Это позволяет визуализатору комбинировать данные, не запрашивая повторно исходные базы.

Коммуникация между компонентами внутри браузера происходит через обмен объектами (например, передачу JSON-структур через postMessage между Web Worker и основным потоком UI). Внешний AI-агент взаимодействует по HTTP API: фронтенд отправляет ему сформированный prompt с контекстом в теле запроса (например, в

формате JSON), а в ответ получает JSON с рекомендациями. Благодаря унификации форматов (везде используется JSON или совместимые объекты) модули легко интегрируются друг с другом. Это облегчает отладку и потенциальную замену компонентов — например, можно заменить источник данных (подключить вместо CAPEC иной каталог атак, преобразовав его в требуемый формат) без изменения логики анализатора или визуализатора.

При инициализации системы происходит загрузка основных баз знаний и генерация сценариев, после чего запускаются анализ и оценка, заканчиваясь визуализацией результатов. Общая последовательность работы модулей можно описать следующим образом:

• **агрегация данных (инициализация знаний):** при старте приложение запускает модуль агрегации. Агрегатор скачивает актуальные данные ATT&CK и CAPEC (либо читает их из локального кэша, если уже сохранены) и строит набор сценариев атак социальной инженерии. На этом этапе формируется единое хранилище сценариев: каждая комбинация техник и шаблонов CAPEC, связанная отношением «может предшествовать», развёртывается в отдельный сценарий (в результате получается множество возможных путей атаки). Одновременно агрегатор может загрузить справочники базовых мер защиты (например, соответствия техник ATT&CK рекомендациям по MITRE Shield или NIST 800-53) и прикрепить их к модели данных — они пригодятся позднее для AI-агента. Результат работы модуля: список сценариев (с заполненными полями техник и CAPEC) сохраняется и передаётся далее;

• **анализ сценариев (обогащение данными об уязвимостях):** следующий запуск получает на вход сырые сценарии от агрегатора. Модуль анализатора перебирает каждый сценарий и для каждого шага обращается к базе знаний CAPEC/CWE (уже загруженной агрегатором) для поиска соответствующих уязвимостей. Также анализатор фиксирует повторяющиеся шаблоны: если несколько различных сценариев содержат одинаковую последовательность из нескольких техник подряд, такая последовательность маркируется как типовой паттерн. По завершении анализа каждое описание сценария дополнено: указаны вероятные CWE

для каждого шага, отмечены критически важные шаги (узлы, без которых дальнейшие этапы невозможны) и приписаны идентификаторы типовых паттернов (если сценарий относится к одной из часто встречающихся групп). Эти дополнения сохраняются обратно в хранилище сценариев. С этого момента система обладает достаточной информацией, чтобы оценивать значимость каждого сценария;

• **оценка рисков сценариев:** как только сценарии готовы, Web Worker инициирует параллельный расчёт рисков по всем цепочкам. Для каждого сценария вычисляется вероятность реализации и предполагаемый ущерб, затем итоговый риск.

Например, сценарию с множеством сложных шагов и редкими эксплойтами будет присвоена низкая вероятность, а сценарию, оканчивающемуся шифрованием данных (Ransomware) — высокий ущерб. Перемножение этих факторов даёт итоговую метрику риска, которую модуль преобразует в категорию (высокий/средний/низкий). Результат работы – каждому сценарию присвоены поля RiskScore (число) и RiskLevel (категория), а также составлена сводка: сколько всего сценариев каждого уровня, какие техники наиболее часто присутствуют в высокорисковых сценариях, и т.п. Вычисленные данные сериализуются в JSON и отправляются из Web Worker в основной поток приложения для дальнейшей визуализации;

• **визуализация и отображение пользователю:** получив от предыдущих этапов полный объём сведений, модуль визуализации строит интерактивные представления. В главном окне UI отображается дашборд аналитика: в одной панели – таблица всех сценариев (с возможностью поиска и фильтрации), в другой – графики (распределение рисков, частота техник, кластерные группы и пр.). Пользователь может изучать эту информацию, выявляя наиболее опасные сценарии. Например, кликнув на столбец гистограммы критических сценариев, он может получить список соответствующих сценариев в таблице; или выбрав определённый кластер, увидеть подробности входящих в него цепочек атак. В этот момент завершается основной цикл автоматического анализа: система сгенерировала и оценила множество вариантов атак и наглядно представила результаты специалисту;

• **запрос рекомендаций AI-агента:** на основании визуализированных данных пользователь (или сама система автоматически) может инициировать обращение к AI-модулю для выработки защитных мер. Например, аналитик нажимает кнопку «Сформировать регламенты» и тем самым запускает передачу данных в AI. Модуль визуализации собирает необходимую информацию для контекста: выделяет топ-опасные сценарии, формирует описание общей обстановки и передаёт вместе с заранее загруженными параметрами организации в API AI-агента. AI-сервис принимает запрос, анализирует его и генерирует рекомендации по мерам безопасности. Этот процесс может занимать несколько секунд, за это время UI может показывать индикатор загрузки. После завершения генерации результат (набор мер) возвращается в приложение;

• **получение и применение мер защиты:** рекомендации AI-агента отображаются в UI в структурированном виде – например, как список конкретных регламентов: «Мера X – описания, приоритет, эффект; Мера Y – ...» и так далее. Аналитик информационной безопасности может последовательно рассмотреть предложенные меры. Система позволяет сразу увидеть, какие атаки нейтрализует каждая мера (перечислены соответствующие техники ATT&CK), и насколько она снижает суммарный риск. Далее, используя модуль конструктора, пользователь может смоделировать внедрение меры: при выборе опции «применить меру» соответствующие сценарии будут пересчитаны. Например, если выбрана мера «Многофакторная аутентификация», система найдёт все сценарии, где присутствуют техники, связанные с компрометацией учётных данных (T1110 Brute Force, T1078 Valid Accounts и др.), и снизит вероятность успеха этих шагов на ~85% (эффективность меры). Затем модуль оценки риска пересчитает риск всех затронутых сценариев и обновит визуализацию: часть сценариев, ранее критических, может перейти в категорию средних, что отразится в таблице и на графиках. Пользователь немедленно видит количественный эффект – например, «Общий риск сценариев понизился на 15%, критических сценариев осталось 2 (было 5)». Он может откатить изменение (отключить меру) или зафиксировать его, выгрузив обновлённый отчёт;

• **экспорт результатов и завершение цикла:** после проведения анализа и подбора контрмер полученные материалы могут быть экспортированы. Система поддерживает выгрузку сценариев и оценок риска (например, в CSV/Excel для отчётности), а также экспорт сгенерированных регламентов в формате PDF или Markdown – для документирования и последующей реализации. Кроме того, возможна интеграция с внешними инструментами: например, экспорт списка мер в формате YAML/JSON для загрузки в SIEM/SOAR-платформы организации, чтобы автоматизировать применение некоторых из предложенных действий. На этом цикл работы можно считать завершённым: специалисты получили и проанализировали всесторонние данные о возможных атаках социальной инженерии и приняли решение о необходимых мерах защиты.

Следует отметить, что взаимодействие модулей спроектировано таким образом, чтобы максимально автоматизировать процесс, но при этом сохранить возможность вмешательства пользователя на каждом ключевом этапе. Сценарии генерируются и оцениваются автоматически, однако эксперт может уточнять вводные (например, добавлять организационные параметры перед запуском AI-анализа) и экспериментировать с мерами защиты в интерактивном режиме. Модули работают асинхронно: фронтенд не блокируется во время сетевых запросов к AI или фоновых вычислений Web Worker. Благодаря этому пользовательский интерфейс остаётся отзывчивым, позволяя продолжать работу (изучать отчёты, прокручивать таблицы и т.д.), пока расчёты выполняются в фоне. После получения результатов соответствующие компоненты UI обновляются событийно.

Разработанная архитектура взаимодействия модулей предусматривает гибкое расширение функциональности за счёт модульной структуры и стандартизованных интерфейсов.

3 Тестирование разработанного решения

3.1 Тестовая инфраструктура и сценарии тестирования

После реализации всех модулей была развёрнута тестовая инфраструктура для проверки корректности работы системы и ее устойчивости под нагрузкой. Тестирование проводилось в несколько этапов, охватывающих функциональные возможности каждого модуля и их совместную работу в комплексе. Ниже перечислены основные аспекты, проверенные в ходе испытаний.

Генерация сценариев атак. Проверка того, что модуль агрегации успешно загружает и обрабатывает базы знаний, формируя полный набор сценариев социальной инженерии. Для этого тестировались различные варианты исходных данных – от урезанного набора (несколько десятков шаблонов CAPEC) до полной базы CAPEC 3.x (~500 шаблонов) и ATT&CK v15 (14 тактик, ~200 техник). Критерием успеха было получение непустого списка сценариев, охватывающего логически связные цепочки атак []. Также вручную верифицировались несколько сгенерированных сценариев: эксперты сверяли их последовательности с известными моделями атак (kill chain) и убеждались в отсутствии противоречий (например, недопустимых циклов или переходов, не соответствующих логике фаз атаки). Отдельно проверялось кросс-сопоставление CAPEC↔ATT&CK: для выборочных шаблонов CAPEC удостоверились, что им правильно найдены соответствующие техники ATT&CK (либо непосредственно через встроенные Taxonomy_Mappings в CAPEC, либо через семантический анализ описаний). Результаты этих тестов подтвердили корректность работы агрегатора: все заявленные источники данных были успешно интегрированы, формат объединённого сценария соответствовал заданным требованиям, а сгенерированные цепочки отражали реалистичные ходы атак [71-92].

Анализ уязвимостей и паттернов. Испытания данного модуля заключались в проверке правильности привязки CWE/CVE к шагам сценариев и выделения повторяющихся шаблонов. Для теста использовались несколько известных шаблонов атак из CAPEC, у которых в описаниях явно указаны связанные CWE. Например, для

CAPEC-98 (Phishing) и CAPEC-130 (SQL Injection) модуль должен был извлечь соответствующие CWE (CWE-604, CWE-89 и др.). Автотесты проверили, что после работы анализатора каждая техника сценария содержит список связанных CWE-идентификаторов (если они предусмотрены в CAPEC). Кроме того, моделировалась ситуация с двумя очень похожими сценариями (различающимися лишь незначительным шагом): ожидалось, что анализатор отметит их как повторяющийся паттерн. Действительно, при тестировании два сгенерированных сценария фишинга, отличавшихся только фазой пост-эксплуатации, были распознаны как вариации одного паттерна.

Это подтвердило работоспособность функции выявления типовых последовательностей: система способна группировать схожие сценарии еще до этапа кластеризации, что сокращает дублирование при оценке рисков.

Оценка рисков сценариев. Данный блок тестировался как на отдельных заранее известных кейсах, так и в массовом режиме на всем множестве сценариев. Сначала проводилась проверка на контрольных примерах. Автоматические тесты проверили соответствие: функция расчета правильно комбинировала вероятность и Impact по заданной формуле. Затем осуществлялся прогон оценки рисков для полной базы сценариев, сгенерированной агрегатором. В тестовой среде было получено порядка 300 000 уникальных сценариев.

Модуль оценки рисков успешно обработал весь этот объем в пакетном режиме, выдав для каждого сценария числовое значение риска и категорию. Важным критерием здесь была эффективность: расчёт не должен занимать чрезмерно долгого времени. Как показали замеры, время присвоения оценки риска всем 300 тыс. сценариям составило около нескольких секунд, что стало возможным благодаря использованию параллелизма и кэширования повторяющихся фрагментов. Точность классификации по уровням риска была подтверждена экспертно: вручную проверены пороговые случаи (сценарии на границе категорий) – система корректно отнесла их к ожидаемым уровням в соответствии с заданными правилами. Таким образом, модуль риска продемонстрировал как правильность алгоритма (в сравнении с методологией

NIST SP 800-30), так и производительность, необходимую для оперативной работы с большими объёмами сценариев.

Интерактивная визуализация и корректность UI. Здесь проверялись две основные стороны – правильность отображения данных и удобство взаимодействия. Тестировалось наполнение таблицы сценариев и согласованность её содержимого с внутренними данными. Например, случайным образом выбирался один сценарий из базы и сравнивался с его представлением в UI: все этапы, техники и уровни риска совпадали. Также проводилась проверка функций фильтрации/поиска: на тестовом наборе из ~10 000 сценариев ввод фильтра по технике “T1566” в реальном времени оставлял в таблице только те строки, где в цепочке присутствует фишинг – и их количество соответствовало ожидаемому (что свидетельствует о корректности работы фильтра и быстродействии).

Диаграммы распределения рисков были сверены с рассчитанной статистикой: так, гистограмма на интерфейсе показывала около 3% сценариев в категории High, ~20% в Medium и остальные в Low, что совпадало с данными, полученными из модуля риска. Графики «топ N техник» также визуально подтверждались цифрами из базы (например, техника T1059 оказалась самой частой, присутствуя более чем в половине сценариев – столбец на диаграмме доходил до ~50%). Навигация по кластерной диаграмме испытывалась вручную: проверено, что при клике на группу сценариев открывается список конкретных сценариев данного кластера и их параметры соответствуют кластерному признаку.

В целом, модуль визуализации прошёл испытания успешно: все его компоненты отображали корректные данные, не выявлено рассинхронизаций или ошибок форматирования. Интерфейс оставался отзывчивым даже при отображении десятков тысяч записей, благодаря виртуализации списка (таблица отображает только видимые строки) и вынесению вычислений в Web Worker.

AI-агент и рекомендации мер защиты. Функциональность AI-модуля проверялась на реалистичных сценариях, сгенерированных системой. Проводилось несколько серий тестов. В одной серии на вход AI передавалась сводка по топ-10 самым критичным сценариям. Ожидалось, что AI-агент вернёт комплекс мер,

покрывающих различные этапы этих атак. Фактически, модель сгенерировала список из ~12 рекомендаций, включающий как технические меры (MFA, проверка вложений на почтовом шлюзе, EDR на рабочих станциях), так и организационные (тренинги по социальной инженерии, проверка кандидатов на доверенные должности).

Экспертный анализ показал, что все предложенные меры являются разумными и обоснованными: каждая из них соотнесена с одной или несколькими техниками ATT&CK, фигурирующими в опасных сценариях. Например, для сценария с кражей учётных данных через фишинг и дальнейшим движением по сети AI-агент порекомендовал многофакторную аутентификацию (чтобы даже при компрометации пароля злоумышленник не смог войти), обучение сотрудников выявлению фишинга (снижение вероятности успешного фишинга) и сегментацию сети (ограничение распространения атаки при компрометации одного узла). Эти меры действительно соответствуют лучшим практикам и упоминаются в стандартах (MFA и сетевые политики присутствуют в NIST SP 800-53).

Другая серия тестов проверяла адаптивность рекомендаций: задавались различные профили организации и проверялось, меняются ли советы AI под новые условия.

Результат подтвердил требуемое поведение: например, при указании профиля «финансовая организация, облачная инфраструктура» AI дополнительно включил меру по мониторингу облачных сред (CSPM), а при профиле «небольшая компания с ограниченным бюджетом» — сделал упор на недорогие меры (обучение, политики безопасности) и опустил в приоритете дорогостоящие решения вроде DLP. Таким образом, тестирование AI-агента продемонстрировало его способность генерировать обоснованные регламенты: рекомендации покрывают выявленные угрозы, согласуются с загруженной базой знаний по контрмерам и учитывают заданный контекст.

Отдельно отмечено, что модель ни разу не предложила откровенно неверных или опасных советов – все рекомендации соответствовали здравому смыслу и опыту экспертов. Это свидетельствует об успешном наполнении AI базой знаний и корректной постановке prompt-запроса.

Отклик системы на внедрение мер защиты. Здесь проверялась связка «AI-агент – конструктор мер – пересчёт риска». В интерактивном режиме воспроизводился следующий сценарий: пользователь получает от AI список мер и последовательно «применяет» некоторые из них, наблюдая за изменением уровня риска. Для автоматизации этого теста был создан скрипт, эмулирующий действия пользователя через API: он запрашивал рекомендации, затем отправлял команду применения меры (с указанием ID меры из полученного списка) и запрашивал обновлённые данные сценариев. Ключевым критерием было уменьшение совокупного риска критичных сценариев при применении сильных мер. Результаты тестирования соответствовали ожиданиям: так, в одном из прогоночных примеров начальный набор включал 5 сценариев с критическим риском; после применения меры «резервное копирование данных» (снижающей ущерб от потери данных) два сценария из пяти перешли в категорию «средний» риск. Добавление меры «MFA для всех пользователей» снизило вероятность реализации оставшихся сценариев и перевело ещё два сценария в средний риск. На рисунке 3.2 показан итоговый эффект: распределение сценариев по уровням риска до и после внедрения двух контрмер (условно, доля красных критических сценариев заметно уменьшилась).

Такие результаты доказывают работоспособность механизма перерасчёта: система адекватно реагирует на виртуальные изменения в модели защиты, пересчитывая риски на лету. Кроме того, UI правильно отображал эти изменения: тест зафиксировал, что цвета индикаторов риска сценариев обновились, диаграмма «пирамида рисков» изменила пропорции сегментов, а в тексте карточек мер появилось сообщение об эффективности (например, «снижение суммарного риска на 12%»). Все это свидетельствует о корректной интеграции модуля конструктора мер и его взаимодействия с остальными компонентами.

Таблица 6. Сложность тестирования модулей

Модуль	**Основная функция**	**Сложность тестирования**
Агрегатор сценариев	Генерация всех возможных сценариев атак	Средняя (много источников, сложная логика переходов)
Анализатор уязвимостей	Добавление CWE/CVE, выявление паттернов	Средняя (проверка корректных привязок)
Модуль оценки рисков	Расчёт вероятности, ущерба и интегрального риска	Высокая (пороговые значения, эффективность кэширования)
Модуль визуализации	Отображение сценариев и диаграмм	Низкая (UI-тесты, проверка синхронности данных)
AI-агент	Генерация рекомендаций по мерам защиты	Высокая (оценка релевантности рекомендаций)
Конструктор мер защиты	Применение мер и пересчёт рисков	Средняя (перерасчёт и отображение результата)

В ходе тестирования использовались как автоматизированные методы (unit-тесты, скрипты, имитирующие действия пользователя), так и ручное взаимодействие с системой. Тестовая инфраструктура включала сервер с запущенными сервисами агрегатора и AI-агента (на локальном хосте, 8-ядерный CPU, 16 ГБ ОЗУ) и клиентскую часть, открытую в актуальной версии браузера Google Chrome. Для сбора метрик производительности применялись хронометраж выполнения ключевых функций и мониторинг потребления ресурсов. Были проанализированы граничные случаи (extreme cases) – например, обработка сценария максимальной длины, одновременный запуск нескольких тяжёлых операций – чтобы убедиться в отсутствии сбоев или утечек памяти.

В результате проведённых испытаний комплекс подтвердил заявленные функциональные характеристики. Все модули успешно прошли проверки на корректность, а взаимодействие между ними оказалось устойчивым даже при

интенсивной нагрузке. Далее приведены количественные результаты тестирования и анализ производительности системы.

3.2 Оценка производительности и масштабируемости

Разработанный программный комплекс был протестирован на предмет производительности (времени выполнения основных операций, потребления ресурсов) и способности масштабироваться при увеличении объёма обрабатываемых данных. Результаты измерений демонстрируют, что текущая реализация удовлетворяет заданным требованиям и обладает резервом по масштабируемости. В таблице 7 приведены усреднённые показатели производительности для разных объёмов входных данных.

Таблица 7. Основные показатели производительности системы

Объём сгенерированных сценариев	Время генерации сценариев (агрегатор)	Время оценки всех рисков	Использование памяти (браузер)
10 000 (тестовый набор)	меньше 3 с	меньше 1 с	~50 МБ
100 000 (сокращённая CAPEC база)	~12 с	~2 с	~200 МБ
300 000 (полная база CAPEC, глубина 5)	~30 с (с оптимизациями)	~5 с (параллельно в 8 потоков)	~600 МБ

Примечание: время генерации включает загрузку внешних баз (кэшированных локально) и построение всех сценариев; время оценки рисков получено на 8-ядерном CPU с использованием Web Worker (эффективно параллелизация на 8 потоков).

Как видно из таблицы, даже при максимальном тестовом объёме (~300 тыс. сценариев) все основные операции выполняются в интерактивно приемлемое время: генерация сценариев заняла порядка полуминуты, что обычно производится однократно при запуске системы или обновлении баз знаний, а массовый расчёт рисков – считанные секунды. Более того, после начального расчёта дальнейшие действия пользователя (фильтрация, визуализация, частичный пересчёт при применении мер) происходят значительно быстрее, так как оперируют уже загруженными в память данными и используют кэш. Загрузка оперативной памяти на максимальном наборе (600 МБ) считается умеренной для современного клиентского ПК с 16 ГБ ОЗУ и не приводит к деградации работы браузера. В ходе нагрузочного тестирования интерфейс оставался плавным: время отзыва на действия (например, открытие окна с рекомендациями или прокрутка таблицы) не превышало десятой доли секунды благодаря оптимизациям DOM-дерева.

Отдельно оценивались масштабируемость и потенциальные узкие места. Текущая архитектура способна масштабироваться горизонтально: при росте объёма данных или числа параллельных пользователей можно запускать несколько экземпляров серверных модулей (например, кластеризовать службу агрегатора или AI-агента за балансировщиком) и распределять нагрузку. Поскольку фронтенд в основном выполняет вычисления локально, увеличение числа пользователей практически линейно масштабируется – каждый клиент потребляет ресурсы только своего компьютера, а серверные компоненты задействуются главным образом при инициализации (агрегатор при старте сессии) и при запросе рекомендаций (AI-агент). Потенциальным ограничением является объём оперативной памяти на стороне браузера: хотя 300 тыс. сценариев успешно обрабатываются, миллион сценариев одновременно держать в памяти клиента уже проблематично. Решением может стать переход к постраничной обработке сценариев или вынесение расчёта рисков на серверную сторону при экстремальных объёмах. Впрочем, при необходимости система легко адаптируется под такие нагрузки: благодаря модульной структуре, нетрудно реализовать вариант, где модуль оценки риска запускается не в Web Worker браузера, а на сервере с мощным CPU/GPU, и результаты просто передаются клиенту

(при этом изменения в остальном коде минимальны, нужно лишь заменить вызов функции).

Стоит подчеркнуть, что заложенные алгоритмические оптимизации доказали свою эффективность. Благодаря кэшированию, сложность вычислений для риска снизилась. На практике это дало ускорение на десятки процентов: без кэша расчет 300 тыс. сценариев занимал ~8 секунд, а с кэшированием – около 5 секунд (экономия ~35%).

Параллелизм же почти линеен по числу потоков до разумных пределов: переход с 1 на 8 потоков сократил время с ~40 до ~5 секунд. Таким образом, система способна эффективно использовать доступные аппаратные ресурсы.

В целом, проведённая оценка производительности показывает соответствие прототипа поставленным требованиям: комплекс может обрабатывать сотни тысяч потенциальных атак в полуавтоматическом режиме, предоставляя результаты анализа в реальном времени. Это делает решение пригодным для применения в реальных условиях, где необходимо оперативно анализировать большие пространства угроз.

Что касается масштабируемости, архитектура имеет значительный запас: переход на более мощные серверы или распределённую обработку позволит обрабатывать многократно большие объемы (миллионы сценариев) и интегрировать систему в инфраструктуру предприятий с тысячами пользователей. Разделение на микросервисы (агрегатор, анализатор, расчет риска, AI-сервис) также упростит масштабирование каждого компонента отдельно при повышении нагрузки.

3.3 Выводы о работоспособности системы и направления улучшения

Проведённые работы по реализации и тестированию подтверждают работоспособность разработанного программного комплекса. Система в целом успешно выполняет свою функцию: автоматически строит все возможные сценарии атак социальной инженерии на основе актуальных знаний, оценивает их риски и наглядно представляет результаты, а также генерирует адаптивные меры противодействия. Интеграция модулей прошла успешно – налажен единый конвейер обработки, где выход одних компонентов корректно воспринимается следующими. Тестирование не выявило критических ошибок: расчёты верны, визуализация совпадает с данными, рекомендации AI совпадают с ожиданиями экспертов. Производительность системы достаточна для практического применения: даже на большом объёме данных время отклика осталось приемлемым, а архитектура показала способность к дальнейшему наращиванию масштабов.

Таким образом, цель исследования, сформулированная как создание инструмента для автоматизированного анализа и моделирования атак социальной инженерии, достигнута. Разработанный программный комплекс доказал свою состоятельность в рамках испытаний. Он может быть использован как в учебных целях (для демонстрации сценариев и последствий атак), так и в прикладных – например, как подсистема в SOC для оценивания риска новых социальных угроз.

В то же время, в процессе разработки и тестирования были выявлены возможности для дальнейшего развития системы. К перспективным направлениям улучшения и расширения функциональности относятся следующие идеи:

- **подключение новых источников данных.** Архитектура агрегатора позволяет легко интегрировать дополнительные базы знаний и данные об атаках. В будущем можно включить в систему автоматизированный сбор информации из реальных инцидентов (отчёты о кибератаках, тикеты SOC) и открытых источников (OSINT, платформы Threat Intelligence). Например, целесообразно парсить репозитории с описаниями фишинговых кампаний или базы типа PhishTank – и преобразовывать их в формализованные сценарии для анализа. Также можно

учитывать внутренние данные конкретной организации (статистика учений по социнженерии, результаты аудитов) при генерации сценариев, чтобы лучше адаптировать модель угроз под заказчика;

- **расширение аналитических возможностей.** Существующий анализатор может быть дополнен методами более глубокой оценки сценариев. Одно из направлений – реализация автоматического построения деревьев атак (Attack Trees) или цепочек Cyber Kill Chain для наиболее критичных сценариев. Это позволит выявлять общие уязвимые узлы и этапы, на которых сосредоточен наибольший риск.

Также можно внедрить алгоритмы машинного обучения для прогнозирования успешности атак: обучить модель классификации сценариев на «успешные» vs «неуспешные» (по историческим данным), чтобы более обоснованно оценивать вероятность для каждого сценария [70-81]. Визуальную аналитику тоже можно расширить: добавить тепловые карты соответствия мер и техник (для наглядного показа, какие меры против каких техник работают), временные линии атак (расположение шагов сценария на временной шкале);

- **интеграция других моделей AI/LLM.** В будущем можно экспериментировать с подключением дополнительных интеллектуальных модулей. Например, можно встроить модель для автоматического обнаружения попыток социальной инженерии в реальном времени – анализируя входящие электронные письма, сообщения и сравнивая их с шаблонами атак, сгенерированными системой. Ещё одно направление – использование более совершенных языковых моделей по мере их появления (новые версии GPT, модели семейства LLaMA и др.). Благодаря стандартизированному формату запроса/ответа, замена или апгрейд LLM сводится к минимальным настройкам (изменение prompt, возможно увеличение контекста) без переработки других компонентов. Можно также реализовать комбинацию моделей: одна генерирует рекомендации, а другая выполняет их peer-review (оценку качества) перед выдачей пользователю. Это повысит надёжность советов AI и снизит риск возможных ошибок или упущений;

- **повышение степени автоматизации защиты.** На текущем этапе система выдаёт рекомендации, а решение об их внедрении остаётся за специалистом. В

перспективе возможно превратить комплекс в частично автоматизированный SOAR-инструмент, способный не только рекомендовать, но и сразу применять определённые меры противодействия. Например, после генерации регламента система могла бы сама инициировать некоторые действия: добавить подозрительные домены в чёрный список почтового шлюза, включить строгие правила аутентификации на сервере и т.п. Разумеется, такие действия должны выполняться осторожно и под контролем, но технически это реализуемо через интеграцию с API корпоративных систем безопасности (Active Directory, почтовых серверов, SIEM и др.). Для этого можно разработать дополнительные модули-интеграторы, подписанные на события системы (например, «принято решение внедрить меру X») и выполняющие соответствующие скрипты. Такая функциональность замкнёт цикл «анализ – рекомендация – реакция» и повысит оперативность защиты организации.

- **масштабирование и переход к микросервисам.** Хотя текущая версия справляется с поставленными задачами, при дальнейшем росте требований может понадобиться перераспределить модули по отдельным сервисам с более гибким масштабированием. Переход к полностью микросервисной архитектуре предполагает, что агрегатор, анализатор, риск-движок, AI-сервис будут работать как независимые приложения, взаимодействующие через REST API, или брокер сообщений. Это облегчит их раздельное обновление и масштабирование – например, можно запустить несколько экземпляров риск-движка на кластере для параллельной обработки миллионов сценариев, или масштабировать AI-сервис под нужное число одновременных запросов. Благодаря тому, что уже сейчас форматы обмена (JSON структуры сценариев, форматы запросов AI) продуманы и задокументированы, такой переход может быть осуществлён с минимальными изменениями в коде. Кроме того, при выносе тяжёлых вычислений на бекэнд появится возможность использовать ресурсоёмкие методы (например, глубокий перебор сценариев длиной >10 или более точные модели ML) без ограничений, накладываемых средой браузера.

Тестирование подтвердило жизнеспособность заложенных идей и алгоритмов, система оказалась удобной в использовании и дала богатый материал для анализа

(сотни тысяч сценариев, статистика по ним, приоритетные риски и меры). Это говорит о том, что выбранный подход вполне применим на практике [49-69].

Проведённая реализация и последующее тестирование разработанного программного комплекса по автоматизированному моделированию, анализу и визуализации сценариев атак социальной инженерии подтвердили его функциональную состоятельность, архитектурную целостность и практическую применимость. Система продемонстрировала устойчивую работу в условиях обработки больших объёмов входных данных, сохранив при этом приемлемое время отклика и высокую точность вычислений. Комплекс успешно реализует весь целевой функционал: формирует полное множество возможных сценариев атак на основе агрегированных данных из формализованных баз знаний (например, MITRE ATT&CK и CAPEC), производит количественную оценку рисков с учётом вероятности реализации, ущерба и эффективности защитных мер, осуществляет визуальное представление сценариев в машиночитаемой и аналитически интерпретируемой форме, а также генерирует рекомендации по противодействию с использованием AI-агента, адаптированного к предметной области информационной безопасности.

Интеграция всех функциональных модулей выполнена корректно: каждый компонент (агрегатор, анализатор уязвимостей, модуль оценки рисков, визуализатор, AI-агент) взаимодействует с другими через стандартизированные интерфейсы и форматы данных, обеспечивая сквозную обработку сценариев без потерь контекста и семантики. Проведённое тестирование показало корректность функционирования на всех уровнях: расчёты рисков совпадают с теоретически ожидаемыми значениями, визуализированные сценарии соответствуют структурным характеристикам данных, а выводы AI-модуля, в том числе регламенты и рекомендации, признаны релевантными профильными специалистами.

ЗАКЛЮЧЕНИЕ

В порядке разрешения комплекса взаимосвязанных противоречий, выявленных в ходе анализа предметной области — между необходимостью в автоматизированном формировании сценариев атак социальной инженерии и отсутствием формализованных, алгоритмизируемых баз знаний потребностью в точной оценке рисков и отсутствием унифицированных алгоритмов для расчёта на уровне сценариев, а также необходимостью в единой архитектуре программного обеспечения и фрагментарностью существующих решений, — удалось разработать и апробировать комплексное алгоритмическое и программное обеспечение для автоматизированного построения, оценки рисков и визуализации сценариев атак социальной инженерии, обладающее следующей новизной, теоретической значимостью и практической ценностью:

– впервые реализован целостный алгоритмический подход, объединяющий автоматическую генерацию сценариев атак, их формализованное пошаговое описание, количественную оценку рисков с учётом технических и человеческих факторов, а также визуализацию полученных сценариев в форме графа с выделением критических узлов и зон воздействия;

– создана модель оценки рисков, адаптированная под специфику атак социальной инженерии, включающая параметры вероятности успешной реализации отдельных этапов, масштаб ущерба и эффективность защитных мер, позволяющая производить ранжирование сценариев по степени критичности;

– реализована архитектура прототипа программного комплекса, способная интегрироваться в системы управления информационной безопасностью, обеспечивающая непрерывный цикл: агрегация знаний → генерация сценариев → оценка рисков → генерация рекомендаций по противодействию → визуализация.

Теоретическая значимость выполненной работы состоит в следующем:

– предложена формализованная концептуальная модель сценария атаки социальной инженерии, объединяющая технико-технологические и поведенческие

компоненты, что способствует развитию методологий моделирования угроз, связанных с человеческим фактором;

– уточнены критерии оценки уязвимости и устойчивости субъектов и процессов к социально-инженерным воздействиям, что расширяет возможности анализа в рамках теории риск-менеджмента и прикладной киберпсихологии;

– предложенный подход к моделированию сценариев может быть положен в основу дальнейших научных исследований в области киберсоциальной безопасности и построения формализованных языков описания атак.

Практическая значимость разработки подтверждается тем, что:

– разработанный программный комплекс может быть применён подразделениями информационной безопасности для предиктивного анализа возможных атак и оценки устойчивости организационных процессов к социальной инженерии;

– визуализация атак в реальном времени и расчет критичности каждого этапа могут быть использованы в учебных и тренинговых центрах для подготовки персонала к распознаванию и нейтрализации сценариев атак;

– алгоритмическое ядро и компоненты оценки риска пригодны для интеграции в существующие решения класса SIEM, SOAR и GRC как вспомогательные модули для анализа “человеческих” уязвимостей.

Таким образом, в результате дипломного проектирования разрешены ключевые противоречия исследуемой области, предложенное решение обладает высокой степенью новизны и прикладной ценностью, а также может быть положено в основу дальнейших исследований и формализации регламентов защиты от атак социальной инженерии, включая средства машинного обучения и цифровых ассистентов, подверженных риску социальной манипуляции.

СПИСОК ЛИТЕРАТУРЫ

1 Secureframe. Social engineering statistics. — Электрон. дан. — Режим доступа: https://secureframe.com/blog/social-engineering-statistics. - Текст: электронный.

2 Hoxhunt. Phishing trends report. — Электрон. дан. — Режим доступа: https://hoxhunt.com/guide/phishing-trends-report. - Текст: электронный.

3 Mazurek M., Kozioł R. Threat modelling for socio-technical attack scenarios // arXiv preprint. — Электрон. дан. — Режим доступа: https://arxiv.org/abs/2505.12104. - Текст: электронный.

4 Hoxhunt. Phishing trends report. — Электрон. дан. — Режим доступа: https://hoxhunt.com/guide/phishing-trends-report. - Текст: электронный.

5 Financial Times. How AI is powering a new wave of cyberattacks. — Электрон. дан. — Режим доступа: https://www.ft.com/content/169179ed-cc1f-467c-be1c-6668781604d6. - Текст: электронный.

6 Legal and regulatory frameworks for AI security. — Scite.ai. — Электрон. дан. — Режим доступа: https://scite.ai/reports/legal-and-regulatory-frameworks-for-r6ObaEQA. - Текст: электронный.

7 Queen’s University Belfast. Study of research and guidance on the cyber security of AI. — Электрон. дан. — Режим доступа: https://assets.publishing.service.gov.uk/media/663cf1b2bd01f5ed3279388e/Study_of_research_and_guidance_on_the_cyber_security_of_AI_-_Queens_University_Belfast_literature_review.pdf. - Текст: электронный.

8 Finogeev A., Kotenko I., Chechulin A. Adversarial attacks against decision-support AI systems // Springer. — Электрон. дан. — Режим доступа: https://link.springer.com/chapter/10.1007/978-3-031-80557-8_1. - Текст: электронный.

9 Dinh T., Xie T. Trust assessment for LLM-based assistants // arXiv preprint. — Электрон. дан. — Режим доступа: https://arxiv.org/abs/2408.07933. - Текст: электронный.

10 Palo Alto Networks. What is MITRE ATT&CK? — Электрон. дан. — Режим доступа: https://www.paloaltonetworks.ca/cyberpedia/what-is-mitre-attack. - Текст: электронный.

11 Palo Alto Networks. What is MITRE ATT&CK? — Электрон. дан. — Режим доступа: https://www.paloaltonetworks.ca/cyberpedia/wk - Текст: электронный.

12 MITRE. CAPEC: Attack comparison. — Электрон. дан. — Режим доступа: https://capec.mitre.org/about/attack_comparison.html - Текст: электронный.

13 Kotenko I., Skormin V. The CAPEC-based generator of attack scenarios for network security evaluation. — ResearchGate. — Электрон. дан. — Режим доступа: https://www.researchgate.net/publication/308828935 - Текст: электронный.

14 MITRE. CAPEC-98: Phishing. — Электрон. дан. — Режим доступа: https://capec.mitre.org/data/definitions/98.html. - Текст: электронный.

15 Kotenko I., Skormin V. The CAPEC-based generator of attack scenarios... — ResearchGate. — Электрон. дан. — Режим доступа: https://www.researchgate.net/publication/308828935. - Текст: электронный.

16 Kotenko I., Skormin V. The CAPEC-based generator of attack scenarios... — ResearchGate. — Электрон. дан. — Режим доступа: https://www.researchgate.net/publication/308828935. - Текст: электронный.

17 NIST SP 800-30 Rev.1. Guide for Conducting Risk Assessments. — Электрон. дан. — Режим доступа: https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-30r1.pdf. - Текст: электронный.

18 Habr. Риски информационной безопасности: модели и методы. — Электрон. дан. — Режим доступа: https://habr.com/ru/articles/495236. - Текст: электронный.

19 Security Vision. Управление рисками: продолжение стандарта NIST SP 800-30. — Электрон. дан. — Режим доступа: https://www.securityvision.ru/blog/upravlenie-riskami-informatsionnoy-bezopasnosti-chast-5-standart-nist-sp-800-30-prodolzhenie-standar. - Текст: электронный.

20 D3 Security. Top MITRE ATT&CK tactics and techniques. — Электрон. дан. — Режим доступа: https://d3security.com/blog/top-mitre-attack-tactics-and-techniques. - Текст: электронный.

21 Doppel. Аудит ИБ в цифровой среде. — Электрон. дан. — Режим доступа: https://doppel.com . - Текст: электронный.

22 Corewin. Информационная безопасность в организациях. — Электрон. дан. — Режим доступа: https://corewin.ua. - Текст: электронный.

23 Sprinto. Social engineering threat statistics. — Электрон. дан. — Режим доступа: https://sprinto.com. - Текст: электронный.

24 Spectrumdata. Аналитика угроз информационной безопасности. — Электрон. дан. — Режим доступа: https://spectrumdata.ru. - Текст: электронный.

25 Microsoft. Security Copilot: AI in Cybersecurity. — Электрон. дан. — Режим доступа: https://www.microsoft.com/security/blog/2023/03/28/introducing-microsoft-security-copilot/ . - Текст: электронный.

26 OpenAI. GPT-4 System Card. — Электрон. дан. — Режим доступа: https://openai.com/research/gpt-4-system-card. - Текст: электронный.

27 MITRE. Threat-Informed Defense: Concepts and Applications. — Электрон. дан. — Режим доступа: https://mitre-engenuity.org/threat-informed-defense/. - Текст: электронный.

28 SafeBreach. Breach and Attack Simulation Platform. — Электрон. дан. — Режим доступа: https://safebreach.com/technology/. - Текст: электронный.

29 Terranova Security. Gamified Awareness Training. — Электрон. дан. — Режим доступа: https://terranovasecurity.com/security-awareness-training/. - Текст: электронный.

30 Hoxhunt. AI-Based Human Cybersecurity Platform. — Электрон. дан. — Режим доступа: https://www.hoxhunt.com/platform. - Текст: электронный.

31 Xianghui F. et al. Graph-based threat scenario modeling // Information Security Journal. — 2022. — Т. 31. — № 2. — С. 105–117. – Текст: непосредственный.

32 Shevtsov A., Kotenko I. Ontology-driven scenario generation for threat simulation // Journal of Computer Virology and Hacking Techniques. — 2021. — Vol. 17(4). — P. 301–318. – Текст: непосредственный.

33 Picus Security. Breach and Attack Simulation Platform. — Электрон. дан. — Режим доступа: https://www.picussecurity.com/platform/breach-and-attack-simulation. - Текст: электронный.

34 ThreatConnect. Intelligence-Driven SOAR. — Электрон. дан. — Режим доступа: https://threatconnect.com/platform/soar/. - Текст: электронный.

35 Oasis Open. STIX™ Version 2.1. — Электрон. дан. — Режим доступа: https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html. - Текст: электронный.

36 OpenCTI. Open Cyber Threat Intelligence Platform. — Электрон. дан. — Режим доступа: https://www.opencti.io/docs/introduction. - Текст: электронный.

37 Kim H. et al. An Ontology-Based Threat Analysis Framework // IEEE Transactions on Dependable and Secure Computing. — 2020. — № 17. — С. 1263–1278. – Текст: непосредственный.

38 Xianghui F. et al. CAPEC-CWE-CVE Mapping Techniques // Information Security Journal. — 2022. — Т. 31. — № 2. — С. 105–117. – Текст: непосредственный.

39 CWE-View: Mapping of Weaknesses to Known Vulnerabilities. — Электрон. дан. — Режим доступа: https://cwe.mitre.org/data/graphs.html. - Текст: электронный.

40 FAIR Institute. Introduction to FAIR Risk Model. — Электрон. дан. — Режим доступа: https://www.fairinstitute.org/fair-risk-management. - Текст: электронный.

41 NIST. Guide for Conducting Risk Assessments (SP 800-30 Rev.1). — Электрон. дан. — Режим доступа: https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf. - Текст: электронный.

42 ISO/IEC 27005:2018. Information security risk management. — Geneva: ISO, 2018. — 53 p. – Текст: непосредственный.

43 OWASP. Risk Rating Methodology. — Электрон. дан. — Режим доступа: https://owasp.org/www-community/OWASP_Risk_Rating_Methodology. - Текст: электронный.

44 Zhang C. et al. Machine Learning for Attack Scenario Clustering // IEEE Trans. on Dependable and Secure Computing. — 2023. — Vol. 20(2). — P. 456–470. . – Текст: непосредственный.

45 IBM Security. Threat Clustering in Real-Time SOCs. — Электрон. дан. — Режим доступа: https://www.ibm.com/security/threat-intelligence. - Текст: электронный.

46 Hu E. et al. LoRA: Low-Rank Adaptation of Large Language Models // arXiv preprint. — 2021. — arXiv:2106.09685. – Текст: непосредственный.

47 Liu X. et al. P-Tuning v2: Prompt Tuning Can Be Comparable to Fine-tuning // ACL 2022. — Vol. 1. — P. 820–833. . – Текст: непосредственный.

48 CIS Controls v8. — Электрон. дан. — Режим доступа: https://www.cisecurity.org/controls/v8/. - Текст: электронный.

49 Остапенко Г.А. Совершенствование организационно-правового обеспечения информационной безопасности предприятия: формирование рискландшафта сетевых атак / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, 110 А.А. Остапенко, А.Ю. Пекло // Информация и безопасность. 2023. - Т. 26. Вып. 2. - С. 203-210. – Текст: непосредственный.

50 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть I) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.С. Кривошеин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

51 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть II) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

52 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть III) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 341-358. – Текст: непосредственный.

53 Остапенко А.Г. Проектная деятельность: научно-методическое развитие в направлении внедрения средств искусственного интеллекта для обеспечения организационно-правовой защиты корпоративных сетей / А.Г. Остапенко, Д.В. Щербакова, А.А. Остапенко, Д.А. Нархов // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 447-454. – Текст: непосредственный.

54 Остапенко Г.А. Нейросетевые задачи и компетенции проектной деятельности по созданию защищённых автоматизированных информационных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность. 2023. - Т. 26. Вып. 4. - С. 579-586. – Текст: непосредственный. 111

55 Остапенко Г.А. Методики регламентации обеспечения информационной безопасности атакуемых автоматизированных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность.2023. - Т.26.Вып. 4.- С.597-602. – Текст: непосредственный.

56 Пекло А.Ю. Атаки типа "сетевая разведка": риск-ландшафт и частная политика информационной безопасности предприятия / А.Ю. Пекло, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. - Т. 26. Вып. 2. - С. 235-246. – Текст: непосредственный.

57 Остапенко А.Г. Направление совершенствования нормативно-правового обеспечения объектов информатизации на основе риск-анализа их кибербезопасности/ А.Г. Остапенко, Д.В. Щербакова, Д.А. Нархов, Ю.В. Макаров, А.С. Кривошеин // Информация и безопасность.2022. - Т.25.Вып. 4. - С.593-598. – Текст: непосредственный.

58 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин [и другие] //

Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 231-238. – Текст: непосредственный.

59 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 239-246. – Текст: непосредственный.

60 Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 219-230. – Текст: непосредственный. 112

61 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. - Т. 27. Вып. 1. - С. 7-30. – Текст: непосредственный.

62 Хромых С.А. Сетевые атаки на уровне приложений: риск-ландшафт и частная политика информационной безопасности предприятия / С.А. Хромых, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. Вып. 2. С. 261-276.

63 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 31-54.

64 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 319-336.

65 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А.

Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 337-378.

66 Остапенко Г.А. Использование средств искусственного интеллекта в ходе исследовательского и учебного процессов при подготовке специалистов по защите информации / Г.А. Остапенко, А.О. Калашников, А.Г. Остапенко, Е.А. Москалева, Д.О. Карпеев, О.В. Поздышева, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 389-400. 113

67 Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 401-420.

68 Остапенко А.Г. Картографирование киберпространства и защита информации / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 89-106.

69 Остапенко А.Г. Картографирование киберпространства и обеспечение информационной безопасности / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 115-128.

70 Остапенко Г.А. Матричная формализация целеполагания и результативности проектной деятельности в сфере защиты информации и обеспечения информационной безопасности / Г.А. Остапенко, В.И. Белоножкин, Н.И. Баранников, А.А. Остапенко, А.Г. Краснобородкин, Т.Ю. Мирошниченко // Информация и безопасность. 2022. Т. 25. Вып. 4. С. 475-484.

71 Смирнов В.В. Кибератаки вида "анализ целевого объекта": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 273-284.

72 Жидков Э.И. Кибератаки вида "социальная инженерия": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. Т. 27. № 2. С. 285-298.

73 Сердечный А.Л. Риск-анализ и прогнозирование частоты и ущербности компьютерных атак / А.Л. Сердечный, А.С. Маликова, А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.Н. Бартенев. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 159-178. 114

74 Архипова К.В. Автоматизированная информационная система моделирования эпидемических процессов, порожденных саморазмножающимися и мутирующими вредоносами / К.В. Архипова, А.А. Остапенко, В.В. Сафронова, В.Ю. Остапенко, Ю.Г. Пастернак // Информация и безопасность. 2022. Т. 25. № 3. С. 349-366.

75 Остапенко Г.А. Киберполигон как проект управления информационными рисками / Г.А. Остапенко, В.И. Белоножкин, А.А. Остапенко, М.Е. Волкова // Информация и безопасность. 2023. Т. 26. № 1. С. 9-16.

76 Остапенко Г.А. Разработка архитектуры киберполигона для повышения качества и результативности учебного процесса в исследовании атак на информационные системы и сети / Г.А. Остапенко, С.С. Куликов, А.В. Коноплин, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. № 1. С. 101-108.

77 Остапенко А.Г. Методические основы проектной деятельности при выполнении научно-исследовательской работы студентами специалитета в сфере обеспечения информационной безопасности / А.Г. Остапенко, А.С. Пахомова, Д.А. Нархов, А.А. Остапенко, А.И. Шеншин // Информация и безопасность. 2023. Т. 26. № 2. С. 169-176.

78 Остапенко А.Г. Научно-технические результаты и перспективы реализации проекта "безопасный интернет" / А.Г. Остапенко, И.А. Боков, А.А. Остапенко, Н.М. Лантюхов, Т.Ю. Мирошниченко, С.В. Лихобабин, С.Д. Трубицын // Информация и безопасность. 2021. Т. 24. № 2. С. 287-296.

79 Сердечный А.Л. Метод информационно-картографического анализа активности группировок хактивистов / А.Л. Сердечный, А.Г. Остапенко // Информация и безопасность. 2023. Т. 26. № 4. С. 587-596.

80 Остапенко А.Г. Сетевая вирусология: прогнозирование развития двувирусных эпидемических процессов в сетях. / А.Г. Остапенко, Е.В. Зарочинцев,

115 О.А. Остапенко, К.В. Сибирко, В.В. Сафронова, П.Д. Федоров. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 203-222.

81 Остапенко А.Г. Картографические модели процессов диффузии вредоносов в сетевом киберпространстве. / А.Г. Остапенко, А.Л. Сердечный, А.А. Остапенко, С.С. Куликов. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 281-286.

82 Остапенко А.Г. Научно-технические результаты и перспективы реализации проекта «Безопасный интернет». / А.Г. Остапенко, И.А. Боков, А.А. Остапенко, Н.М. Лантюхов, Т.Ю. Мирошниченко, С.В. Лихобабин, С.Д. Трубицын. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 287-296.

83 Кобцев О.Е. Сетевые атаки компьютерными вирусами: риск-ландшафт / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, В.Г. Юрасов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 55-66.

84 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частная политика и регламенты информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, Ю.Г. Пастернак, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 67-80.

85 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частные инструкции информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, В.И. Белоножкин, К.А. Разинкин, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 81-90.

86 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, Д.С. Покудин, Н.Н. Корвяков // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 239-246.

87 Смирнов В.В. Кибератаки вида «анализ целевого объекта»: рискландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. 116 Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 273-284.

88 Жидков Э.И. Кибератаки вида «социальная инженерия»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 285-294.

89 Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов»: разработка частной политики информационной безопасности / А.А. Золотарев, Д.А. Нархов, А.Н. Мокроусов, В.И. Борисов, А.Е. Дешина, А.С. Пахомова, А.Ю. Егоров // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 91-98.

90 Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов построение риск-ландшафта / А.А. Золотарев, Д.А.Нархов, М.И. Бочаров, А.И. Мордовин, Н.М. Радько, О.В. Поздышева, А.Г. Краснобородкин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 99-108.

91 Минаев В.А. Геофизические угрозы кибербезопасности / В.А. Минаев, А.О. Фаддеев, А.В. Мокшанцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 117-124.

92 Рытов М.Ю. Порядок оценки уровня эффективности системы непрерывного противодействия инцидентам информационной безопасности на объекте / М.Ю. Рытов, О.М. Голембиовская, Е.В. Кондрашова, М.М. Голембиовский, К.Е. Шинаков // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 135-142.

ПРИЛОЖЕНИЕ А

```
export const ViewCapec = () => {
  const [currentPage, setCurrentPage] = useState(1);
  const itemsPerPage = 15;

  const { capecId } = useParams();
  const [searchParams] = useSearchParams();
  const useAI = searchParams.get('useAI') === 'true';

  const formattedScenarios = useMemo(() => {
    const capec = capecList[capecId]

    const tacticOrder = Object.keys(capec);
    const techniqueOptions = tacticOrder.map(tactic => capec[tactic]);
    const allScenarios = cartesianProduct(techniqueOptions);

    return allScenarios.map(scenario => {
      const sumU = scenario.reduce((sum, t) => sum + t.U, 0);
      const compositionVeroyat = scenario.reduce((sum, t) => sum * t.veroyatnost, 1);
      const path = scenario.map(t => t.technik);
      const risk = sumU * compositionVeroyat;
      return { path, risk };
    }).sort((a, b) => b.risk - a.risk);
  }, [capecId]);

  const clustersByTechniques = useMemo(() => {
    const criticalScenarios = formattedScenarios.filter(
      scenario => calculateRiskLevel(scenario.risk) === 'CRITICAL'
    );
```

```
const levenshteinDistance = (a: string[], b: string[]): number => {
  if (a.length === 0) return b.length;
  if (b.length === 0) return a.length;

  const matrix = Array(b.length + 1).fill(null).map(() => Array(a.length + 1).fill(null));

  for (let i = 0; i <= a.length; i += 1) {
    matrix[0][i] = i;
  }

  for (let j = 0; j <= b.length; j += 1) {
    matrix[j][0] = j;
  }

  for (let j = 1; j <= b.length; j += 1) {
    for (let i = 1; i <= a.length; i += 1) {
      const indicator = a[i - 1] === b[j - 1] ? 0 : 1;
      matrix[j][i] = Math.min(
        matrix[j][i - 1] + 1,
        matrix[j - 1][i] + 1,
        matrix[j - 1][i - 1] + indicator,
      );
    }
  }
  return matrix[b.length][a.length];
};

const distanceThreshold = 5;
const clusters: Array<{ name: string, scenarios: any[], commonChain?: string[] }> = [];
```

```
const clusteredIndices = new Set<number>();

criticalScenarios.forEach((scenario, i) => {
  if (clusteredIndices.has(i)) return;

  const newCluster = {
    name: `Кластер ${clusters.length + 1}`,
    scenarios: [scenario]
  };
  clusteredIndices.add(i);

  criticalScenarios.forEach((otherScenario, j) => {
    if (i === j || clusteredIndices.has(j)) return;

    if (levenshteinDistance(scenario.path, otherScenario.path) <= distanceThreshold) {
      newCluster.scenarios.push(otherScenario);
      clusteredIndices.add(j);
    }
  });
  clusters.push(newCluster);
});

// Find the dominant common chain for each cluster
return clusters.map(cluster => {
  if (cluster.scenarios.length < 2) {
    return { ...cluster, commonChain: [] };
  }

  const MIN_CHAIN_LENGTH = 3;
  const chainCounts = new Map<string, { count: number, chain: string[] }>();
```

```
    const paths = cluster.scenarios.map(s => s.path);

    paths.forEach(path => {
      const chainsInThisPath = new Set<string>();
      if (path.length < MIN_CHAIN_LENGTH) return;

      for (let len = MIN_CHAIN_LENGTH; len <= path.length; len++) {
        for (let i = 0; i <= path.length - len; i++) {
          const subChain = path.slice(i, i + len);
          chainsInThisPath.add(subChain.join(' → '));
        }
      }

      chainsInThisPath.forEach(subChainKey => {
        const current = chainCounts.get(subChainKey) || { count: 0, chain:
subChainKey.split(' → ') };
        chainCounts.set(subChainKey, { count: current.count + 1, chain: current.chain });
      });
    });

    if (chainCounts.size === 0) {
      return { ...cluster, commonChain: [] };
    }

    const frequentChains = [...chainCounts.entries()].filter(([, value]) => value.count > 1);

    if (frequentChains.length === 0) {
      return { ...cluster, commonChain: [] };
    }
```

```
    frequentChains.sort((a, b) => {
      const [, valA] = a;
      const [, valB] = b;
      if (valB.count !== valA.count) {
        return valB.count - valA.count;
      }
      return valB.chain.length - valA.chain.length;
    });

    const bestChain = frequentChains[0][1].chain;

    const isSubArray = (haystack: string[], needle: string[]) => {
      if (!needle.length) return true;
      for (let i = 0; i <= haystack.length - needle.length; i++) {
        if (haystack.slice(i, i + needle.length).every((v, k) => v === needle[k])) {
          return true;
        }
      }
      return false;
    };

    const scenariosWithPattern = cluster.scenarios.filter(scenario =>
      isSubArray(scenario.path, bestChain)
    );

    return { ...cluster, commonChain: bestChain, scenarios: scenariosWithPattern };
  }).filter(cluster => cluster.scenarios.length > 1);
}, [formattedScenarios]);

// Карта для сопоставления ID техник с их названиями
```

```
  const mitreTechniqueNames: Record<string, string> = {
    "T1110": "Брутфорс (Brute Force)",
    "T1078": "Действительные учетные записи (Valid Accounts)",
    "T1558": "Кереростинг (Kerberoasting)",
    "T1550": "Передача побочного хэша (Pass the Hash)",
    "T1046": "Сканирование сетевых служб (Network Service Scanning)",
    "T1562": "Обход защиты (Impair Defenses)",
    "T1041": "Эксфильтрация через C2 канал (Exfiltration Over C2 Channel)",
    "T1486": "Шифрование для вымогательства (Data Encrypted for Impact - Ransomware)",
    "T1485": "Удаление данных (Data Destruction)",
    "T1068": "Эскалация привилегий через уязвимость ядра (Exploitation for Privilege Escalation)",
    "T1190": "Эксплуатация внешних удаленных служб (Exploit Public-Facing Application)",
    "T1210": "Удаленное выполнение служб (Exploitation of Remote Services)",
    "T1070": "Очистка следов (Indicator Removal on Host)",
    "T1546": "Выполнение, запускаемое по событию (Event Triggered Execution)",
    "T1547": "Автозапуск при загрузке или входе в систему (Boot or Logon Autostart Execution)",
или securityMeasures.ts
  };

  const techniqueNameMap = useMemo(() => {
    const map = new Map<string, string>();
    const capec = capecList[capecId];
    if (capec) {
      Object.values(capec).forEach((techniquesArray: Technique[]) => { // Явное приведение типа
        techniquesArray.forEach(tech => {
```

```
        map.set(tech.technik, mitreTechniqueNames[tech.technik] || tech.technik); // Используем карту имен
      });
    });
  }
  return map;
 }, [capecId]);

 const [selectedMeasures, setSelectedMeasures] = useState<SecurityMeasure[]>([]);
 const [availableMeasures, setAvailableMeasures] = useState<SecurityMeasure[]>([]);
 const [modifiedCriticalScenariosCount, setModifiedCriticalScenariosCount] = useState(0);
 const [isCalculatingRisk, setIsCalculatingRisk] = useState(false);
 const [riskCalculationError, setRiskCalculationError] = useState<string | null>(null);
 const [allModifiedScenarios, setAllModifiedScenarios] = useState<any[]>([]);

 // Инициализируем Worker
 const riskWorker = useMemo(() => new RiskCalculationWorker(), []);

 // Добавим лог для проверки selectedMeasures
 useEffect(() => {
  console.log("Текущие выбранные меры:", selectedMeasures);
 }, [selectedMeasures]);

 // Обновляем текущие сценарии на основе данных из Worker
 const currentScenarios = useMemo(() => {
  const startIndex = (currentPage - 1) * itemsPerPage;
  // Используем allModifiedScenarios, полученные от Worker
  return allModifiedScenarios.slice(startIndex, startIndex + itemsPerPage);
 }, [allModifiedScenarios, currentPage]);
```

```
  const totalPages = Math.ceil(formattedScenarios.length / itemsPerPage);

  // Переносим расчет критических сценариев и всех модифицированных сценариев в Worker
  useEffect(() => {
    if (formattedScenarios.length > 0) {
      setIsCalculatingRisk(true);
      setRiskCalculationError(null);
      riskWorker.postMessage({ formattedScenarios, selectedMeasures });
    }

    riskWorker.onmessage = (event) => {
      setModifiedCriticalScenariosCount(event.data.modifiedCriticalScenariosCount);
      setAllModifiedScenarios(event.data.allModifiedScenarios); // Обновляем все модифицированные сценарии
      setIsCalculatingRisk(false);
    };

    riskWorker.onerror = (error) => {
      console.error('Ошибка Worker расчета риска:', error);
      setRiskCalculationError('Не удалось рассчитать критические сценарии.');
      setIsCalculatingRisk(false);
    };

    return () => {
      riskWorker.onmessage = null;
      riskWorker.onerror = null;
    };
  }, [formattedScenarios, selectedMeasures, riskWorker]);
```

```
const renderScenarioGraph = (path: string[], commonChain: string[] = []) => {
  if (!path || path.length === 0) {
    return null;
  }

  let startIndex = -1;
  if (commonChain && commonChain.length > 0) {
    for (let i = 0; i <= path.length - commonChain.length; i++) {
      if (path.slice(i, i + commonChain.length).every((v, k) => v === commonChain[k])) {
        startIndex = i;
        break;
      }
    }
  }

  const nodeSize = 44; // Diameter of the circle
  const horizontalGap = 25;
  const svgHeight = 50;
  const svgWidth = path.length * nodeSize + (path.length - 1) * horizontalGap;

  return (
    <svg width={svgWidth} height={svgHeight} style={{ overflow: 'visible' }}>
      <defs>
        <marker
          id="arrowhead"
          viewBox="0 0 10 10"
          refX="8"
          refY="5"
          markerWidth="6"
```

```
          markerHeight="6"
          orient="auto-start-reverse"
        >
          <path d="M 0 0 L 10 5 L 0 10 z" fill="#999" />
        </marker>
      </defs>
      <g>
        {path.map((tech, index) => {
          const isHighlighted =
            startIndex !== -1 && index >= startIndex && index < startIndex +
commonChain.length;

          const nodeX = index * (nodeSize + horizontalGap);
          const nodeY = (svgHeight - nodeSize) / 2;

          return (
            <g key={index}>
              {index > 0 && (
                <line
                  x1={(index - 1) * (nodeSize + horizontalGap) + nodeSize}
                  y1={svgHeight / 2}
                  x2={nodeX}
                  y2={svgHeight / 2}
                  stroke="#999"
                  strokeWidth="1.5"
                  markerEnd="url(#arrowhead)"
                />
              )}
              <rect
                x={nodeX}
```

```
            y={nodeY}
            width={nodeSize}
            height={nodeSize}
            rx={nodeSize / 2}
            fill={isHighlighted ? '#fffbe6' : '#fafafa'}
            stroke={isHighlighted ? '#ffe58f' : '#d9d9d9'}
            strokeWidth="1"
          />
          <text
            x={nodeX + nodeSize / 2}
            y={svgHeight / 2}
            textAnchor="middle"
            dominantBaseline="middle"
            fontFamily="monospace"
            fontSize="12px"
            fontWeight={isHighlighted ? 600 : 400}
            fill={isHighlighted ? '#d46b08' : '#555'}
          >
            {tech}
          </text>
        </g>
      );
    })}
  </g>
 </svg>
 );
};

const columns = [
  ...Object.keys(capecList[capecId]).map(el => ({
```

```
title: <span style={{ whiteSpace: 'normal' }}>{el}</span>,
dataIndex: el,
key: el,
width: 90,
ellipsis: true,
render: (text: string) => {
  if (!text) return '-';
  return (
    <span style={{
      display: 'inline-block',
      padding: '4px 8px',
      fontFamily: 'monospace',
      fontWeight: 'bold',
      backgroundColor: '#f0f2f5',
      borderRadius: '4px',
      color: '#262626',
    }}>
      {text}
    </span>
  );
},
onCell: (_, index) => ({
  style: {
    backgroundColor: index % 2 === 0 ? '#ffffff' : '#fafafa',
    color: '#262626',
    fontWeight: 500,
    borderBottom: '1px solid #f0f0f0'
  }
}),
onHeaderCell: () => ({
```

```
      style: {
        backgroundColor: '#1890ff',
        color: '#ffffff',
        fontWeight: 'bold',
        borderBottom: '2px solid #096dd9'
      }
    })
  })),
  {
    title: 'Риск',
    dataIndex: 'risk',
    key: 'risk',
    width: 200,
    align: 'center' as const,
    render: (risk: number, record: any) => {
      const originalRisk = risk;
      const modifiedRisk = record.modifiedRisk;
      // Проверяем originalRisk на 0, чтобы избежать деления на ноль
      const riskReduction = originalRisk !== 0 ? ((originalRisk - modifiedRisk) /
originalRisk) * 100 : 0;

      // console.log('Отображение риска:', {
      //   originalRisk,
      //   modifiedRisk,
      //   riskReduction,
      //   hasMeasures: record.appliedMeasures?.length > 0
      // });

      return (
        <div style={{
```

```
  fontSize: '16px',
  fontWeight: 'bold',
  padding: '8px',
  fontFamily: 'monospace',
  textAlign: 'center',
  background: riskReduction > 0 ? '#f6ffed' : '#fff',
  borderRadius: '4px',
  border: riskReduction > 0 ? '1px solid #b7eb8f' : 'none'
}}>
  <div style={{
    color: modifiedRisk > 0.5 ? '#cf1322' : '#262626',
    marginBottom: '8px'
  }}>
    {(modifiedRisk * 1e14).toFixed(16)}
  </div>

  {selectedMeasures.length > 0 && (
    <div style={{
      fontSize: '12px',
      color: '#8c8c8c',
      borderTop: '1px dashed #d9d9d9',
      paddingTop: '8px',
      marginTop: '8px'
    }}>
      <div style={{ marginBottom: '4px' }}>
        {riskReduction > 0 && !isNaN(riskReduction) ? (
          <span style={{ color: '#52c41a' }}>
            ↓ Снижение риска на {riskReduction.toFixed(1)}%
          </span>
        ) : (
```

```
              <span style={{ color: '#8c8c8c' }}>
                Нет снижения риска
              </span>
            )}
          </div>

          {record.appliedMeasures && record.appliedMeasures.length > 0 && (
            <div style={{ marginTop: '8px' }}>
              {record.appliedMeasures.map(({ measure, reduction }: { measure: SecurityMeasure, reduction: number }) => (
                <Tag
                  key={measure.id}
                  color={measure.priority === 'high' ? 'red' : measure.priority === 'medium' ? 'orange' : 'green'}
                  style={{ margin: '2px' }}
                >
                  {measure.name}: -{reduction.toFixed(1)}%
                </Tag>
              ))}
            </div>
          )}
        </div>
      );
    },
    onCell: (_, index) => ({
      style: {
        backgroundColor: index % 2 === 0 ? '#ffffff' : '#fafafa',
        borderBottom: '1px solid #f0f0f0',
```

```
        borderLeft: '2px solid #1890ff'
      }
    }),
    onHeaderCell: () => ({
      style: {
        backgroundColor: '#1890ff',
        color: '#ffffff',
        fontWeight: 'bold',
        borderBottom: '2px solid #096dd9',
        fontSize: '16px'
      }
    })
  }
];

  const svgRef = useRef<SVGSVGElement>(null);
  const heatmapRef = useRef<SVGSVGElement>(null);
  const sankeyRef = useRef<SVGSVGElement>(null);
  const pieChartRef = useRef<SVGSVGElement>(null);
  const [heatmapData, setHeatmapData] = useState<{ correlationMatrix: number[][],
techniques: string[] } | null>(null);
  const [heatmapSvgDimensions, setHeatmapSvgDimensions] = useState<{ width:
number; height: number }>({ width: 0, height: 0 });
  const [securityAnalysis, setSecurityAnalysis] = useState<string>("");
  const [isAnalyzing, setIsAnalyzing] = useState(false);
  const [analysisError, setAnalysisError] = useState<string | null>(null);
  const [clusterMode, setClusterMode] = useState<'risk' | 'techniques'>('risk');

  useEffect(() => {
    if (!svgRef.current || !formattedScenarios.length) return;
```

```
    // Очищаем предыдущий график
    d3.select(svgRef.current).selectAll("*").remove();

    // Настройки графика (для столбчатой диаграммы техник)
    const margin = { top: 40, right: 40, bottom: 120, left: 150 };
    const width = 1400 - margin.left - margin.right;
    const height = 500 - margin.top - margin.bottom;

    // Создаем SVG
    const svg = d3.select(svgRef.current)
      .attr("width", width + margin.left + margin.right)
      .attr("height", height + margin.top + margin.bottom)
      .append("g")
      .attr("transform", `translate(${margin.left},${margin.top})`);

    // Фильтруем только критические сценарии
    const criticalScenarios = formattedScenarios.filter(scenario =>
calculateRiskLevel(scenario.risk) === 'CRITICAL');

    if (criticalScenarios.length === 0) {
      svg.append("text")
        .attr("x", width / 2)
        .attr("y", height / 2)
        .attr("text-anchor", "middle")
        .style("font-size", "18px")
        .text("Критические сценарии не найдены для анализа техник.");
      return;
    }
```

```
  const techniqueCounts = new Map<string, number>();
  criticalScenarios.forEach(scenario => {
    scenario.path.forEach(technik => {
      techniqueCounts.set(technik, (techniqueCounts.get(technik) || 0) + 1);
    });
  });

  const sortedTechniques = Array.from(techniqueCounts.entries())
    .map(([technik, count]) => ({ technik, count }))
    .sort((a, b) => b.count - a.count);

  const topTechniques = sortedTechniques.slice(0, Math.min(sortedTechniques.length,
20));

  const colorScale = d3.scaleSequential(d3.interpolateBlues)
    .domain([0, d3.max(topTechniques, d => d.count) || 0]);

  const x = d3.scaleBand()
    .range([0, width])
    .domain(topTechniques.map(d => d.technik))
    .padding(0.2);

  const y = d3.scaleLinear()
    .range([height, 0])
    .domain([0, d3.max(topTechniques, d => d.count) || 0]);

  svg.append("g")
    .attr("transform", `translate(0,${height})`)
    .call(d3.axisBottom(x))
    .selectAll("text")
```

```
  .attr("transform", "translate(-10,0)rotate(-45)")
  .style("text-anchor", "end")
  .style("font-size", "12px")
  .style("fill", "#555");

svg.append("g")
  .call(d3.axisLeft(y).ticks(Math.min(d3.max(topTechniques, d => d.count) || 0, 10)))
  .selectAll("text")
  .style("font-size", "12px")
  .style("fill", "#555");

svg.append("text")
  .attr("x", width / 2)
  .attr("y", -margin.top / 2)
  .attr("text-anchor", "middle")
  .style("font-size", "20px")
  .style("font-weight", "bold")
  .style("fill", "#333")
  .text("Топ техник в критических сценариях");

svg.append("text")
  .attr("transform", `translate(${width / 2}, ${height + margin.bottom - 10})`)
  .style("text-anchor", "middle")
  .style("font-size", "14px")
  .style("fill", "#555")
  .text("Техника");

svg.append("text")
  .attr("transform", "rotate(-90)")
  .attr("y", -margin.left + 40)
```

```
  .attr("x", -(height / 2))
  .style("text-anchor", "middle")
  .style("font-size", "14px")
  .style("fill", "#555")
  .text("Частота");

svg.selectAll("rect")
  .data(topTechniques)
  .enter()
  .append("rect")
  .attr("x", d => x(d.technik) || 0)
  .attr("y", d => y(d.count))
  .attr("width", x.bandwidth())
  .attr("height", d => height - y(d.count))
  .attr("fill", d => colorScale(d.count))
  .attr("opacity", 0.9)
  .attr("stroke", "#096dd9")
  .attr("stroke-width", 1)
  .on("mouseover", function(event, d) {
    d3.select(this)
      .attr("opacity", 1)
      .attr("stroke", "#000")
      .attr("stroke-width", 2)
      .style("cursor", "pointer");

    const tooltip = d3.select("body").append("div")
      .attr("class", "tooltip")
      .style("position", "absolute")
      .style("background", "rgba(0, 0, 0, 0.85)")
      .style("color", "white")
```

```
        .style("padding", "8px")
        .style("border-radius", "4px")
        .style("font-size", "13px")
        .style("pointer-events", "none")
        .style("z-index", 1000);

      tooltip.html(`Техника: ${d.technik}<br>Частота в критических сценариях:
${d.count}`)
        .style("left", (event.pageX + 15) + "px")
        .style("top", (event.pageY - 30) + "px");
    })
    .on("mouseout", function() {
      d3.select(this)
        .attr("opacity", 0.9)
        .attr("stroke", "#096dd9")
        .attr("stroke-width", 1)
        .style("cursor", "default");
      d3.selectAll(".tooltip").remove();
    });

  svg.append("g")
    .attr("class", "grid")
    .call(d3.axisLeft(y)
      .ticks(Math.min(d3.max(topTechniques, d => d.count) || 0, 10))
      .tickSize(-width)
      .tickFormat(() => "")
    )
    .style("stroke", "#ddd")
    .style("stroke-dasharray", "3,3");
```

```
}, [formattedScenarios]);

useEffect(() => {
  // Create worker instance
  const worker = new Worker(new URL('./heatmap.worker.ts', import.meta.url));

  // Send data to worker
  worker.postMessage(formattedScenarios);

  // Listen for results from worker
  worker.onmessage = (event) => {
    setHeatmapData(event.data);
  };

  worker.onerror = (error) => {
    console.error('Worker error:', error);
  };

  // Clean up worker on component unmount
  return () => {
    worker.terminate();
  };

}, [formattedScenarios]);

useEffect(() => {
  if (!sankeyRef.current || !formattedScenarios.length) return;

  // Clear previous Sankey content
  d3.select(sankeyRef.current).selectAll("*").remove();
```

```
    const margin = { top: 20, right: 20, bottom: 20, left: 20 };
    const width = window.innerWidth - margin.left - margin.right;
    const height = 1000 - margin.top - margin.bottom;

    const svg = d3.select(sankeyRef.current)
      .attr("width", width + margin.left + margin.right)
      .attr("height", height + margin.top + margin.bottom)
      .append("g")
      .attr("transform", `translate(${margin.left},${margin.top})`);

    const tacticOrder = Object.keys(capecList[capecId]);
    const nodesMap = new Map<string, { name: string, id: string, type: 'tactic' | 'technik'
}>();
    const linksMap = new Map<string, number>();

    // Create nodes and count links from scenarios
    formattedScenarios.forEach(scenario => {
      let previousNodeId: string | null = null;

      scenario.path.forEach((technikName, index) => {
        const currentTactic = tacticOrder[index];
        const tacticNodeId = `tactic:${currentTactic}`;
        const technikNodeId = `technik:${technikName}`;

        // Add tactic node if not exists
        if (!nodesMap.has(tacticNodeId)) {
          nodesMap.set(tacticNodeId, { name: currentTactic, id: tacticNodeId, type: 'tactic' });
        }
```

```
      // Add technik node if not exists
      if (!nodesMap.has(technikNodeId)) {
        nodesMap.set(technikNodeId, { name: technikName, id: technikNodeId, type:
'technik' });
      }

      // Create link from tactic to the first technique in that tactic for this scenario
      if (index === tacticOrder.indexOf(currentTactic)) { // Check if it's the first technique
in this tactic for this scenario
          const linkKey = `${tacticNodeId}->${technikNodeId}`;
          linksMap.set(linkKey, (linksMap.get(linkKey) || 0) + 1);
      }

      // Create link from previous technique to current technique
      if (previousNodeId !== null) {
        const linkKey = `${previousNodeId}->${technikNodeId}`;
        linksMap.set(linkKey, (linksMap.get(linkKey) || 0) + 1);
      }

      previousNodeId = technikNodeId; // Set current technik as previous for the next
iteration
    });
  });

  // Convert maps to arrays for Sankey layout
  const nodes = Array.from(nodesMap.values());
  const links = Array.from(linksMap.entries()).map(([key, value]) => {
    const [sourceId, targetId] = key.split('->');
    const sourceNode = nodes.find(node => node.id === sourceId);
    const targetNode = nodes.find(node => node.id === targetId);
```

```
    return { source: sourceNode, target: targetNode, value: value };
  }).filter(link => link.source && link.target); // Filter out links with missing nodes

  // Initialize the Sankey layout
  const sankeyLayout = sankeyCircular()
    .nodeWidth(30) // Увеличена ширина узлов для четкости
    .nodePadding(60) // Увеличиваем отступ между узлами с 20 до 40 для лучшей различимости линий
    .extent([[1, 1], [width - 1, height - 6]]);

  // Assign nodes and links to the layout
  sankeyLayout.nodes(nodes as any);
  sankeyLayout.links(links as any);

  // Compute the layout (this is where circular link error occurs)
  // If error persists, the issue is in the nodes/links data structure.

  // Compute the layout
  try {
    sankeyLayout(); // Use the layout object
  } catch (error) {
    console.error('Sankey layout error:', error);
    return; // Stop rendering if layout fails
  }

  // Create a color scale for tactics
  const tacticColorScale = d3.scaleOrdinal(d3.schemeCategory10)
    .domain(tacticOrder); // Use the defined tactic order as the domain

  // Add title to the Sankey diagram
```

```
  svg.append("text")
    .attr("x", width / 2)
    .attr("y", -margin.top / 2 + 10) // Position the title above the chart area
    .attr("text-anchor", "middle")
    .style("font-size", "20px")
    .style("font-weight", "bold")
    .text("Потоки техник в сценариях"); // Set the title text

  // Add links (paths)
  const link = svg.append("g")
    .attr("fill", "none")
    .attr("stroke-opacity", 0.5) // Adjust opacity
    .selectAll("path")
    .data(links)
    .join("path")
      .attr("d", d => (d as any).path) // Use the path property on the link object

  // Set stroke color based on source node's tactic
  link.attr("stroke", d => {
    const sourceNode = d.source as any;
    if (sourceNode.type === 'tactic') {
      return tacticColorScale(sourceNode.name);
    } else if (sourceNode.type === 'technik') {
      // Find the tactic for this technique. This assumes a technique belongs to a single
tactic in capecList.
      // A more robust approach might be needed if techniques can belong to multiple
tactics.
      const techniqueTactic = tacticOrder.find(tacticName =>
        capecList[capecId][tacticName].some(tech => tech.technik === sourceNode.name)
      );
```

```
      return techniqueTactic ? tacticColorScale(techniqueTactic) : '#ccc'; // Default to gray if tactic not found
    }
    return '#ccc'; // Default color for unexpected node types
  })
  .attr("stroke-width", d => Math.max(1, d.width || 0));

  // Add link tooltips (optional)
  link.append("title")
    .text(d => `${d.source.name} → ${d.target.name}\nValue: ${d.value}`);

  // Add nodes (rectangles)
  const node = svg.append("g")
    .selectAll("rect")
    .data(nodes)
    .join("rect")
      .attr("x", d => d.x0 || 0)
      .attr("y", d => d.y0 || 0)
      .attr("height", d => (d.y1 || 0) - (d.y0 || 0))
      .attr("width", d => (d.x1 || 0) - (d.x0 || 0))
      .attr("fill", d => d.type === 'tactic' ? "#1f77b4" : "#ff7f0e") // Example colors for tactic/technik
      .append("title") // Add node tooltip
        .text(d => `${d.name}\n${d.type === 'tactic' ? 'Тактика' : 'Техника'}`);

  // Add node labels
  svg.append("g")
    .attr("font-family", "sans-serif")
    .attr("font-size", 23) // Значительно увеличен размер шрифта для максимальной четкости на скриншоте
```

```
      .selectAll("text")
      .data(nodes)
      .join("text")
        .attr("x", d => (d.x0 || 0) < width / 2 ? (d.x1 || 0) + 8 : (d.x0 || 0) - 8) // Увеличиваем
отступ текста с 6 до 8
        .attr("y", d => ((d.y1 || 0) + (d.y0 || 0)) / 2)
        .attr("dy", "0.35em")
        .attr("text-anchor", d => (d.x0 || 0) < width / 2 ? "start" : "end")
        .text(d => d.name);

  }, [formattedScenarios, capecId]);

  useEffect(() => {
    if (!pieChartRef.current || !capecId) return;

    // Очищаем предыдущий график
    d3.select(pieChartRef.current).selectAll("*").remove();

    // Вычисляем ширину и радиус от ширины окна
    const pageWidth = window.innerWidth;
    const margin = { top: 60, right: 200, bottom: 60, left: 200 };
    const width = pageWidth - margin.left - margin.right;
    const height = 800 - margin.top - margin.bottom;
    const radius = Math.min(width, height) / 2;

    const svg = d3.select(pieChartRef.current)
      .attr("width", width + margin.left + margin.right)
      .attr("height", height + margin.top + margin.bottom)
      .append("g")
      .attr("transform", `translate(${width/2 + margin.left},${height/2 + margin.top})`);
```

```
    // Подготавливаем данные
    const data = Object.entries(capecList[capecId]).map(([tactic, techniques]) => ({
      tactic,
      value: (techniques as Technique[]).length
    }));

    // Создаем цветовую шкалу
    const color = d3.scaleOrdinal()
      .domain(data.map(d => d.tactic))
      .range(d3.schemeCategory10);

    // Создаем генератор дуг
    const pie = d3.pie<any>()
      .value(d => d.value)
      .sort(null);

    const arc = d3.arc()
      .innerRadius(radius * 0.5) // Делаем кольцевую диаграмму
      .outerRadius(radius * 0.8);

    const outerArc = d3.arc()
      .innerRadius(radius * 0.9)
      .outerRadius(radius * 0.9);

    // Функция для определения опасности тактики
    const getTacticRisk = (tactic: string) => {
      const techniques = capecList[capecId][tactic];
      return techniques.reduce((sum, tech) => sum + (tech.U * tech.veroyatnost), 0) /
techniques.length;
```

```
};

// Определяем опасные тактики (верхние 30%)
const tacticRisks = Object.keys(capecList[capecId]).map(tactic => ({
  tactic,
  risk: getTacticRisk(tactic)
})).sort((a, b) => b.risk - a.risk);

const dangerousTactics = new Set(
  tacticRisks.slice(0, Math.ceil(tacticRisks.length * 0.3)).map(t => t.tactic)
);

const arcOuter = d3.arc().innerRadius(radius * 0.8).outerRadius(radius * 0.8);
const polyline = svg.selectAll("polyline")
  .data(pie(data))
  .enter()
  .append("polyline")
  .attr("points", function(d: any) {
    // 1. Точка на внешней границе сектора
    const posA = arcOuter.centroid(d);
    // 2. Излом: смещаем по X наружу
    const posB = [...posA];
    posB[0] = posA[0] + (midAngle(d) < Math.PI ? 30 : -30);
    // 3. Конец: ещё дальше по X
    const labelX = radius * 1.35 * (midAngle(d) < Math.PI ? 1 : -1);
    const posC = [labelX, posB[1]];
    return [posA, posB, posC].map(p => p.join(",")).join(" ");
  })
  .style("fill", "none")
  .style("stroke", d => dangerousTactics.has(d.data.tactic) ? "#cf1322" : "#999")
```

```
  .style("stroke-width", d => dangerousTactics.has(d.data.tactic) ? "2px" : "1.5px");

// Функция для переноса строки по пробелу и по длине слова
function wrapLabel(text: string, maxLen: number = 15) {
  const words = text.split(' ');
  let lines: string[] = [];
  words.forEach(word => {
    if (word.length <= maxLen) {
      lines.push(word);
    } else {
      // Разбиваем длинное слово на части по maxLen
      for (let i = 0; i < word.length; i += maxLen) {
        lines.push(word.slice(i, i + maxLen));
      }
    }
  });
  return lines;
}

// Подписи выравниваем по горизонтали с концом линии
const text = svg.selectAll("text")
  .data(pie(data))
  .enter()
  .append("text")
  .attr("x", function(d: any) {
    return radius * 1.35 * (midAngle(d) < Math.PI ? 1 : -1);
  })
  .attr("y", function(d: any) {
    // Используем Y второй точки (излома)
    const posA = arcOuter.centroid(d);
```

```
      const posB = [...posA];
      posB[0] = posA[0] + (midAngle(d) < Math.PI ? 30 : -30);
      return posB[1];
    })
    .attr("dy", ".35em")
    .style("text-anchor", function(d: any) {
      return midAngle(d) < Math.PI ? "start" : "end";
    })
    .selectAll("tspan")
    .data(function(d: any) {
      // Убираем количество техник из боковой метки
      return wrapLabel(d.data.tactic); // Теперь только название тактики
    })
    .enter()
    .append("tspan")
    .attr("x", function(d, i, nodes) {
      return d3.select(nodes[i].parentNode).attr("x");
    })
    .attr("dy", (d, i) => i === 0 ? 0 : "1.2em")
    .text(d => d)
    .style("font-size", "16px")
    .style("fill", function(_, i, nodes) {
      const parentDatum = d3.select(nodes[i].parentNode).datum();
      return dangerousTactics.has(parentDatum.data.tactic) ? "#cf1322" : "#333";
    })
    .style("font-weight", "600")
    .style("text-shadow", function(_, i, nodes) {
      const parentDatum = d3.select(nodes[i].parentNode).datum();
      return dangerousTactics.has(parentDatum.data.tactic) ? "0 0 1px rgba(207,19,34,0.2)"
: "none";
```

```
  });

// Добавляем количество техник прямо на сегмент
svg.selectAll(".count-label")
  .data(pie(data))
  .enter()
  .append("text")
  .attr("class", "count-label")
  .attr("transform", (d: any) => `translate(${arc.centroid(d)})`)
  .attr("dy", "1.6em") // Смещаем ниже для размещения под риском
  .style("font-size", "12px")
  .style("font-weight", "bold")
  .style("text-anchor", "middle")
  .style("fill", "white")
  .text((d: any) => `${d.data.value} техник`);

// Улучшаем заголовок
svg.append("text")
  .attr("x", 0)
  .attr("y", -height/2 - margin.top/2)
  .attr("text-anchor", "middle")
  .style("font-size", "24px") // Увеличиваем размер заголовка
  .style("font-weight", "bold")
  .style("fill", "#333")
  .text("Распределение техник по тактикам");

// Добавляем подзаголовок с общим количеством техник
// svg.append("text") ... (блок с totalTechniques) — удалить

// Улучшаем сектора
```

```
    const path = svg.selectAll("path")
      .data(pie(data))
      .enter()
      .append("path")
      .attr("d", arc as any)
      .attr("fill", d => dangerousTactics.has(d.data.tactic) ?
        d3.color(color(d.data.tactic)).darker(0.2) : // Делаем цвет темнее для опасных тактик
        color(d.data.tactic))
      .attr("stroke", "white")
      .style("stroke-width", d => dangerousTactics.has(d.data.tactic) ? "3px" : "2px") // Толще обводка для опасных тактик
      .style("opacity", 0.9) // Увеличиваем начальную прозрачность
      .on("mouseover", function(event, d: any) {
        d3.select(this)
          .style("opacity", 1)
          .style("cursor", "pointer");

        // Добавляем всплывающую подсказку с информацией о риске
        const tooltip = d3.select("body").append("div")
          .attr("class", "tooltip")
          .style("position", "absolute")
          .style("background", "rgba(0, 0, 0, 0.85)")
          .style("color", "white")
          .style("padding", "8px")
          .style("border-radius", "4px")
          .style("font-size", "14px")
          .style("pointer-events", "none")
          .style("z-index", 1000);
```

```
    const risk = getTacticRisk(d.data.tactic);
    tooltip.html(`
      <strong>${d.data.tactic}</strong><br>
      Количество техник: ${d.data.value}<br>
      Средний риск: ${(risk * 100).toFixed(2)}%
    `)
      .style("left", (event.pageX + 15) + "px")
      .style("top", (event.pageY - 30) + "px");
  })
  .on("mouseout", function() {
    d3.select(this)
      .style("opacity", 0.9);
    d3.selectAll(".tooltip").remove();
  });

// Добавляем текст среднего риска прямо на сегмент
svg.selectAll(".risk-label")
  .data(pie(data))
  .enter()
  .append("text")
  .attr("class", "risk-label")
  .attr("transform", (d: any) => `translate(${arc.centroid(d)})`)
  .attr("dy", "0.35em") // Выравнивание по центру
  .style("font-size", "12px")
  .style("font-weight", "bold")
  .style("text-anchor", "middle")
  .style("fill", "white") // Белый цвет для контраста
  .text((d: any) => `${(getTacticRisk(d.data.tactic) * 100).toFixed(1)}%`);

// Вспомогательная функция для определения положения подписи
```

```
  function midAngle(d: any) {
    return d.startAngle + (d.endAngle - d.startAngle) / 2;
  }

}, [capecId]);

useEffect(() => {
  const analyzeSecurity = async () => {
    if (!formattedScenarios.length || !useAI) return;

    setIsAnalyzing(true);
    setAnalysisError(null);

    try {
      // Подготовка данных для анализа
      const criticalScenarios = formattedScenarios
        .filter(scenario => calculateRiskLevel(scenario.risk) === 'CRITICAL')
        .slice(0, 10);

      const currentCapec = capecList[capecId || ''] as Record<string, Technique[]>;
      if (!currentCapec) {
        throw new Error('Invalid CAPEC ID');
      }

      // Собираем данные из всех визуализаций
      const visualizationData: AnalysisData['visualizationData'] = {
        // Данные из столбчатой диаграммы (топ техники)
        topTechniques: Array.from(new Map(
          criticalScenarios.flatMap(scenario =>
            scenario.path.map(technik => [technik, 1])
```

```
      ).reduce((acc, [technik, count]) => {
        acc.set(technik, (acc.get(technik) || 0) + count);
        return acc;
      }, new Map())
    ).entries())
      .map(([technik, count]) => ({ technik, count }))
      .sort((a, b) => b.count - a.count)
      .slice(0, 20),

    // Данные из тепловой карты (корреляции)
    techniqueCorrelations: heatmapData ? {
      matrix: heatmapData.correlationMatrix,
      techniques: heatmapData.techniques
    } : null,

    // Данные из круговой диаграммы (распределение по тактикам)
    tacticDistribution: Object.entries(currentCapec).map(([tactic, techniques]) => ({
      tactic,
      techniqueCount: techniques.length,
      averageRisk: techniques.reduce((sum, tech) => sum + (tech.U * tech.veroyatnost),
0) / techniques.length
    })).sort((a, b) => b.averageRisk - a.averageRisk),

    // Общая статистика рисков
    riskStatistics: {
      critical: modifiedCriticalScenariosCount,
      medium: formattedScenarios.filter(scenario => calculateRiskLevel(scenario.risk)
=== 'MEDIUM').length,
      low: formattedScenarios.filter(scenario => calculateRiskLevel(scenario.risk) ===
'LOW').length,
```

```
    total: formattedScenarios.length
  }
};

const analysisData: AnalysisData = {
  capecId: capecId || '',
  criticalScenarios: criticalScenarios.map(scenario => ({
    path: scenario.path,
    risk: scenario.risk
  })),
  techniqueStats: Object.entries(currentCapec).map(([tactic, techniques]) => ({
    tactic,
    techniques: techniques.map(t => ({
      id: t.technik,
      probability: t.veroyatnost,
      impact: t.U
    }))
  })),
  visualizationData
};

const response = await openai.chat.completions.create({
  messages: [
    {
      role: "system",
      content: "
  model: "deepseek-chat",
});
```

```
        setSecurityAnalysis(response.choices[0].message.content || "Нет доступного
анализа");
      } catch (error) {
        console.error('Error analyzing security:', error);
        setAnalysisError('Failed to generate security analysis. Please try again later.');
      } finally {
        setIsAnalyzing(false);
      }
    };

    analyzeSecurity();
  }, [formattedScenarios, capecId, heatmapData, useAI, modifiedCriticalScenariosCount]);

  // Функция для получения доступных мер защиты на основе критических
сценариев
  const getAvailableMeasures = () => {
    const criticalScenarios = formattedScenarios
      .filter(scenario => calculateRiskLevel(scenario.risk) === 'CRITICAL')
      .slice(0, 10);

    // Собираем все уникальные техники из критических сценариев
    const criticalTechniques = new Set<string>();
    criticalScenarios.forEach(scenario => {
      scenario.path.forEach(tech => criticalTechniques.add(tech));
    });

    console.log('Критические техники:', Array.from(criticalTechniques));

    // Фильтруем меры, которые могут быть применены к критическим техникам
    const applicableMeasures = securityMeasures.filter(measure => {
```

```
      const hasMatchingTechniques = measure.techniques.some(tech =>
        Array.from(criticalTechniques).some(criticalTech =>
          criticalTech.toLowerCase().includes(tech.toLowerCase()) ||
          tech.toLowerCase().includes(criticalTech.toLowerCase())
        )
      );
      return hasMatchingTechniques;
    });

    console.log('Доступные меры:', applicableMeasures);

    // Если нет подходящих мер, показываем все меры
    if (applicableMeasures.length === 0) {
      console.log('Не найдено точных совпадений, показываем все меры');
      setAvailableMeasures(securityMeasures);
    } else {
      setAvailableMeasures(applicableMeasures);
    }
  };

  // Загружаем доступные меры при монтировании компонента и при изменении
сценариев
  useEffect(() => {
    if (formattedScenarios.length > 0) {
      getAvailableMeasures();
    }
  }, [formattedScenarios]);

  return (
```

```
    <div style={{ width: '100vw', display: 'flex', flexDirection: 'column', alignItems:
'center', justifyContent: 'center' }}>
      <Statistic title={
        <div style={{
          background: 'linear-gradient(135deg, #1890ff, #096dd9)',
          padding: '20px 40px',
          borderRadius: '16px',
          boxShadow: '0 4px 12px rgba(0,0,0,0.1)',
          marginBottom: '20px'
        }}>
          <Typography.Title style={{
            fontSize: 40,
            textAlign: 'center',
            margin: 0,
            color: '#ffffff',
            textShadow: '2px 2px 4px rgba(0,0,0,0.2)',
            letterSpacing: '1px'
          }} level={1}>
          {capecId}
          </Typography.Title>
        </div>
      } value={formattedScenarios.length} formatter={(value) => (
        <div style={{
          textAlign: 'center',
          color: '#cf1322',
          fontSize: 80,
          fontWeight: 'bold',
          textShadow: '2px 2px 4px rgba(0,0,0,0.1)',
          background: 'linear-gradient(45deg, #fafafa, #f0f0f0)',
          padding: '20px 40px',
```

```
    borderRadius: '16px',
    boxShadow: '0 4px 12px rgba(0,0,0,0.1)'
  }}>
     <CountUp end={value as number} separator="," />
    <Typography.Title style={{
      fontSize: 40,
      fontWeight: 'bold',
      margin: 0,
      display: 'inline-flex',
      marginLeft: 20,
      color: '#262626'
    }} level={4}>сценария</Typography.Title>
  </div>
)} />

<div style={{
  display: 'flex',
  gap: '20px',
  margin: '20px 0',
  justifyContent: 'center'
}}>
  <div style={{
    padding: '20px 40px',
    background: 'linear-gradient(45deg, #fff1f0, #ffccc7)',
    borderRadius: '16px',
    boxShadow: '0 4px 12px rgba(0,0,0,0.1)',
    flex: 1,
    maxWidth: '300px'
  }}>
```

```
        <Typography.Title level={3} style={{ margin: 0, color: '#cf1322', textAlign: 'center' }}>
          Критических сценариев: <CountUp end={modifiedCriticalScenariosCount} separator="," />
        </Typography.Title>
        <Typography.Text style={{ display: 'block', textAlign: 'center', marginTop: '10px', color: '#820014' }}>
          {selectedMeasures.length > 0 ? 'После применения мер' : 'Исходный риск'}
        </Typography.Text>
      </div>

      <div style={{
        padding: '20px 40px',
        background: 'linear-gradient(45deg, #fff7e6, #ffe7ba)',
        borderRadius: '16px',
        boxShadow: '0 4px 12px rgba(0,0,0,0.1)',
        flex: 1,
        maxWidth: '300px'
      }}>
        <Typography.Title level={3} style={{ margin: 0, color: '#d46b08', textAlign: 'center' }}>
          Средних сценариев: <CountUp end={formattedScenarios.filter(scenario => calculateRiskLevel(scenario.risk) === 'MEDIUM').length} separator="," />
        </Typography.Title>
        <Typography.Text style={{ display: 'block', textAlign: 'center', marginTop: '10px', color: '#873800' }}>
          (Риск ≥ 0.000001)
        </Typography.Text>
        <Typography.Text style={{ display: 'block', textAlign: 'center', marginTop: '5px', color: '#873800', fontSize: '12px' }}>
```

```
          По методологии NIST SP 800-30
        </Typography.Text>
      </div>

      <div style={{
        padding: '20px 40px',
        background: 'linear-gradient(45deg, #f6ffed, #b7eb8f)',
        borderRadius: '16px',
        boxShadow: '0 4px 12px rgba(0,0,0,0.1)',
        flex: 1,
        maxWidth: '300px'
      }}>
        <Typography.Title level={3} style={{ margin: 0, color: '#389e0d', textAlign:
'center' }}>
          Минимальных сценариев: <CountUp end={formattedScenarios.filter(scenario =>
calculateRiskLevel(scenario.risk) === 'LOW').length} separator="," />
        </Typography.Title>
        <Typography.Text style={{ display: 'block', textAlign: 'center', marginTop: '10px',
color: '#135200' }}>
          (Риск &lt; 0.000001)
        </Typography.Text>
        <Typography.Text style={{ display: 'block', textAlign: 'center', marginTop: '5px',
color: '#135200', fontSize: '12px' }}>
          По методологии NIST SP 800-30
        </Typography.Text>
      </div>
    </div>

    <div style={{
      margin: '20px 0',
```

```
        padding: '20px',
        background: '#fff',
        borderRadius: '8px',
        boxShadow: '0 2px 8px rgba(0,0,0,0.1)',
        width: '100%',
        maxWidth: '1400px',
        overflowX: 'auto'
      }}>
        <svg ref={svgRef}></svg>
      </div>

      <div style={{
        margin: '20px 0',
        padding: '20px',
        background: '#fff',
        borderRadius: '8px',
        boxShadow: '0 2px 8px rgba(0,0,0,0.1)',
        width: '100%',
        maxWidth: '1400px',
        overflowX: 'auto'
      }}>
        <svg ref={heatmapRef} width={heatmapSvgDimensions.width}
height={heatmapSvgDimensions.height}></svg>
      </div>

      <div style={{
        margin: '20px 0',
        padding: '20px',
        background: '#fff',
        borderRadius: '8px',
```

```
  boxShadow: '0 2px 8px rgba(0,0,0,0.1)',
  width: '100%',
  maxWidth: '100%',
  overflowX: 'auto'
}}>
  <svg ref={sankeyRef} style={{ width: '100%', height: 'auto' }}></svg>
</div>

<div style={{
  margin: '20px 0',
  padding: '20px',
  background: '#fff',
  borderRadius: '8px',
  boxShadow: '0 2px 8px rgba(0,0,0,0.1)',
  width: '100vw',
  maxWidth: '100vw',
  overflowX: 'auto',
  display: 'flex',
  justifyContent: 'center',
  alignItems: 'center'
}}>
  <svg ref={pieChartRef}></svg>
</div>

<Table
  pagination={false}
  columns={columns}
  dataSource={currentScenarios.map((scenario, idx) => ({
    key: idx.toString(),
    ...Object.fromEntries(
```

```
          scenario.path.map((technique, index) => [
            Object.keys(capecList[capecId])[index],
            technique
          ])
        ),
        risk: scenario.risk,
        modifiedRisk: scenario.modifiedRisk,
        appliedMeasures: scenario.appliedMeasures
      }))}
      size="small"
      scroll={{ x: 'max-content' }}
      style={{
        marginBottom: 16,
        border: '1px solid #1890ff',
        borderRadius: '8px',
        overflow: 'hidden',
        boxShadow: '0 2px 8px rgba(0,0,0,0.1)'
      }}
    />
    <Pagination onChange={setCurrentPage} style={{ marginTop: 2 }}
defaultCurrent={1} total={totalPages} current={currentPage} />

    {/* Security Analysis Section */}
    {useAI && (
      <Card
        title="Анализ безопасности и рекомендации"
        style={{ marginTop: '20px', marginBottom: '20px' }}
      >
        {isAnalyzing ? (
          <div style={{ textAlign: 'center', padding: '20px' }}>
```

```
        <Spin size="large" />
        <p style={{ marginTop: '10px' }}>Анализ данных безопасности...</p>
      </div>
    ) : analysisError ? (
      <Alert
        message="Ошибка"
        description={analysisError}
        type="error"
        showIcon
      />
    ) : (
      <div style={{
        padding: '20px',
        background: '#fafafa',
        borderRadius: '8px',
        fontSize: '16px',
        lineHeight: '1.6'
      }}>
        <ReactMarkdown>
          {securityAnalysis}
        </ReactMarkdown>
      </div>
    )}
  </Card>
)}

{/* Панель конструктора мер защиты */}
<Card
  title="Конструктор мер защиты"
```

```
      style={{ marginTop: '20px', marginBottom: '20px', width: '100%', maxWidth:
'1400px' }}
    >
      <Space direction="vertical" style={{ width: '100%' }}>
        {availableMeasures.length === 0 ? (
          <Alert
            message="Загрузка мер защиты..."
            description="Пожалуйста, подождите, пока система анализирует сценарии и
подбирает подходящие меры защиты."
            type="info"
            showIcon
          />
        ) : (
          <List
            grid={{ gutter: 16, column: 2 }}
            itemLayout="vertical"
            dataSource={availableMeasures}
            renderItem={measure => (
              <List.Item>
                <Card>
                  <Space direction="vertical" style={{ width: '100%' }}>
                    <div style={{ display: 'flex', justifyContent: 'space-between', alignItems:
'center' }}>
                      <Typography.Title level={4} style={{ margin: 0
}}>{measure.name}</Typography.Title>
                      <Space>
                        <Tag color={measure.priority === 'high' ? 'red' : measure.priority ===
'medium' ? 'orange' : 'green'}>
                          Приоритет: {measure.priority.toUpperCase()}
                        </Tag>
```

```
                <Tag color="blue">
                  Эффективность: {(measure.effectiveness * 100).toFixed(0)}%
                </Tag>
              </Space>
            </div>

            <Typography.Text>{measure.description}</Typography.Text>

            <div>
              <Typography.Text strong>Противодействующие
техники:</Typography.Text>
              <div style={{ marginTop: '8px' }}>
                {measure.techniques.map(technique => (
                  <Tag key={technique} style={{ margin: '4px' }}>{technique}</Tag>
                ))}
              </div>
            </div>

            <div>
              <Typography.Text strong>Шаги по внедрению:</Typography.Text>
              <div style={{
                marginTop: '8px',
                padding: '12px',
                background: '#f5f5f5',
                borderRadius: '4px',
                whiteSpace: 'pre-line'
              }}>
                {measure.implementation}
              </div>
            </div>
```

```
                <Button
                  type={selectedMeasures.some(m => m.id === measure.id) ? "primary" :
"default"}
                  onClick={() => {
                    setSelectedMeasures(prev =>
                      prev.some(m => m.id === measure.id)
                        ? prev.filter(m => m.id !== measure.id)
                        : [...prev, measure]
                    );
                  }}
                >
                  {selectedMeasures.some(m => m.id === measure.id) ? "Отменить меру" :
"Применить меру"}
                </Button>
              </Space>
            </Card>
          </List.Item>
        )}
      />
    )}
  </Space>
</Card>

{/* Scenario Clustering Section */}
<Card
  title="Кластеризация сценариев по схожим техникам"
  style={{ marginTop: '20px', width: '100%', maxWidth: '1400px' }}
>
  <div>
```

```
<Row gutter={[16, 16]}>
  {clustersByTechniques.map((cluster, index) => (
    <Col span={12} key={index}>
      <Card
        title={`${cluster.name} (${cluster.scenarios.length} сценариев)`}
        extra={cluster.commonChain && cluster.commonChain.length > 0 && (
          <Tag color="gold">
            Общий паттерн: {cluster.commonChain.join(' → ')}
          </Tag>
        )}
      >
        <List
          size="small"
          dataSource={cluster.scenarios.slice(0, 5)} // Limit to 5 for preview
          renderItem={(scenario: any) => (
            <List.Item>
              <div style={{ overflowX: 'auto', padding: '10px 0' }}>
                {renderScenarioGraph(scenario.path, cluster.commonChain)}
              </div>
            </List.Item>
          )}
          footer={
            cluster.scenarios.length > 5 ? (
              <div style={{ textAlign: 'center', color: '#888', fontStyle: 'italic' }}>
                ... и еще {cluster.scenarios.length - 5} сценариев
              </div>
            ) : null
          }
        />
      </Card>
```

```
            </Col>
          ))}
        </Row>
      </div>
    </Card>
  </div>
 );
}
```